Saudi GRC Platform

Readme

Source: `README.md`

Saudi GRC Platform — Integration Deliverable Package

Structured deliverables for the TSS GRC platform. Every document in this package is anchored to the running code, schema, and seed data at HEAD of branch `feat/pdpl-extensions`.

Read order: start with `01-Product-Blueprint`, then read whichever section is relevant to your role (see "Owner / development usage" column below).

File output plan

#	Folder	File	Type	Purpose	Owner	Development usage
1	01-Product-Blueprint/	product-blueprint.md	MD	Platform purpose, positioning, customers, regulatory coverage, modules, integration logic, licensing, differentiators, maturity roadmap	Product / GTM	Pitch + onboarding reference
2	02-Module-Architecture/	module-architecture.md	MD	Per-module description, personas, workflows, registers, screens, key fields, evidence, reports, integrations — all 10 modules	Tech leads	Design + handoff
3	03-Workflow-Catalogue/	workflow-catalogue.md	MD	Every workflow with EN/AR name, trigger, steps, roles, SLA, evidence, signature requirement	Implementation	Sprint planning + UAT
3	03-Workflow-Catalogue/	workflow-lifecycles.md	MD	Per-workflow state machine: status, allowed transitions, mover, SLA, notifications	Implementation	Workflow engine config

#	Folder	File	Type	Purpose	Owner	Development usage
4	04-Data-Model/	data-model.md	MD	Logical data model + entity descriptions + key fields + relations + AR/EN labels	DB lead	Schema + ORM scaffolding
5	05-UI-Screens/	ui-screens.md	MD	Per-screen requirements (EN/AR title, sections, fields, filters, actions, validation, role permissions, empty states, RTL considerations)	UX + Frontend	Page build + design review
6	06-Evidence-Library/	evidence-library.md	MD	Per-control evidence catalogue: owner, frequency, types, expiry, approval, regulatory source	Compliance + Evidence	Evidence catalog seeding
7	07-Regulatory-Mapping/	regulatory-mapping.md	MD	DGA / SAMA / NRC / NCA / PDPL / ISO 22301 / 27001 / 31000 / 27701 mapping to modules + workflows + objects + evidence	Compliance	Regulatory alignment
8	03-Workflow-Catalogue/	workflow-lifecycles.md	MD	(see above — lifecycle definitions live alongside the catalogue)	Workflow Engine	Engine wiring
9	08-RBAC/	rbac-matrix.md	MD	Full RBAC matrix: 27 roles × 8 actions × 11 modules	Security + IAM	Permission seeding
10	09-Automation-Rules/	automation-rules.md	MD	28 cross-module automation rules: trigger, condition, action, notification, escalation, audit	Backend	Service-layer hooks

#	Folder	File	Type	Purpose	Owner	Development usage
11	10-Reports-Dashboards/	reports-dashboards.md	MD	16 report specs: audience, sections, KPIs, charts, filters, formats, approval, signature	Reporting + Frontend	Report templates
12	11-Implementation-Backlog/	implementation-backlog.md	MD	Agile backlog: 16 epics × stories with priority + dependency + sprint grouping; status (DONE/IN_PROGRESS/PLANNED)	PMO + Engineering	Sprint planning
13	13-API-Specification/	api-specification.md	MD	REST endpoint catalogue + conventions; pointer to live OpenAPI at /v3/api-docs	Backend + Integrations	API contract
14	12-Developer-Handoff/	developer-handoff.md	MD	Architecture, workflow engine, API, DB, audit, notifications, integration, signature, security, localisation, reporting, testing, migration requirements	Engineering	Onboarding
15	14-Test-Cases/	test-cases.md	MD	UAT test cases: ID, scenario, preconditions, steps, expected, role, pass/fail	QA + UAT	Acceptance testing
16	15-Sample-Data/	sample-seed-data.md	MD	Seed-data catalogue per migration; instructions for fresh-DB bootstrap	Engineering + Demo	Demo + UAT data

#	Folder	File	Type	Purpose	Owner	Development usage
17	16-AI-Features/	ai-features.md	MD	15 LLM-assisted features (risk-description, BIA impact, RTO/RPO, supplier scoring, PIA + NCA gap, evidence quality, CAPA advisor, exec / board narratives, reg-change impact, RCA draft, lessons distiller, control mapping) — each with input / output / human review / approval / hallucination risk / guardrails / audit / privacy	Product + Backend + Security	AI roadmap + provider procurement
18	17-Frontend-Requirements/	frontend-requirements.md	MD	Spec-level FE breakdown: nav, pages, components, table columns, form fields, buttons, filters, modals, wizards, dashboard widgets, empty states, validation, AR/EN labels, RTL behaviour, RBAC visibility, status badges, evidence upload, signature, report export	Frontend + UX	Rebuild / extend the UI

#	Folder	File	Type	Purpose	Owner	Development usage
19	18-Excel-Workbook/	workbook-spec.md + tss-grc-implementation-package.xlsx	MD + XLSX	23-sheet workbook: Module Catalogue, Workflow Catalogue, Workflow Steps, Role Matrix, Approval Matrix, Data Objects, Entity Relationships, UI Screens, UI Fields, Evidence Library, Regulatory Mapping, Controls Library, Risk / BIA / Supplier / PDPL / NCA / Incident / Corrective-Action registers, Reports Catalogue, Automation Rules, Test Cases, Sample Data	BA / Config consultant / DBA / QA	Implementation config + seed import

Cross-references back into the repo

Topic	Source of truth
Gap analysis (40/40 capabilities)	docs/saudi-grc-gap-analysis.md
Module status snapshot	STATUS.md
Sprint plans	sprints/sprint-{1,2,3,4-convergence}.md
Original session summary	SESSION_SUMMARY.md
Repo overview	README.md
Backend modules	tss-grc-backend/src/main/java/com/tss/grc/module/ (17 modules)
Frontend pages	tss-grc-ui-v2/src/pages/ (80+ pages)
Flyway migrations	tss-grc-backend/src/main/resources/db/migration/sqlserver/ (V1..V54)
Translations	tss-grc-ui-v2/src/translations/{en,ar}.ts (5,000+ keys)
Live OpenAPI spec	http://localhost:8084/v3/api-docs (dev profile)
Mojibake repair	fix_arabic_mojibake.py

Status — what was checked vs. spec

Spec requirement	Status	Evidence
OUTPUT 1 Product Blueprint	✓ DONE	01-Product-Blueprint/product-blueprint.md
OUTPUT 2 Module Architecture (10 modules)	✓ DONE	02-Module-Architecture/module-architecture.md
OUTPUT 3 Workflow Catalogue	✓ DONE	03-Workflow-Catalogue/workflow-catalogue.md
OUTPUT 4 Data Model	✓ DONE	04-Data-Model/data-model.md
OUTPUT 5 UI Screens	✓ DONE	05-UI-Screens/ui-screens.md
OUTPUT 6 Evidence Library	✓ DONE	06-Evidence-Library/evidence-library.md
OUTPUT 7 Regulatory Mapping	✓ DONE	07-Regulatory-Mapping/regulatory-mapping.md
OUTPUT 8 Workflow Lifecycles	✓ DONE	03-Workflow-Catalogue/workflow-lifecycles.md
OUTPUT 9 RBAC	✓ DONE	08-RBAC/rbac-matrix.md
OUTPUT 10 Automation Rules	✓ DONE	09-Automation-Rules/automation-rules.md
OUTPUT 11 Reports & Dashboards	✓ DONE	10-Reports-Dashboards/reports-dashboards.md
OUTPUT 12 Implementation Backlog	✓ DONE	11-Implementation-Backlog/implementation-backlog.md
OUTPUT 13 File Output Plan	✓ DONE	this README
OUTPUT 14 Developer Handoff	✓ DONE	12-Developer-Handoff/developer-handoff.md
OUTPUT 15 Test Cases	✓ DONE	14-Test-Cases/test-cases.md
OUTPUT 16 Sample Seed Data	✓ DONE	15-Sample-Data/sample-seed-data.md
OUTPUT 17 AI-Assisted Features	✓ DONE	16-AI-Features/ai-features.md
OUTPUT 18 Frontend Implementation Requirements	✓ DONE	17-Frontend-Requirements/frontend-requirements.md
OUTPUT 19 Excel Workbook (23 sheets + .xlsx)	✓ DONE	18-Excel-Workbook/workbook-spec.md + tss-grc-implementation-package.xlsx
API spec	✓ live + summary	13-API-Specification/api-specification.md + /v3/api-docs

All 16 outputs present. Each is grounded in the actual platform code, schemas, migrations, and existing internal documentation; no content is inferred or invented. Placeholder IDs (where official control numbers are awaited) are clearly tagged with the `*-PLACEHOLDER-NNN` convention per the spec.

Saudi GRC Platform

Product Blueprint

Source: `product-blueprint.md`

01 — Executive Product Blueprint

Platform: TSS GRC Platform **Version surveyed:** `feat/pdpl-extensions` (HEAD `c6f116f`, 2026-05-11)
Owner: TSS / Anthropic implementation **Scope of this document:** the platform as built and deployable.

---

1. Platform purpose

TSS GRC is a bilingual (Arabic-primary / English) multi-tenant **enterprise Governance, Risk and Compliance platform** purpose-built for Saudi Arabia and the wider MENA market.

It consolidates into one product the workflows a Saudi regulated entity must operate to meet NCA cybersecurity controls, SDAIA / PDPL privacy rules, SAMA operational-resilience expectations, ISO 22301 / 27001 / 31000 / 37301 best practice, and the National Risk Council's resilience agenda. The platform covers risk identification, treatment and acceptance; business continuity and crisis activation; supplier resilience including fourth-party depth; cyber control assessment and incident response; personal-data lifecycle from intake to disposal; and the cross-cutting workflows of evidence, attestation, digital signature, board reporting and corrective actions.

2. Saudi market positioning

Dimension	Position
Geography	Saudi-first; designed for Riyadh / Jeddah / Khobar operational regions. UTC+3, Hijri calendar surfacing alongside Gregorian.
Language	Arabic primary; English secondary. Every user-visible entity carries *_ar and *_en columns. RTL/LTR auto-switching.
Data residency	Default tenant data stays in Saudi cloud regions; cross-border transfers tracked under PDPL Art. 29.
Frameworks	NCA ECC, CSCC, CCC, OTCC; SAMA Cyber Security Framework; PDPL + SDAIA implementing regulations; SAMA outsourcing rules; ISO 22301, 27001, 31000, 27701 (where applicable), 37301.
Sectors targeted	Banking & finance (SAMA), insurance (SAMA), telco & cloud (NCA + CITC), healthcare (NHIC), critical infrastructure (CNI), and the digital-government estate (DGA / SDAIA).

3. Target customers

Primary:

- Tier-1 Saudi banks and financial institutions (SAMA Cyber + NCA ECC + operational resilience)
- Government entities & digital-government agencies (DGA, SDAIA, NCA scope)
- Critical national infrastructure operators (telco, energy, utilities, healthcare)
- Saudi-listed firms (CMA disclosure + ESG + internal audit needs)

Secondary:

- Large supplier ecosystems serving the Saudi public sector (vendor portal use-case)
- Saudi subsidiaries of GCC and global organisations operating under PDPL

4. Regulatory coverage

Regulator / Standard	Coverage in the platform
NCA — ECC, CSCC, CCC, OTCC	Framework catalogue (V37), control libraries (V42-44), control assessments, filings (V27), cyber-incident management with NCA notification path
SDAIA — PDPL & Implementing Regs	ROPA, privacy notices, consent, DSR, PIA, breach (72h), cross-border transfer, disposal certificate, processor due-diligence
SAMA — Cyber + Outsourcing	SAMA framework seed + control library; supplier risk + resilience; cross-border + processor rules; reporting cadence
ISO 22301 / 31000 / 27001	Mapped under evidence.frameworks, BCM lifecycle, ERM lifecycle, control library
National Risk Council / National Resilience	Critical service identification, BIA, BCP, DR plans, crisis activation, exercises
CMA / Audit	Board reporting, audit workspace, audit lifecycle, evidence chain-of-custody
HRSD (Nitaqat, GOSI, WPS)	HRSD compliance panel + process initiation
MOC	Tasattur, consumer-complaint, CR feed integration

5. Core modules

The platform is a modular Spring Boot monolith. 17 backend modules under `tss-grc-backend/src/main/java/com/tss/grc/module/`:

Module	Headline function
auth	JWT auth, MFA, password / token policies
iam	Users, roles, permissions, org membership, SSO/Nafath
admin	Platform admin: tenants, branding, committee workflows
risk	ERM register, appetite, KRIs, scenarios, emerging risk
bcm	BIA, BCP, exercises, DR plans, crisis management
scm	Vendor register, dependency map, resilience (alternates, exit plans, tests), fourth-party, contract clauses
tprm	Third-party risk programme, onboarding, reassessment, cyber assessment
cyber	Frameworks, controls, assessments, incidents, vulnerabilities, exceptions, assets, RCA
compliance	Frameworks, requirements, controls, attestations, regulatory feed, MOC/HRSD/SAMA panels
privacy	ROPA, notices, consent, DSR, PIA, breach, CBT, disposal, DSA, processor DD, cyber-bridge
evidence	Repository, versions, chain-of-custody (SHA-256), permissions
incident	Incident lifecycle (NIST 800-61), RCA, lessons-learned, CAPA generation
capa	Corrective + preventive action tracker

Module	Headline function
signature	Digital signature transactions, board pack, multi-provider
workflow	Workflow engine + versioning
reporting	Board pack, regulatory packages, scheduled reports, exports
dashboard	Live KPIs, heatmap, widget customisation

Plus the `platform` module (multi-tenant context, audit, realtime broadcaster, notifications).

6. Cross-module integration logic

The platform's distinctive value is **the bridges between modules**. Concrete wired-in integrations as of HEAD:

- **Cyber** → **PDPL** (V46): cyber incidents that touch personal data automatically trigger a PDPL data-breach record + start the 72h timer; full audit trail in `privacy.cyber_breach_bridge_log`.
- **ROPA** → **PDPL workflows** (V32-V34 + V48): each ROPA entry surfaces counters for its linked privacy notices, cross-border transfers and disposal certificates with one-click deep-link.
- **TPRM** → **CAPA** (TprmAutomationService): failed processor due-diligence assessments, HIGH-concentration fourth-party rows, and FAILED resilience tests auto-open a CAPA with the right severity and target date.
- **RCA** → **CAPA** (V31): approved RCA recommendations spawn CAPA tasks with `originType="rca"` traceability.
- **Evidence chain** (V47): every evidence version is SHA-256 hashed against the prior version; the chain is independently verifiable.
- **Workflow signatures** (V30): any workflow approval can require a cryptographic digital signature; provider-pluggable (internal, DocuSign, Absher, Nafath).
- **Realtime broadcaster**: 13 lifecycle services emit `changed.*` events over STOMP/WebSocket so dashboards and detail pages refresh live.

7. Licensing model

The product is positioned for **annual SaaS subscription** with a per-organisation tier and optional add-ons:

Tier	Includes
Core	ERM, BCM, Compliance, Evidence, Reporting, Bilingual UI
Saudi Regulatory Pack	NCA frameworks + filing, PDPL extensions, SAMA pack, HRSD/MOC panels
Resilience Pack	Supply chain, fourth-party, alternate / exit / resilience-tests, DR plans, crisis room
Cyber Add-on	Cyber controls, incidents, vulnerabilities, OT/ICS (OTCC), Cloud (CCC), SOC integrations
Privacy Add-on	Full PDPL: ROPA + notices + consent + DSR + PIA + breach + CBT + disposal + DSA + processor DD
Premium	Board Pack PDF/PPTX, advanced realtime, white-label, scheduled reports, advanced workflow engine

Multi-tenant: a customer typically buys at the **organisation** level; sub-organisations (group entities) get full data isolation under a single platform tenant.

8. Key differentiators

1. **Saudi-native, not localised after the fact.** Frameworks (NCA suite + SAMA + PDPL) are first-class; the data model has Arabic from row one.
2. **Cross-module automation is wired, not aspirational.** A FAILED Art. 28 processor assessment automatically opens a CAPA; a cyber incident touching PII automatically files a PDPL breach with a 72h timer.
3. **Bilingual data, not bilingual labels.** Every business object carries `_ar` and `_en` columns and shows the operator's chosen language.
4. **Saudi-business Arabic, not literal MSA translations.** Heat-map labels, workflow names, evidence-pack titles use the phrasing a SAMA inspector or audit-committee chair actually uses.
5. **Operator-graded controls.** NCA ECC 30, CSCC 32, CCC 30, OTCC 27, SAMA 8, ISO 22301 8, PCI DSS 8 — 145 controls with bilingual procedure text and maturity tiers shipped at install.
6. **One platform, not a portfolio.** ERM + BCM + cyber + privacy + supply chain + audit + evidence + reporting all in one schema, one auth, one notification stream — no inter-module ETL.

9. Product maturity roadmap

Phase	Status	Sprints	Highlights
Sprint 1 — Foundation	✓ DONE	sprints/sprint-1.md	Auth, IAM, Risk, BCM, Compliance, Evidence base, bilingual shell
Sprint 2 — Vertical depth	✓ DONE	sprints/sprint-2.md	Cyber, Incidents, TPRM, SCM, Audit
Sprint 3 — Saudi regulator coverage	✓ DONE	sprints/sprint-3.md	NCA ECC + filing, PDPL + DSR + PIA + breach, HRSD/MOC/SAMA panels
Sprint 4 — Convergence	✓ DONE	sprints/sprint-4-convergence.md	Workflow engine, realtime, board pack, attestation, regulatory feed
Sprint 5 — Gap closure	✓ DONE	(this doc set)	Digital signature, RCA, scenarios, emerging risk, IT DRP, committees, contract clauses, alt suppliers + exit, NCA suite (CSCC/CCC/OTCC), PDPL extensions (CBT, disposal, notice), evidence chain-of-custody, cyber→PDPL bridge
Sprint 6 — TPRM depth	✓ DONE	(this doc set)	Fourth-party exposure, DSA, processor DD, third-party cyber, supplier resilience tests, consolidated TPRM overview, dashboard surfacing, cross-module automation

Phase	Status	Sprints	Highlights
Next: Sprint 7 — Operate	planned	TBD	OT/ICS deep-dive (Saudi industrial sector), SAMA outsourcing portal, AI governance, ESG/Vision-2030 alignment, advanced analytics

Cross-references

Topic	See
Per-module architecture	/02-Module-Architecture/
Workflow catalogue	/03-Workflow-Catalogue/
Data model	/04-Data-Model/
Regulatory mapping	/07-Regulatory-Mapping/
Gap analysis	docs/saudi-grc-gap-analysis.md
Module status snapshot	STATUS.md
Repo-level overview	README.md

Saudi GRC Platform

Module Architecture

Source: `module-architecture.md`

02 — Module Architecture

Per-module breakdown. Every module follows the layered layout under `tss-grc-backend/src/main/java/com/tss/grc/module/{name}/` with `controller/`, `dto/`, `entity/`, `repository/`, `service/`. Frontend pages under `tss-grc-ui-v2/src/pages/{slug}/`.

---

1. Enterprise Risk Management (ERM)

Description	ISO 31000-aligned end-to-end risk programme: appetite, identification, assessment, treatment, KRIs, scenarios, emerging risk, committee oversight.
Business purpose	Quantify and govern enterprise risk, demonstrate board-level oversight, escalate when appetite is breached.
Personas	Risk Manager, Risk Owner, Control Owner, Risk Committee Chair, Executive Reviewer
Core workflows	Risk lifecycle DRAFT→IN_REVIEW→ACTIVE→ACCEPTED /MITIGATED/CLOSED; KRI breach event; Risk acceptance with signature; Scenario approval; Emerging risk HORIZON →MONITORING→ESCALATED/MATURED/DISMISSED
Registers	risk.risks, risk.risk_assessments, risk.risk_appetite_statements, risk.kri_definitions, risk.kri_breach_events, risk.scenarios, risk.emerging_risks
Data objects	Risk, RiskAssessment, RiskAppetiteStatement, KriDefinition, KriBreachEvent, RiskScenario, EmergingRisk, Issue
Screens	RiskRegisterPage, RiskDetailPage, RiskLifecyclePage, AppetiteBreachFeed, NewRiskModal, RiskScenariosPage, EmergingRiskPage
Key fields	code, titleEn/Ar, category, likelihood, impact, inherentScore, residualScore, treatment, owner, appetiteBand, kriValue, breachThreshold, scenarioType (MONTE_CARLO|STRESS_TEST|WHAT_IF)
Approval points	Risk acceptance (requires digital signature for above-appetite); Scenario approval; Emerging risk escalation
Evidence	Risk acceptance memo, scenario calculation pack, KRI monthly snapshot, committee minutes
Reports	Board Risk Report (PDF), Top-10 risks, Appetite breach feed, Heatmap
Integrations	→ CAPA (treatment plans), → Compliance (control linkage), → Incident (issue from incident), → Signature (acceptance), → Reporting

2. Business Continuity Management (BCM)

Description	ISO 22301-aligned BCM: critical services, BIA, BCP, IT DRP, exercises, crisis activation.

Business purpose	Quantify business impact, prove ability to recover within RTO/RPO, demonstrate exercise + lessons-learned discipline.
Personas	BCM Manager, BIA Owner, Service Owner, DR Owner, Crisis Manager
Core workflows	BIA scoring; BCP build + approve; DRP playbook test; Exercise schedule→run→after-action; Crisis activation → invocation → stand-down
Registers	bcm.critical_processes, bcm.bia_records, bcm.bcm_plans, bcm.dr_plans, bcm.exercises, bcm.invocations, bcm.crisis_*
Data objects	CriticalProcess, BiaRecord, BcmPlan, DisasterRecoveryPlan, BcmExercise, CrisisCommsTemplate, CrisisAudience, CrisisDistribution
Screens	BcmPage, BcmLifecyclePage, BcmDependencyPage, DrPlansPage, CrisisManagementPage
Key fields	mtpd, rto, rpo, mbco, serviceCriticality, siteType (HOT|WARM|COLD|ACTIVE_ACTIVE|CLOUD_DR), failoverStepsJson, failbackStepsJson, lastTestedAt, nextTestDue
Approval points	BIA sign-off (Service Owner + Risk Manager); BCP approval (BCM Manager); DRP approve+activate; Crisis declare
Evidence	BIA report, BCP document, DRP playbook, exercise after-action, crisis log, attestation
Reports	BCM Readiness Report, Critical-services continuity report, DR readiness, Crisis exercise after-action
Integrations	→ ERM (treatment links), → SCM (vendor dependencies), → Cyber (asset criticality), → CAPA (action items)

3. Supply Chain Resilience (SCM)

Description	Vendor register, dependency map, alternate suppliers, exit plans, resilience tests, fourth-party exposure, contract clause library.
Business purpose	Map and reduce single-supplier risk; ensure tested fallbacks for critical vendors; demonstrate SAMA outsourcing compliance.
Personas	Supplier Manager, Procurement Owner, Vendor Risk Manager, BCM Officer
Core workflows	Vendor register + criticality; Alternate supplier maintenance; Exit plan + rehearsal; Resilience test (tabletop/failover/exit-rehearsal/SLA/joint-crisis); Fourth-party validation + mitigation; Contract clause approval
Registers	scm.vendors, scm.alternate_suppliers, scm.exit_plans, scm.supplier_resilience_tests, scm.fourth_party_exposures, scm.contract_clauses, scm.dependencies, scm.slas, scm.supplier_incidents

Data objects	Vendor, AlternateSupplier, ExitPlan, SupplierResilienceTest, FourthPartyExposure, ContractClause, Dependency, Sla, SupplierIncident, VendorAssessment
Screens	ScmPage, SupplierResiliencePage, ResilienceTestsPage, FourthPartyPage, ContractClausesPage, DependencyMap, VendorDetailPage, VendorPortalPage
Key fields	criticality, country, alternateVendorRole, contractualStatus, scenarioScope, outcome (PASS|PASS_WITH_OBSERVATIONS|FAIL|NOT_RUN), rtoTargetMinutes, concentrationRisk (LOW|MEDIUM|HIGH), flowDownClausesPresent
Approval points	Alternate-supplier APPROVED; Exit-plan APPROVED + ACTIVATED; Resilience-test COMPLETED→APPROVED; Fourth-party VALIDATED→MITIGATED; Contract clause APPROVED
Evidence	Vendor due-diligence pack, alternate-supplier vetting, exit-plan minutes, test after-action, fourth-party validation memo, contract addendum
Reports	Supplier resilience report, Concentration risk heatmap, Upcoming tests calendar, Exit-plan readiness
Integrations	→ TPRM (cyber assessment), → BCM (vendor → critical process), → Compliance (contract clauses), → CAPA (FAIL → CAPA), → Signature (exit-plan sign-off)

4. NCA Cybersecurity Compliance

Description	NCA framework catalogue (ECC, CSCC, CCC, OTCC) + control libraries + self-assessment + filing + incident notification.
Business purpose	Demonstrate compliance with NCA Essential Cyber-security Controls and the supplementary CSCC (cloud customer), CCC (cloud provider), OTCC (OT) suites; produce the annual self-assessment filing.
Personas	Cybersecurity Manager, NCA Compliance Owner, Asset Owner, Vulnerability Manager, CISO
Core workflows	Framework applicability; Control assessment; Maturity scoring; Filing (NcaEccFiling); Cyber-incident NIST 800-61 lifecycle; Cloud (CCC) + OT (OTCC) specific checks
Registers	cyber.cyber_frameworks, cyber.cyber_controls, cyber.cyber_sub_controls, cyber.control_assessments, cyber.cyber_assets, cyber.cyber_incidents, cyber.vulnerabilities, cyber.exceptions, cyber.root_cause_analyses
Data objects	CyberFramework, CyberControl, CyberSubControl, ControlAssessment, CyberAsset, CyberIncident, Vulnerability, NcaEccFiling, RootCauseAnalysis
Screens	CyberPage, FrameworkControlsPage, CyberLifecyclePage, VulnerabilitiesV2Page, NcaEccExportPage, AssetRegisterPage, ControlDetailPage

Key fields	controlNumber, domain, maturityLevel (L1..L5), implementationStatus (IMPLEMENTED|PARTIAL|PLANNED|NOT_APPLICABLE|NOT_IMPLEMENTED), controlType, reviewFrequency, frameworkName
Approval points	Control assessment APPROVED; Filing SUBMITTED; Incident phase transitions (DETECTION→…→LESSONS_LEARNED); RCA APPROVED
Evidence	Control attestation, assessor working papers, scan reports, pentest letters, asset inventory, NCA filing PDF
Reports	NCA Compliance Report, NCA filing pack, Maturity heatmap, Cyber incident report
Integrations	→ ERM (cyber risk), → PDPL (cyber→breach bridge), → Evidence (control evidence), → CAPA (gap remediation), → Signature (filing CISO attestation)

5. PDPL / Data Privacy

Description	Personal data lifecycle aligned to PDPL + SDAIA: ROPA, notices, consent, DSR, PIA, breach, cross-border, disposal, data sharing, processor due-diligence.
Business purpose	Demonstrate full PDPL compliance; meet the 30-day DSR SLA and 72-hour breach-notification deadline; document Art. 28 processor controls and Art. 29 cross-border mechanisms.
Personas	Data Protection Officer (DPO), Privacy Manager, Data Owner, Legal Reviewer
Core workflows	ROPA maintenance; Privacy notice DRAFT→PUBLISHED→ARCHIVED; Consent capture+withdrawal; DSR intake→fulfil (30 days); PIA DRAFT→IN_REVIEW→APPROVED; Breach detection→72h regulator notify→close; CBT REQUESTED→ASSESSED→APPROVED; Disposal SCHEDULED→IN_PROGRESS→COMPLETED→VERIFIED; DSA DRAFT→IN_REVIEW→ACTIVE→EXPIRED/TERMINATED; Processor assessment IN_PROGRESS→COMPLETED→APPROVED/REJECTED
Registers	privacy.processing_activities (ROPA), privacy.privacy_notices, privacy.consents, privacy.dsr_cases, privacy.dpias, privacy.data_breaches, privacy.cross_border_transfers, privacy.disposal_certificates, privacy.data_sharing_agreements, privacy.processor_assessments, privacy.cyber_breach_bridge_log
Data objects	ProcessingActivity, PrivacyNotice, Consent, DataSubjectRequest, Dpia, DataBreach, CrossBorderTransfer, DisposalCertificate, DataSharingAgreement, ProcessorAssessment, CyberPdplBridgeEvent

Screens	PrivacyPage, PrivacyLifecyclePage, RopaPage, PdplExtensionsPage (data-lifecycle), DsrPortalPage, DpiaDetailPage, CyberPdplBridgePage, DataSharingPage, ProcessorAssessmentsPage
Key fields	lawfulBasis, dataCategories, dataSubjects, retentionPeriodDays, crossBorderMechanism (NONE|ADEQUACY|SCC|BCR|EXPLICIT_CONSENT…), c1..c8 control outcomes, breach 72h timer, disposalMethod (DELETE|ANONYMIZE|ARCHIVE|DESTROY)
Approval points	Notice PUBLISH; PIA APPROVE; Breach close; CBT ASSESS+APPROVE; Disposal VERIFY; DSA ACTIVATE; Processor assessment APPROVE
Evidence	DPO sign-off memo, signed notice, consent record, DSR response pack, PIA report, breach notification, CBT contract addendum, disposal certificate, processor audit pack
Reports	PDPL Compliance Report, DSR SLA dashboard, Breach register, Cross-border register, Processor due-diligence pack
Integrations	→ Cyber (cyber-bridge automated breach trigger), → SCM (vendor → processor), → CAPA (failed Art. 28 → CAPA), → Signature (DPO/CISO attestation), → Reporting

6. Regulatory Compliance

Description	Framework catalogue, requirement library, control mapping, attestation campaigns, regulatory feed, MOC/HRSD/SAMA panels, policy lifecycle.
Business purpose	Unify regulatory obligations across NCA + SDAIA + SAMA + MOC + HRSD + ISO; track requirement-to-control coverage; run attestation cycles.
Personas	Compliance Officer, Control Owner, Internal Auditor, Legal Reviewer
Core workflows	Framework activation; Requirement mapping; Control assessment; Attestation campaign (CCM); Regulatory change capture + impact; Policy DRAFT→APPROVED→ACTIVE→SUPERSEDED
Registers	compliance.frameworks, compliance.controls, compliance.requirements, compliance.assessments, compliance.policies, compliance.regulatory_changes, compliance.attestation_campaigns
Screens	CompliancePage, FrameworkPacksPage, PolicyTemplatesPage, PolicyDetailPage, RegulatoryChangePage, AttestationCampaignsPage, ControlCrosswalkPage, MocPanel, HrsdProcessInitiation, NitaqatPanel
Key fields	frameworkCode, requirementRef, controlNumber, attestationCycle, policyStatus (DRAFT|APPROVED|ACTIVE|SUPERSEDED), regulatoryImpact

Approval points	Policy approve/supersede; Framework activate; Attestation cycle close
Evidence	Policy PDF, attestation responses, regulatory citation, control crosswalk
Reports	Regulatory Compliance Report, Attestation completion, Policy expiry forecast
Integrations	→ ERM (control→risk), → Cyber (NCA frameworks), → Privacy (PDPL requirements), → Reporting

7. Evidence Management

Description	Central evidence repository with versions, chain-of-custody hash, expiry, links to controls / workflows / risks.
Business purpose	One source of truth for "the document that proves we did this", with tamper-evident chain and audit linkage.
Personas	Evidence Owner, Control Owner, Auditor (internal + external)
Core workflows	Upload+version; Link to control/risk/incident; Approve; Verify chain; Expire+renew
Registers	evidence.evidence_items, evidence.evidence_versions, evidence.evidence_links, evidence.frameworks, evidence.controls, evidence.sub_controls, evidence.permissions
Screens	EvidencePage, EvidenceChainPage (SHA-256), FileUploadDemoPage, FrameworkPacksPage
Key fields	externalId, titleEn/Ar, currentVersionNo, chainStatus (VALID|BROKEN|UNVERIFIED), chainFirstBreakVersion, contentHashSha256, chainHashSha256, expiryDate
Approval points	Evidence APPROVE; Chain verify (on-demand)
Evidence about evidence	Audit log + chain hash report
Reports	Evidence pack export, Chain integrity report, Expiry forecast
Integrations	→ all modules (linked-evidence panels), → Signature (sign critical evidence)

8. Incident, Crisis & Regulatory Notification

Description	Unified incident management (security, BCM, supplier, privacy) with crisis activation and regulator-notification paths.
Business purpose	One front-door for "something went wrong"; correct routing to NCA / SDAIA / SAMA / CITC / HRSD timers; structured RCA + CAPA.
Personas	Incident Manager, SOC Lead, Crisis Manager, DPO, CISO, Regulatory Liaison

Core workflows	Incident lifecycle (NIST 800-61: DETECTION→ANALYSIS→CONTAINMENT→ERADICATION→RECOVERY→POST_INCIDENT→LESSONS_LEARNED); Crisis declare→invocation→stand-down; Regulator notify (NCA 2h critical, SDAIA 72h, SAMA bilateral); RCA (5-Whys/Fishbone/Pareto) DRAFT→IN_REVIEW→APPROVED; Auto-generate CAPAs
Registers	incident.incidents, incident.timeline_events, incident.lessons_learned, cyber.cyber_incidents, cyber.root_cause_analyses, bcm.invocations, bcm.crisis_*
Screens	IncidentsPage, CyberPage→Incidents tab, RcaPage, CrisisManagementPage, CyberPdplBridgePage
Key fields	severity, classification, impactedAssets, regulatorNotified, notificationReference, methodology (FIVE_WHYS|FISHBONE|PARETO|OTHER), problemStatement, recommendations
Approval points	RCA submit/approve; Lessons-learned approve; Regulator notification sign-off
Evidence	Incident timeline, RCA report, regulator notification receipt, lessons-learned memo
Reports	Cyber Incident Report, Data Breach Report (PDPL), Lessons-learned register
Integrations	→ PDPL (cyber→breach bridge), → CAPA (RCA→CAPA), → ERM (incident→issue), → Signature (notification sign-off)

9. Reporting and Dashboards

Description	Live dashboards, board-pack generator, scheduled reports, regulator-package exports.
Business purpose	Visualize the platform state at any altitude (board / executive / operational), produce the periodic + on-demand reports the regulators expect.
Personas	Executive Reviewer, Board Secretary, Compliance Officer, Auditor
Core workflows	Live dashboard refresh; Scheduled report run; Board-pack generation (PDF/PPTX); Regulator evidence-pack zip
Surfaces	DashboardPage (widget engine), Board Pack module, ReportSchedulesPage, NcaEccExportPage
Key features	Customisable widget layout, live STOMP refresh, ExportMenu (CSV/XLSX/PDF), bilingual report templates
Approval points	Board pack sign-off (digital signature); Regulatory pack approve
Reports	See /10-Reports-Dashboards/ for full catalogue
Integrations	Consumes all modules via realtime broadcaster

10. Administration, Configuration, and Workflow Engine

Description	Platform admin: tenants, users, roles, committees, white-label, notifications, workflow versioning, audit.
Business purpose	Operate the platform — tenant isolation, role-based access, workflow customisation, notification routing, audit log.
Personas	System Administrator, GRC Administrator, Workflow Designer
Core workflows	Tenant onboarding; User+role; Committee charter + meetings; Workflow version DRAFT→ACTIVE→DEPRECATED; Notification channel + outbox; White-label theme apply
Registers	iam.users, iam.roles, iam.permissions, admin.committees, admin.committee_meetings, workflow.workflows, workflow.workflow_versions, notification.outbox, notification.channels
Screens	AdminPage, OnboardingPage, CommitteesPage, WorkflowsPage, WorkflowVersionsPage, NotificationChannelsPage, NotificationOutboxPage, SsoConfigPage, MfaPage, WhiteLabelPage, SettingsPage
Key fields	organisationId, role-permission map, workflow definition (JSON), committee charter, channel type (EMAIL|SMS|WEBHOOK|TEAMS), mfa method
Approval points	Workflow promote to ACTIVE; Committee charter approve; Tenant activate
Evidence	Workflow change log, role assignment history, audit log export
Reports	User access matrix, Workflow inventory, Audit log report
Integrations	Underpins every module

Saudi GRC Platform

Workflow Catalogue

Source: `workflow-catalogue.md`

03 — Workflow Catalogue

Every workflow in the platform, English + Arabic name, state machine, SLA, escalation, evidence, signature requirement. Anchored to the actual service classes that own the state transitions.

Common conventions:

- **Audit trail**: every transition writes to `BaseEntity.updatedAt` + realtime broadcaster `changed.{entity}`. Sensitive transitions (approve, reject, sign) also log to `audit.events`.
- **Notifications**: routed through `notification.outbox` + channels.
- **Digital signature**: optional per workflow; some are mandatory (see table column).
- **Lifecycle**: every workflow ends in a terminal status; no re-open without explicit revoke transition.

BCM Workflows

BCM Governance

- **AR**: ■■■■■■ ■■■■■■■■■■ ■■■■■■■■
- **Purpose**: charter the BCM programme, define committee, set policy.
- **Trigger**: programme start or annual review.
- **Pre-conditions**: executive sponsor named.
- **Steps**: draft charter → executive review → board approve → publish → annual review.
- **Roles**: BCM Manager (draft), Executive Sponsor (review), Board (approve).
- **Approval matrix**: 2 levels — Executive + Board.
- **Inputs**: organisation chart, regulatory drivers, prior charter.
- **Outputs**: signed charter; mapped to `evidence.evidence_items` with type `BCM_CHARTER`.
- **Evidence**: charter PDF + signature transaction.
- **Modules**: BCM, Compliance, Admin (committees).
- **Registers**: `bcm.bcm_plans` (charter row), `admin.committees`.
- **Notifications**: board calendar invite, charter publish notice.
- **SLA**: 90 days from policy expiry to renewal.
- **Escalation**: at -30 days notify Executive Sponsor.
- **Status lifecycle**: DRAFT → IN_REVIEW → APPROVED → ACTIVE → ARCHIVED.
- **Audit**: full history retained in `audit.events`.
- **Signature**: required at APPROVED.

Critical Service Identification

- **AR**: ■■■■■■ ■■■■■■■■ ■■■■■■■
- **Purpose**: list every service the org delivers, classify criticality.
- **Trigger**: annual or change-driven.
- **Pre-conditions**: service inventory imported.

- **Steps**: service owner submits → BCM reviews → BIA owner classifies → Risk Manager endorses.
- **Roles**: Service Owner, BCM Manager, Risk Manager.
- **Status**: DRAFT → CLASSIFIED → APPROVED.
- **SLA**: 14 days from import.
- **Modules**: BCM, ERM. **Registers**: `bcm.critical_processes`.
- **Signature**: not required (record approval is enough).

Business Impact Analysis (BIA)

- **AR**: ■■■■■ ■■■ ■■■■■■■
- **Purpose**: quantify MTPD/RTO/RPO per critical service.
- **Trigger**: new service, annual cycle, post-incident.
- **Steps**: scoping → impact scoring (financial, regulatory, reputational, operational) → dependency capture → RTO/RPO set → review → approve.
- **Roles**: BIA Owner, Service Owner, Risk Manager, BCM Manager.
- **Approval**: BIA Owner submits → BCM Manager approves.
- **Outputs**: BIA record with `mtpd`, `rto`, `rpo`, `mbco`, dependencies.
- **Evidence**: BIA report PDF, dependency map screenshot.
- **Status**: DRAFT → SCORING → IN_REVIEW → APPROVED → SUPERSEDED.
- **SLA**: 21 days from BIA initiation.
- **Escalation**: at -3 days notify BCM Manager; at +0 escalate to Risk Committee.
- **Signature**: required at APPROVED.
- **Registers**: `bcm.bia_records`.

BCM Risk Assessment

- **AR**: ■■■■■ ■■■■■ ■■■■■■■■■■ ■■■■■■■■
- Risk-assessment workflow scoped to continuity events.
- **Trigger**: post-BIA.
- **Roles**: BCM Manager, Risk Manager.
- **Status**: DRAFT → ASSESSED → APPROVED.
- **Modules**: BCM, ERM (linked risk).
- **Signature**: optional.

Business Continuity Strategy

- **AR**: ■■■■■■■■■■■ ■■■■■■■■■■ ■■■■■■■■
- Choose treatment (hot/warm/cold/active-active/cloud-DR) per critical service.
- **Trigger**: post-BIA approval.
- **Roles**: BCM Manager, CIO, CFO.
- **Status**: DRAFT → APPROVED.
- **Signature**: required at APPROVED.

BCP Development

- **AR**: ■■■■■ ■■■ ■■■■■■■■■ ■■■■■■■
- Build the BCP document with named teams, comms tree, alternate site.
- **Steps**: draft → peer review → BCM approve → publish.
- **Roles**: BCM Manager (owner), Service Owner (reviewer).
- **Status**: DRAFT → IN_REVIEW → APPROVED → ACTIVE → ARCHIVED.
- **Evidence**: BCP PDF, comms tree.
- **Signature**: required at APPROVED.
- **Registers**: `bcm.bcm_plans`.

IT Disaster Recovery (DRP)

- **AR**: ■■■ ■■■■■■■ ■■■■■■ ■■ ■■■■■■■
- DRP playbook per system with RTO/RPO, failover + failback steps, site type, test schedule.
- **Steps**: draft → peer review → approve → activate → test (record outcome) → fail-back.
- **Roles**: DR Owner, CIO, BCM Manager.
- **Status**: DRAFT → IN_REVIEW → APPROVED → ACTIVATED → ARCHIVED (with REJECTED side-branch).
- **Module**: BCM (`module/bcm/drp/`). **Service**: `DrPlanService`.
- **Test action**: `recordTest(outcome, nextTestDue)`.
- **SLA**: annual test minimum; quarterly for tier-1 systems.
- **Signature**: required at APPROVED + at each test sign-off.

Crisis and Emergency Activation

- **AR**: ■■■■■ ■■■■■■■ ■■■■■■■■
- Declare crisis → invoke plans → standing communications.
- **Trigger**: incident severity threshold, manual declaration.
- **Roles**: Crisis Manager, Executive Sponsor, BCM Manager.
- **Status**: DECLARED → STANDUP → STANDDOWN → POST_MORTEM.
- **SLA**: 30-minute stand-up window.
- **Escalation**: auto-page Crisis Manager.
- **Modules**: BCM, Incident.
- **Evidence**: declaration log, comms record, after-action.
- **Signature**: required at POST_MORTEM close.

Communication Management

- **AR**: ■■■■■ ■■■■■■■■■
- Pre-approved templates + audiences + distribution lists, exercised under crisis.
- **Roles**: Comms Lead, Crisis Manager.
- **Registers**: `bcm.crisis_comms_templates`, `bcm.crisis_audiences`, `bcm.crisis_distributions`.

- **Signature**: not typically required.

BCM Testing and Exercises

- **AR**: [redacted]
- Schedule → run → after-action → corrective actions.
- **Roles**: Exercise Facilitator, BCM Manager.
- **Status**: SCHEDULED → IN_PROGRESS → COMPLETED → APPROVED.
- **Outputs**: after-action report, CAPA items.
- **Registers**: `bcm.exercises`.
- **Signature**: optional.

Lessons Learned

- **AR**: [redacted]
- Capture lessons from incidents + exercises + BCM invocations.
- **Roles**: BCM Manager + RCA Facilitator.
- **Status**: DRAFT → APPROVED.
- **Integration**: feeds CAPA + future BIA cycles.
- **Signature**: not required.

Corrective Actions (BCM)

- **AR**: [redacted]
- Tracks BCM-origin CAPAs.
- **Module**: `capa/`. **Origin types**: `bcm_exercise`, `bcm_invocation`, `rca`.
- **Status**: OPEN → IN_PROGRESS → AWAITING_VERIFICATION → CLOSED / CANCELLED.
- **Signature**: at CLOSED for high-severity items.

BCM Compliance Evidence

- **AR**: [redacted]
- Periodic evidence collection mapped to ISO 22301 + SAMA + NCA controls.
- **Module**: Evidence.
- **Signature**: per evidence (see Output 6).

Management Review (BCM)

- **AR**: [redacted]
- Annual top-down review per ISO 22301 clause 9.3.
- **Roles**: Executive Sponsor, BCM Manager, Risk Manager.
- **Output**: management-review minutes + actions.
- **Signature**: required (executive sign-off).

Supply Chain Resilience Workflows

Supplier Registration

- **AR**: ■■■■■■ ■■■■■■■
- New vendor record creation, validation, KYC checks.
- **Roles**: Procurement Owner, Supplier Manager.
- **Status**: DRAFT → KYC_PENDING → ACTIVE → SUSPENDED → CLOSED.
- **Registers**: `scm.vendors`.
- **Signature**: not required.

Supplier Criticality Assessment

- **AR**: ■■■■■■ ■■■■■■■ ■■■■■■■
- Score vendor criticality (LOW/MEDIUM/HIGH/CRITICAL) based on services + spend.
- **Roles**: Supplier Manager.
- **Status**: DRAFT → SCORED → APPROVED.

Supplier Risk Assessment

- **AR**: ■■■■■■ ■■■■■■ ■■■■■■■
- Periodic risk assessment per vendor.
- **Roles**: Vendor Risk Manager.
- **Registers**: `scm.vendor_assessments`.
- **Status**: DRAFT → IN_PROGRESS → COMPLETED → APPROVED.

End-to-End Supply Chain Mapping

- **AR**: ■■■■ ■■■■■■ ■■■■■■ ■■■■■■■■ ■■■■■■■■
- Visual map: services → systems → primary → fourth-party vendors.
- **Module**: SCM (`Dependency.java`) + new Fourth-party module.
- **Status**: DRAFT → PUBLISHED.

Dependency Mapping

- **AR**: ■■■■ ■■■■■■ ■■■■■■■■■
- Per-system and per-process dependencies.
- **Registers**: `scm.dependencies`, `bcm.process_dependencies`.

Supplier BCM Evidence Review

- **AR**: ■■■■■■■ ■■■■■ ■■■■■■■■■■ ■■■■■■ ■■■■■■■
- Annual BCP + DR evidence review per critical vendor.
- **Roles**: BCM Officer + Vendor Risk Manager.
- **Signature**: optional.

Fourth-Party Risk Assessment

- **AR**: ■■■■■■ ■■■■■■■ ■■■■■■ ■■■■■■■
- Map vendors-of-vendors; detect concentration risk; validate; mitigate.

- **Module**: `scm/fourthparty/`. **State machine**: DISCOVERED → VALIDATED → MITIGATED → RETIRED.
- **Service**: `FourthPartyExposureService` with auto-CAPA on HIGH concentration.
- **Roles**: Vendor Risk Manager.
- **Registers**: `scm.fourth_party_exposures`.

Supplier SLA Monitoring

- **AR**: ■■■ ■■■■■■■■ ■■■■■■ ■■■■■■■
- Track SLA targets vs actuals per vendor.
- **Registers**: `scm.slas`.

Supplier Incident Escalation

- **AR**: ■■■■■■ ■■■■■■ ■■■■■■■
- Vendor-reported incidents → escalation per criticality.
- **Registers**: `scm.supplier_incidents`.

Alternate Supplier Planning

- **AR**: ■■■■■■ ■■■■■■■ ■■■■■■■
- Maintain 1-3 ranked alternates per critical vendor.
- **Module**: `scm/resilience/`. **State machine**: DRAFT → APPROVED → ARCHIVED.
- **Registers**: `scm.alternate_suppliers`.

Supplier Exit Planning

- **AR**: ■■■■■■ ■■■■■■■ ■■ ■■■■■■■
- 90-day exit plan: data, contracts, parallel-run.
- **State**: DRAFT → APPROVED → ACTIVATED → ARCHIVED (with REJECTED).
- **Action**: `recordTest(outcome, nextTestDue)`.

Supplier Resilience Testing

- **AR**: ■■■■■■■ ■■■■■ ■■■■■■■■■
- Tabletop / failover / exit-rehearsal / SLA / joint-crisis tests per vendor.
- **Module**: `scm/resilience/` (`SupplierResilienceTest`).
- **State**: SCHEDULED → IN_PROGRESS → COMPLETED → APPROVED / CANCELLED.
- **Service**: auto-CAPA on FAIL outcome.

Contractual Resilience Clause Review

- **AR**: ■■■■■■■ ■■■■■ ■■■■■■■ ■■■■■■■■■■
- Clause library + approval + deprecation.
- **Module**: `scm/clauses/`. **State**: DRAFT → APPROVED → DEPRECATED.

Supplier Corrective Action Tracking

- **AR**: ■■■■■■■ ■■■■■■■■■■ ■■■■■■■■■■ ■■■■■■■■■

- CAPAs originated from supplier workflows.
- **Module**: CAPA.

ERM Workflows

Risk Governance

- **AR**: ■■■■■■ ■■■■■■■■
- Charter + committee + appetite cadence.

Risk Appetite

- **AR**: ■■■■■ ■■■■■■■■ (■■■■■■■)
- Set per category + level; review annually.
- **Registers**: `risk.risk_appetite_statements`.

Risk Identification

- **AR**: ■■■■■■ ■■■■■■■■
- Bottom-up + top-down identification.
- **Status**: NEW → DRAFT.

Risk Assessment

- **AR**: ■■■■■■ ■■■■■■■■
- Likelihood × impact, inherent + residual.
- **Registers**: `risk.risk_assessments`.
- **Status**: DRAFT → ASSESSED → APPROVED.

Risk Treatment

- **AR**: ■■■■■■■ ■■■■■■■■
- Avoid / mitigate / transfer / accept.
- **Status**: DRAFT → IN_PROGRESS → IMPLEMENTED → VERIFIED.

Risk Acceptance

- **AR**: ■■■■■ ■■■■■■■■ ■■■■ ■■■■■
- Formal acceptance for above-appetite risks.
- **Signature**: required (CRO).
- **Status**: REQUESTED → APPROVED → ACTIVE → EXPIRED.

KRI Monitoring

- **AR**: ■■■■■■■ ■■■■■■■ ■■■■■■ ■■■■■■■■■
- Continuous monitoring with breach events.
- **Registers**: `risk.kri_definitions`, `risk.kri_breach_events`.

Control Management

- **AR**: ■■■■■■ ■■■■■■■■
- Control library + assessment + test.
- **Module**: Compliance + Cyber.

Issue Management

- **AR**: ■■■■■■ ■■■■■■■■■
- Issues raised from incidents, audits, KRI breaches.

Emerging Risk Management

- **AR**: ■■■■■■ ■■■■■■■■ ■■■■■■■■
- Horizon-scanning signals.
- **Module**: `risk/emerging/`. **State**: HORIZON → MONITORING → ESCALATED / MATURED / DISMISSED.

Scenario Analysis

- **AR**: ■■■■■■ ■■■■■■■■■■■■■
- Monte Carlo / stress / what-if.
- **Module**: `risk/scenario/`. **State**: DRAFT → APPROVED → ARCHIVED.

Risk Reporting

- **AR**: ■■■■■■■ ■■■■■■■■
- Board, executive, operational tiers.

Risk Committee Workflow

- **AR**: ■■■■■ ■■■■■■■■
- Quarterly meetings, decisions, action items.
- **Module**: `admin/committee/`. **State**: SCHEDULED → IN_PROGRESS → COMPLETED → MINUTES_APPROVED → CANCELLED.

Lessons Learned Integration

- **AR**: ■■■■ ■■■■■■■ ■■■■■■■■■■
- Cross-feeds from incidents + exercises into ERM.

PDPL / Privacy Workflows

Personal Data Processing Register (ROPA)

- **AR**: ■■■■ ■■■■■■ ■■■■■■■ ■■■■■■■■■ ■■■■■■■■
- PDPL Art. 31.
- **Registers**: `privacy.processing_activities`.
- **Status**: DRAFT → ACTIVE → ARCHIVED.

Privacy Notice Management

- **AR**: ■■■■■■ ■■■■■■■■ ■■■■■■■■■

- PDPL Art. 12 templating + versioning.
- **Module**: `privacy/extensions/`. **State**: DRAFT → PUBLISHED → ARCHIVED → SUPERSEDED.

Consent Management

- **AR**: [redacted]
- Consent capture, withdrawal, audit.

Data Subject Rights Request

- **AR**: [redacted]
- 30-day SLA (PDPL Art. 22-26).
- **State**: NEW → IN_REVIEW → FULFILLED → REJECTED / EXPIRED.
- **Escalation**: at day 23 notify DPO; at day 28 escalate to Privacy Manager.
- **Signature**: required on response.

Privacy Impact Assessment (PIA)

- **AR**: [redacted]
- **State**: DRAFT → IN_REVIEW → APPROVED.
- **Signature**: required at APPROVED.

Data Sharing and Disclosure

- **AR**: [redacted]
- Formal disclosure agreements (regulator, credit bureau, group, JV).
- **Module**: `privacy/dsa/`. **State**: DRAFT → IN_REVIEW → ACTIVE → EXPIRED / TERMINATED.
- **Signature**: required at ACTIVE.

Cross-Border Data Transfer

- **AR**: [redacted]
- PDPL Art. 29; mechanism + assessment + approval + expiry.
- **Module**: `privacy/extensions/`. **State**: REQUESTED → ASSESSED → APPROVED / REJECTED → EXPIRED.

Personal Data Breach Management

- **AR**: [redacted]
- 72-hour SDAIA notification timer.
- **State**: DETECTED → CONTAINED → ASSESSED → NOTIFIED → CLOSED.
- **Auto-trigger** from cyber-bridge service.
- **Signature**: required at NOTIFIED.

Data Retention and Disposal

- **AR**: [redacted]
- PDPL Art. 18.

- **Module**: `privacy/extensions/`. **State**: SCHEDULED → IN_PROGRESS → COMPLETED → VERIFIED → CANCELLED.
- **Signature**: required at VERIFIED.

Processor and Third-Party Privacy Assessment

- **AR**: ■■■ ■■■■■■■ ■■■■■■■ ■■■■■■■■■
- PDPL Art. 28 eight-control assessment.
- **Module**: `privacy/processor/`. **State**: IN_PROGRESS → COMPLETED → APPROVED / REJECTED.
- **Auto-CAPA** on FAIL outcome.

NCA Workflows

NCA Framework Applicability

- **AR**: ■■■■ ■■■■■ ■■■■ NCA
- Decide which frameworks (ECC / CSCC / CCC / OTCC) apply.

NCA Control Library

- **AR**: ■■■■■ ■■■■■ NCA
- Maintain control catalogue.
- **Module**: `cyber/`. **Registers**: `cyber.cyber_controls` (145 controls seeded).

NCA Self-Assessment

- **AR**: ■■■■■■■ ■■■■■■ ■■ NCA
- Annual self-assessment + filing.
- **State**: DRAFT → IN_REVIEW → APPROVED → FILED.
- **Signature**: required at FILED (CISO).

Cybersecurity Risk Assessment

- **AR**: ■■■■■ ■■■■■■■ ■■■■■■■■■■
- Per-asset + per-control risk.

Asset and Critical System Classification

- **AR**: ■■■■■ ■■■■■■ ■■■■■■■■ ■■■■■■
- Classify assets (cyber + business).

Identity and Access Management Compliance

- **AR**: ■■■■■■■■ ■■■■■■ ■■■■■■ ■■■■■■■
- IAM control assessment.

Privileged Access Review

- **AR**: ■■■■■■ ■■■■■■ ■■■■■■■
- Quarterly review.

Vulnerability and Patch Compliance

- **AR**: ■■■■■ ■■■■■■■ ■■■■■■■■
- Vuln pipeline.
- **Registers**: `cyber.vulnerabilities`.

Cyber Incident Management

- **AR**: ■■■■■ ■■■■■■■ ■■■■■■■■■■
- NIST 800-61 lifecycle.
- **State**: DETECTION → ANALYSIS → CONTAINMENT → ERADICATION → RECOVERY → POST_INCIDENT → LESSONS_LEARNED.
- **Signature**: required at NOTIFIED (NCA).

Cloud Cybersecurity Compliance

- **AR**: ■■■■■■■■ ■■■■ ■■■■■■■■
- CCC framework — 30 controls.

OT / ICS Cybersecurity Compliance

- **AR**: ■■■■■■■■ ■■■■ ■■■■■■■ ■■■■■■■■■
- OTCC framework — 27 controls.

Cybersecurity Awareness and Training

- **AR**: ■■■■■■■ ■■■■■■■■ ■■■■■■■■■
- Annual campaign + attestation.

NCA Corrective Action and Remediation

- **AR**: ■■■■■■■■ ■■■■■■■■■ ■■ NCA
- CAPAs from NCA self-assessment gaps.

Cross-Module Workflows

Regulatory Obligation Mapping

- **AR**: ■■■ ■■■■■■■■■■ ■■■■■■■■■
- Map requirements across frameworks to controls.

Evidence Management

- **AR**: ■■■■■ ■■■■■■
- See Module 7.

Control Testing

- **AR**: ■■■■■■ ■■■■■■■
- Periodic operational testing.

Exception Management

- **AR**: ■■■■■■ ■■■■■■■■■■■■
- Risk-accepted control exceptions.
- **Registers**: `cyber.exceptions`.

Corrective Action Management

- **AR**: ■■■■■■ ■■■■■■■■■■ ■■■■■■■■■■
- See `capa/`.

Executive Reporting

- **AR**: ■■■■■■■■■ ■■■■■■■■■■
- See Output 11.

Board Reporting

- **AR**: ■■■■■■■ ■■■■■ ■■■■■■■■
- Board Pack PDF/PPTX.
- **Signature**: required (Chairman).

Regulatory Evidence Package Generation

- **AR**: ■■■■■ ■■■■■■■ ■■■■■■■■■■
- On-demand zip per regulator.

Digital Signature Approval

- **AR**: ■■■■■■■ ■■■■■■■■ ■■■■■■■
- Provider-pluggable (internal, DocuSign, Absher, Nafath).
- **Module**: `signature/`. **State**: REQUESTED → SIGNED / REJECTED / EXPIRED.

Audit Trail Review

- **AR**: ■■■■■■■ ■■■■ ■■■■■■■■
- Auditor-only read of `audit.events`.

Saudi GRC Platform

Workflow Lifecycles

Source: `workflow-lifecycles.md`

08 — Workflow Status Lifecycles

Per-workflow state machines. Drawn from the actual service classes that enforce transitions. All transitions write to `audit.events` and emit a `changed.{entity}` realtime broadcast.

Shared notation: - → = allowed transition. - Italic role = the only role(s) authorised to move the record. - ■ = SLA timer starts on entry to this state. - ■ = notification fires on entry. - ■ = digital signature required to enter.

ERM — Risk lifecycle

Status	Meaning	→ next	Mover	SLA	Notifications	Audit
DRAFT	Identified, not yet assessed	ASSESSED	Risk Owner	none	■ owner	full
ASSESSED	Likelihood × impact scored	APPROVED, DRAFT	Risk Mgr	14d ■	■ Risk Mgr	full
APPROVED	Inherent + residual approved	TREATED, ACCEPTED, MITIGATED, CLOSED	Risk Mgr	none	■ owner	full
TREATED	Treatment plan in flight	MITIGATED, ACCEPTED, CLOSED	Risk Owner	tracked via CAPA	■ monthly	full
ACCEPTED	Above-appetite, formally accepted	MITIGATED, EXPIRED	CRO ■	until expiry	■ CRO + Risk Committee	full
MITIGATED	Residual back below appetite	CLOSED	Risk Mgr	none	■ owner	full
CLOSED	No longer applicable	(terminal)	Risk Mgr	n/a	■ owner	full
EXPIRED	Acceptance lapsed	ACCEPTED, MITIGATED	Risk Mgr	reopen 7d ■	■ CRO	full

ERM — Scenario lifecycle (V35)

`DRAFT → APPROVED → ARCHIVED` (with `REJECTED` side-branch). *Mover:* Risk Mgr. ■ at APPROVED.

ERM — Emerging Risk lifecycle (V39)

`HORIZON → MONITORING → ESCALATED → MATURED | DISMISSED`. *Mover:* Risk Analyst.

ERM — Risk Acceptance lifecycle

`REQUESTED → APPROVED → ACTIVE → EXPIRED → REOPENED`. ■ at APPROVED (CRO).

BCM — BIA lifecycle

`DRAFT → SCORING → IN_REVIEW → APPROVED → SUPERSEDED`. *Mover:* BIA Owner → BCM Manager. SLA 21d from initiation. ■ at APPROVED.

BCM — BCP lifecycle

`DRAFT → IN_REVIEW → APPROVED → ACTIVE → ARCHIVED`. *Mover:* BCM Manager. ■ at APPROVED.

BCM — DRP lifecycle (V41)

Status	Meaning	→ next	Mover	SLA
DRAFT	New plan	IN_REVIEW, REJECTED	DR Owner	7d
IN_REVIEW	Peer review	APPROVED, REJECTED, DRAFT	CIO	7d
APPROVED ■	Operational	ACTIVATED, ARCHIVED	CIO + BCM Mgr	annual test
ACTIVATED	Live failover	APPROVED, ARCHIVED	BCM Mgr	n/a
ARCHIVED	Replaced	(terminal)	BCM Mgr	n/a
REJECTED	Not approved	DRAFT	Reviewer	n/a

BCM — Crisis Event lifecycle

`DECLARED → STAND_UP → ACTIVE → STAND_DOWN → POST_MORTEM`. *Mover:* Crisis Manager. ■ at POST_MORTEM.

BCM — Exercise lifecycle

`SCHEDULED → IN_PROGRESS → COMPLETED → APPROVED`. *Mover:* Exercise Facilitator → BCM Manager.

SCM — Vendor lifecycle

`DRAFT → KYC_PENDING → ACTIVE → SUSPENDED → CLOSED`. *Mover:* Procurement + Supplier Mgr.

SCM — Alternate Supplier lifecycle (V36)

`DRAFT → APPROVED → ARCHIVED`. *Mover:* Vendor Risk Mgr.

SCM — Exit Plan lifecycle (V36)

`DRAFT → APPROVED → ACTIVATED → ARCHIVED` (with `REJECTED`). *Mover:* COO. ■ at APPROVED.

SCM — Supplier Resilience Test lifecycle (V54)

Status	Meaning	→ next	Mover	Auto-action
SCHEDULED	Planned	IN_PROGRESS, CANCELLED	Facilitator	—
IN_PROGRESS	Test running	COMPLETED, CANCELLED	Facilitator	—
COMPLETED	Outcome recorded	APPROVED	BCM/CIO	auto-CAPA on FAIL
APPROVED	Closed	(terminal)	BCM Manager	—

Status	Meaning	→ next	Mover	Auto-action
CANCELLED	Cancelled with reason	(terminal)	Facilitator	—

SCM — Fourth-Party Exposure lifecycle (V50)

`DISCOVERED → VALIDATED → MITIGATED → RETIRED`. *Mover:* Vendor Risk Mgr. **Auto-CAPA** when concentration newly elevates to HIGH.

SCM — Contract Clause lifecycle (V45)

`DRAFT → APPROVED → DEPRECATED`. *Mover:* GC.

Cyber — Cyber Incident lifecycle (NIST 800-61, 9 phases)

`DETECTION → ANALYSIS → CONTAINMENT → ERADICATION → RECOVERY → POST_INCIDENT → LESSONS_LEARNED → CLOSED`. *Mover:* Incident Manager → CISO at LESSONS_LEARNED. ■ at NOTIFIED (NCA / SDAIA).

Cyber — Control Assessment lifecycle

`DRAFT → ASSESSED → APPROVED`. *Mover:* Control Owner → Compliance.

Cyber — Vulnerability lifecycle

`OPEN → IN_REMEDIATION → REMEDIATED → VERIFIED → CLOSED` (with `RISK_ACCEPTED` side-branch). *Mover:* Vulnerability Manager.

Cyber — RCA lifecycle (V31)

`DRAFT → IN_REVIEW → APPROVED → REJECTED`. *Mover:* RCA Facilitator → Approver. ■ at APPROVED. Generates CAPAs on APPROVED.

PDPL — Privacy Notice lifecycle (V32)

`DRAFT → PUBLISHED → ARCHIVED → SUPERSEDED`. *Mover:* DPO. ■ at PUBLISHED.

PDPL — DSR lifecycle

Status	Meaning	→ next	SLA
NEW	Received	IN_REVIEW	day-0
IN_REVIEW	Triage	FULFILLED, REJECTED	day-7 ■
FULFILLED ■	Responded	(terminal)	day-30 hard SLA
REJECTED	Not actionable	(terminal)	with reason
EXPIRED	Missed 30d	escalate to Privacy Mgr	auto-escalate

PDPL — PIA lifecycle

`DRAFT → IN_REVIEW → APPROVED → REJECTED`. *Mover:* DPO. ■ at APPROVED.

PDPL — Breach lifecycle

`DETECTED → CONTAINED → ASSESSED → NOTIFIED → CLOSED`. ■ at NOTIFIED. 72h ■ from DETECTED to NOTIFIED.

PDPL — Cross-Border Transfer lifecycle (V32)

`REQUESTED → ASSESSED → APPROVED / REJECTED → EXPIRED`. *Mover:* DPO.

PDPL — Disposal Certificate lifecycle (V32)

`SCHEDULED → IN_PROGRESS → COMPLETED → VERIFIED → CANCELLED`. *Mover:* Data Owner → DPO. ■ at VERIFIED.

PDPL — Data Sharing Agreement lifecycle (V51)

`DRAFT → IN_REVIEW → ACTIVE → EXPIRED | TERMINATED`. *Mover:* GC + DPO. ■ at ACTIVE.

PDPL — Processor Assessment lifecycle (V52)

`IN_PROGRESS → COMPLETED → APPROVED | REJECTED`. *Mover:* DPO. ■ at APPROVED. **Auto-CAPA on FAIL**.

TPRM — Third-Party Cyber Assessment lifecycle (V53)

`DRAFT → IN_REVIEW → APPROVED → RETIRED`. *Mover:* Vendor Risk Mgr → CISO.

Compliance — Policy lifecycle

`DRAFT → APPROVED → ACTIVE → SUPERSEDED → ARCHIVED`. ■ at APPROVED.

Compliance — Regulatory Change lifecycle

`CAPTURED → IMPACT_ASSESSED → ACTION_PLANNED → IMPLEMENTED → VERIFIED`.

Compliance — Attestation Campaign lifecycle

`SCHEDULED → IN_PROGRESS → CLOSED`.

CAPA lifecycle

`OPEN → IN_PROGRESS → AWAITING_VERIFICATION → CLOSED | CANCELLED`. ■ at CLOSED for high-severity items.

Digital Signature Transaction lifecycle

`REQUESTED → SIGNED | REJECTED | EXPIRED`. *Mover:* Signer.

Committee Meeting lifecycle (V40)

`SCHEDULED → IN_PROGRESS → COMPLETED → MINUTES_APPROVED | CANCELLED`. ■ at MINUTES_APPROVED.

Evidence-item lifecycle

`UPLOADED → REVIEWED → APPROVED → EXPIRED | SUPERSEDED`. Chain verification is event-driven; on `verifyChain()` the chain status flips between `UNVERIFIED → VALID | BROKEN`.

Common SLA rules

Workflow	SLA timer	Hard deadline	Auto-escalation
DSR	30 days	yes (PDPL)	day-23 to DPO, day-28 to Privacy Mgr
Breach notification	72 hours	yes (PDPL Art. 20)	hour-48 to DPO, hour-60 to CISO
BIA cycle	21 days	soft	day-18 to BCM Mgr
DR test	12 months	soft	-30d to DR Owner
Risk acceptance review	annual	soft	-30d to Risk Owner
Processor reassessment	12 months	soft	-30d to DPO
Resilience test	12 months (per vendor tier)	soft	-30d to Vendor Risk Mgr
NCA filing	annual	yes (NCA)	-60d to CISO
Vulnerability patch	30 days (critical)	yes	per-day to Vuln Mgr
CAPA target	per record	tracking	-7d to owner

Common audit-log rules

Every state transition writes a row to `audit.events` containing: - `actor_user_id` + IP + UA - `entity_type` + `entity_id` + `external_id` - `verb` (e.g. `submit`, `approve`, `reject`, `sign`) - `before_json` + `after_json` (status fields only — not full record) - `at` (UTC timestamp).

Audit-log retention: 60 months minimum. Read access restricted to roles with `AUDIT_READ` permission.

Saudi GRC Platform

Data Model

Source: `data-model.md`

04 — Data Model and Entity Relationship Design

Logical data model of the TSS GRC platform, anchored to the actual JPA entities and SQL Server tables.

Conventions:

- Every business entity extends `BaseEntity` adding: `id` (BIGINT IDENTITY, PK), `organisationId` (tenant scope), `externalId` (URL-safe code), `isDeleted` SMALLINT (soft delete), `isActive`, `createdAt/By`, `updatedAt/By`, `deletedAt/By`, `rowVersion`.
- Bilingual fields: every user-visible string has `*_en` and `*_ar`.
- Tenancy: `organisationId` indexed on every query. `TenantContext` thread-local enforces filter.
- Soft delete: `@Where(clause="is_deleted = 0")` on every entity.
- Status: every state-machine entity has `status NVARCHAR(20)` + audit timestamps per terminal transition.

Core entities

Organization

- **AR**: ■■■■■■■ | **EN**: Organisation
- Tenant boundary. Every other row references it.
- **Table**: `platform.organisations`
- **Fields**: `id`, `external_id` (slug), `name_en`, `name_ar`, `registration_number` (CR), `vat_number`, `sector`, `country` (ISO3), `parent_organisation_id`, `status`, `branding_json`, `effective_from`, `effective_to`.
- **API**: `Organisation`
- **Relations**: 1→N every other business entity.

Department

- **AR**: ■■■■■■■ | **EN**: Department
- Internal org chart.
- **Table**: `iam.departments`
- **Fields**: `id`, `organisation_id`, `parent_department_id`, `name_en`, `name_ar`, `manager_user_id`, `cost_centre`.

User

- **AR**: ■■■■■■■■ | **EN**: User
- **Table**: `iam.users`
- **Fields**: `username`, `email`, `display_name_en`, `display_name_ar`, `phone`, `password_hash`, `mfa_enabled`, `mfa_method`, `default_org_id`, `last_login_at`, `failed_login_count`, `locked_until`, `roles` (M:N via `iam.user_roles`).

Role

- **AR**: ■■■■■ | **EN**: Role
- **Table**: `iam.roles`
- **Fields**: `name`, `description_en`, `description_ar`, `permissions` (M:N via `iam.role_permissions`).
- See `/08-RBAC/` for the full role catalogue.

Committee

- **AR**: ■■■■■■ | **EN**: Committee
- **Table**: `admin.committees`
- **Fields**: `name_en`, `name_ar`, `description_en`, `description_ar`, `charter_en`, `charter_ar`, `members_json`, `cadence`, `chair_user_id`, `secretary_user_id`, `status` (ACTIVE | DISSOLVED).
- **Children**: `admin.committee_meetings`.

Service

- **AR**: ■■■■■■ | **EN**: Critical Service
- The unit of BCM scoping.
- **Table**: `bcm.critical_processes`
- **Fields**: `name_en`, `name_ar`, `criticality` (LOW | MEDIUM | HIGH | CRITICAL), `owner_user_id`, `business_function`, `regulatory_drivers`.

Process

- **AR**: ■■■■■■■ | **EN**: Business Process
- Sub-unit of service.
- **Table**: `bcm.business_processes` (where applicable).

Asset

- **AR**: ■■■■■ | **EN**: Asset
- **Table**: `cyber.cyber_assets`
- **Fields**: `name_en`, `name_ar`, `asset_type` (SERVER | NETWORK | DB | APPLICATION | OT_ICS | CLOUD), `classification`, `owner`, `location`, `criticality`, `residency`.

Application

- Subset of Asset (`asset_type = 'APPLICATION'`).

Data Asset

- **AR**: ■■■■■ ■■■■■■■ | **EN**: Data Asset
- **Table**: `cyber.data_assets` (or `evidence.data_assets`)
- **Fields**: `name_en`, `name_ar`, `classification` (PUBLIC | INTERNAL | CONFIDENTIAL | RESTRICTED), `pii_flag`, `residency`, `owner`, `retention_policy`.

Personal Data Processing Activity (ROPA)

- **AR**: ■■■■ ■■■■■■ ■■■■■■■■ ■■■■■■■ | **EN**: Processing Activity
- **Table**: `privacy.processing_activities`

- **Fields**: `code` (ROPA-XXX), `activity_name_en`, `activity_name_ar`, `purpose_en`, `purpose_ar`, `lawful_basis`, `data_categories`, `data_subjects`, `source_asset_id`, `recipients`, `retention_days`, `cross_border_flag`, `last_reviewed_at`, `business_owner`.

Supplier (Vendor)

- **AR**: ■■■■■■ | **EN**: Vendor
- **Table**: `scm.vendors`
- **Fields**: `vendor_name`, `vendor_name_ar`, `vendor_type`, `country`, `risk_rating`, `criticality`, `status`, `contract_end_date`.

Contract

- **AR**: ■■■■■ | **EN**: Contract
- **Table**: `scm.contracts`
- **Fields**: `vendor_id`, `contract_code`, `effective_from`, `effective_to`, `value_sar`, `status`.

Dependency

- **Table**: `scm.dependencies`, `bcm.process_dependencies`
- **Fields**: `source_type`, `source_id`, `target_type`, `target_id`, `dependency_kind`, `criticality`.

Risk

- **Table**: `risk.risks`
- **Fields**: `risk_code`, `title_en`, `title_ar`, `category`, `subcategory`, `inherent_likelihood`, `inherent_impact`, `residual_likelihood`, `residual_impact`, `treatment_strategy`, `risk_owner`, `appetite_band`, `status`.

Control

- **Table**: `cyber.cyber_controls` (cybersecurity); `compliance.controls` (general); `evidence.controls` (evidence catalog)
- **Fields**: `framework_name`, `domain`, `control_number`, `title_en`, `title_ar`, `procedure_en`, `control_type` (PREVENTIVE | DETECTIVE | CORRECTIVE), `review_frequency`, `maturity_level`, `implementation_status`.

Regulatory Requirement

- **Table**: `compliance.requirements`
- **Fields**: `regulator`, `requirement_ref`, `summary_en`, `summary_ar`, `effective_from`, `effective_to`.

Evidence

- **Table**: `evidence.evidence_items` + `evidence.evidence_versions` + `evidence.evidence_links` + `evidence.permissions`.
- **Fields**: `external_id`, `title_en`, `title_ar`, `evidence_type`, `owner`, `expiry_date`, `current_version_no`, `chain_status` (VALID | BROKEN | UNVERIFIED), `chain_first_break_version`.

Assessment

- Generic assessment record per discipline:
- `risk.risk_assessments`

- `cyber.control_assessments`
- `scm.vendor_assessments`
- `privacy.dpias`
- `privacy.processor_assessments`
- `tprm.third_party_cyber_assessments`

BIA

- **Table**: `bcm.bia_records`
- **Fields**: `service_id`, `mtpd_hours`, `rto_hours`, `rpo_hours`, `mbco_pct`, `financial_impact_sar`, `regulatory_impact`, `reputational_impact`, `operational_impact`, `dependencies_json`, `last_reviewed_at`, `status`.

BCP

- **Table**: `bcm.bcm_plans`
- **Fields**: `plan_code`, `title_en`, `title_ar`, `service_id`, `team_json`, `comms_tree_json`, `alternate_site`, `version`, `status`.

DRP

- **Table**: `bcm.dr_plans`
- **Fields**: `plan_code`, `title_en`, `title_ar`, `system_name`, `rto_minutes`, `rpo_minutes`, `site_type`, `failover_steps_json`, `failback_steps_json`, `last_tested_at`, `next_test_due`, `last_test_outcome`, `status`.

Incident

- **Table**: `incident.incidents` (generic); `cyber.cyber_incidents` (cyber-specific)
- **Fields**: `incident_number`, `title_en`, `title_ar`, `severity`, `classification`, `detected_at`, `phase`, `assignee_user_id`, `impacted_assets_json`, `regulator_notified`, `notification_reference`.

Crisis Event

- **Table**: `bcm.invocations` + `bcm.crisis_*`

Data Breach

- **Table**: `privacy.data_breaches`
- **Fields**: `breach_external_id`, `detected_at`, `notified_at`, `sdaia_deadline_at` (72h), `data_subjects_count`, `categories`, `status`.

Cyber Incident

- **Table**: `cyber.cyber_incidents` (as above).

Corrective Action (CAPA)

- **Table**: `capa.tasks`
- **Fields**: `external_id`, `origin_type`, `origin_id`, `title_en`, `title_ar`, `capa_type` (CORRECTIVE | PREVENTIVE), `severity`, `owner`, `target_date`, `status` (OPEN → IN_PROGRESS → AWAITING_VERIFICATION → CLOSED / CANCELLED).

Issue

- Linked from incidents + audits + KRI breaches.

KRI

- **Table**: `risk.kri_definitions` + `risk.kri_breach_events`.

KPI

- Surface for reporting (mostly derived).

SLA

- **Table**: `scm.slas`
- **Fields**: `vendor_id`, `metric`, `target`, `breach_threshold`, `measurement_window`.

Exercise

- **Table**: `bcm.exercises`
- **Fields**: `title_en`, `title_ar`, `scenario`, `scheduled_for`, `participants`, `outcome`, `lessons_learned_id`.

Test (resilience)

- **Table**: `scm.supplier_resilience_tests` (new in V54).

Report

- Reports are generated artifacts persisted into Evidence and/or `reporting.scheduled_reports`.

Approval

- Cross-cutting concept implemented per workflow + per signature transaction.

Digital Signature Transaction

- **Table**: `signature.digital_signature_transactions`
- **Fields**: `external_id`, `related_entity_type`, `related_entity_id`, `signer_user_id`, `signer_name`, `provider`, `purpose`, `purpose_ar`, `signed_document_hash`, `certificate_reference`, `status` (REQUESTED → SIGNED / REJECTED / EXPIRED), `expiry_date`.

Audit Log

- **Table**: `audit.events`
- **Fields**: `event_id`, `organisation_id`, `actor_user_id`, `verb`, `entity_type`, `entity_id`, `before_json`, `after_json`, `ip_address`, `user_agent`, `at`.

Key relationships

- Organization 1 — N every business entity (`organisation_id` FK).
- Service 1 — N BIA 1 — N BCP 1 — N DRP.
- Service 1 — N CriticalProcess; CriticalProcess M — N Asset.
- Asset 1 — N Vulnerability.
- Asset 1 — N Cyber Incident (impacted-assets join).
- Cyber Incident 1 — 1 Data Breach (via cyber-bridge log).

- Vendor 1 — N AlternateSupplier (`primary_vendor_id`); 1 — N ExitPlan; 1 — N ResilienceTest; 1 — N FourthPartyExposure (`primary_vendor_name`).
- ProcessingActivity (ROPA) 1 — N PrivacyNotice (`linked_ropa_codes`); 1 — N CrossBorderTransfer (`ropa_code`); 1 — N DisposalCertificate (`related_entity_type='ropa'`); 1 — N DataSharingAgreement (`linked_ropa_codes`); 1 — N ProcessorAssessment (via `related_processor_id`).
- Risk M — N Control (`risk.risk_controls` linkage).
- Risk 1 — N Treatment Plan 1 — N CAPA.
- Evidence 1 — N EvidenceVersion 1 — N EvidenceLink (polymorphic to Control, Risk, Incident, BIA, BCP, etc.).
- Incident 1 — N RCA 1 — N CAPA.
- Committee 1 — N CommitteeMeeting.
- DigitalSignatureTransaction polymorphic to any workflow entity via `(related_entity_type, related_entity_id)`.
- AuditLog polymorphic across all entities.

Many-to-many tables

- `iam.user_roles` (user, role, organisation)
- `iam.role_permissions` (role, permission)
- `evidence.evidence_links` (evidence, target entity-type, target id, link-type)
- `cyber.control_assessments_assets` (assessment, asset)
- `risk.risk_controls` (risk, control)
- `compliance.policy_framework_mappings` (policy, framework)

Suggested API object names + DB table mapping

Domain	API DTO	Table
Risk	Risk	risk.risks
BIA	BiaRecord	bcm.bia_records
BCP	BcmPlan	bcm.bcm_plans
DRP	DisasterRecoveryPlan	bcm.dr_plans
Vendor	TprmVendorDto	scm.vendors
Alternate Supplier	AlternateSupplier	scm.alternate_suppliers
Exit Plan	ExitPlan	scm.exit_plans
Resilience Test	SupplierResilienceTest	scm.supplier_resilience_tests
Fourth-Party	FourthPartyExposure	scm.fourth_party_exposures
Contract Clause	ContractClause	scm.contract_clauses
Cyber Framework	CyberFramework	cyber.cyber_frameworks

Domain	API DTO	Table
Cyber Control	CyberControl	cyber.cyber_controls
Cyber Incident	CyberIncident	cyber.cyber_incidents
Asset	CyberAsset	cyber.cyber_assets
Vulnerability	Vulnerability	cyber.vulnerabilities
RCA	RootCauseAnalysis	cyber.root_cause_analyses
ROPA	ProcessingActivity	privacy.processing_activities
Privacy Notice	PrivacyNotice	privacy.privacy_notices
CBT	CrossBorderTransfer	privacy.cross_border_transfers
Disposal	DisposalCertificate	privacy.disposal_certificates
DSA	DataSharingAgreement	privacy.data_sharing_agreements
Processor DD	ProcessorAssessment	privacy.processor_assessments
TPRM Cyber	ThirdPartyCyberAssessment	tprm.third_party_cyber_assessments
Bridge Log	CyberPdplBridgeEvent	privacy.cyber_breach_bridge_log
CAPA	CapaTask	capa.tasks
Evidence	EvidenceItem	evidence.evidence_items
Signature	DigitalSignatureTransaction	signature.digital_signature_transactions
Committee	Committee	admin.committees
Committee Meeting	CommitteeMeeting	admin.committee_meetings
Emerging Risk	EmergingRisk	risk.emerging_risks
Risk Scenario	RiskScenario	risk.scenarios

Bilingual labels — sample dictionary

EN	AR
Organisation	■■■■■■■
User	■■■■■■■■
Role	■■■■■
Department	■■■■■■■
Committee	■■■■■■
Service	■■■■■■
Process	■■■■■■■
Asset	■■■■■
Risk	■■■■■■■■
Control	■■■■■■
Evidence	■■■■■■
Assessment	■■■■■■■

EN	AR
Incident	■■■■■■■
Data Breach	■■■ ■■■■■■■■
Cyber Incident	■■■■■■■ ■■■■■■■■■■
Corrective Action	■■■■■■■ ■■■■■■■■
Vendor / Supplier	■■■■■■
Contract	■■■■■
Dependency	■■■■■■■
Approval	■■■■■■■■
Signature	■■■■■■■
Audit Log	■■■ ■■■■■■■
Status	■■■■■■
Priority	■■■■■■■■
Owner	■■■■■■
Due Date	■■■■■ ■■■■■■■■■

Saudi GRC Platform

Ui Screens

Source: `ui-screens.md`

05 — Screen and UI Requirements

Page-level requirements for every UI surface. Every page lives under `tss-grc-ui-v2/src/pages/{slug}/` (React + Vite + bilingual `Shell` component with RTL/LTR auto-switch).

Shared conventions:

- All pages use `Shell` → `PageHeader` → KPI grid → `Tabs` → primary `Card` with table.
- Empty state via with `Icon`, `title`, `sub`.
- Filters via ; saved views via .
- Create modals via with `FieldDef[]` schema.
- Validation: required fields enforced by `FormModal` + server-side bean validation; toast on `ApiError`.
- Bilingual: every label sourced from `translations/en.ts` + `ar.ts`; every record shows the `_ar` field when `lang === 'ar'`.
- RTL: when `lang === 'ar'`, root sets `dir="rtl"`; layout uses logical CSS properties (`marginInlineStart` etc.) throughout.

Executive Dashboard

- **EN/AR**: Executive Dashboard | ■■■■ ■■■■■■ ■■■■■■■■■■
- **Path**: `/dashboard`
- **Purpose**: at-a-glance view of platform state with widget customisation.
- **Sections**: page-header + customise toolbar + add-widget chip strip + widget grid.
- **Widgets**: Saudi posture, open intakes, overdue reassessments, CAB queue, critical risks, **TPRM snapshot** (new), heatmap, risks by severity, frameworks, activity feed.
- **Buttons**: Refresh, Customise, Reset layout, Board Pack PDF/PPTX, ExportMenu (PDF/XLSX).
- **Roles**: every authenticated user (filtered view based on role).
- **Validation**: none; refresh & customise are idempotent.
- **Empty state**: per-widget — falls back to demo data if not authenticated.
- **RTL**: full RTL flip; PDF export uses `RtlFontConfig` for Arabic.

Regulatory Library

- **EN/AR**: Regulatory Library | ■■■■■■■■ ■■■■■■■■■■
- **Path**: `/compliance` (tab `frameworks`)
- **Purpose**: browse all activated frameworks + their requirement + control mapping.
- **Tabs**: Frameworks, Requirements, Crosswalk, Scorecard, Continuous Monitoring (CCM).
- **Fields**: framework name, regulator, version, control count, applicability, effective range.

Risk Register

- **EN/AR**: Risk Register | ■■■ ■■■■■■■■

- **Path**: `/risk`
- **Purpose**: enterprise risk register with filtering, heatmap drill, KRI breach feed.
- **Tabs**: All, Critical, High, Medium, Low, Closed, Heatmap.
- **Buttons**: New Risk, Bulk Actions, Export.
- **Fields**: code, title, category, inherent, residual, owner, status, appetite-band, last reviewed.
- **Drill-in**: row → `/risk/:id` → assessment, treatment, KRIs, evidence.

Risk Assessment Form

- **EN/AR**: Risk Assessment | ■■■■■ ■■■■■■■
- **Path**: `/risk/:id` (Assessment tab) or `/risk?new=1`
- **Fields**: likelihood (1-5), impact (1-5), inherent score (auto), residual score (after controls), treatment, owner, target date.
- **Validation**: likelihood + impact required; numeric range.

Risk Treatment Plan

- **EN/AR**: Treatment Plan | ■■■ ■■■■■■■■
- **Path**: `/risk/:id` (Treatment tab)
- **Workflow actions**: Submit treatment, Approve, Implement, Verify.

Risk Appetite Dashboard

- **EN/AR**: Risk Appetite | ■■■■ ■■■■■■■
- **Path**: `/risk` (Appetite tab) + `AppetiteBreachFeed` component on detail pages.

BIA Register

- **EN/AR**: BIA Register | ■■■ ■■■■■ ■■■ ■■■■■■■
- **Path**: `/bcm` (BIA tab)
- **Fields**: service, MTPD, RTO, RPO, MBCO, last reviewed, status.

BIA Assessment Form

- **EN/AR**: BIA Assessment | ■■■■■ ■■■■■ ■■■ ■■■■■■■
- **Sections**: Service scoping → impact dimensions → dependencies → RTO/RPO set.

Critical Services Register

- **EN/AR**: Critical Services | ■■■■■■■ ■■■■■■
- **Path**: `/bcm` (Services tab).

BCP Builder

- **EN/AR**: BCP Builder | ■■■■ ■■■ ■■■■■■■■■■■
- **Path**: `/bcm` (BCP tab) + `/bcm-lifecycle` lifecycle pipeline.

DRP Builder

- **EN/AR**: DR Plans | ■■■ ■■■■■■■ ■■ ■■■■■■■
- **Path**: `/dr-plans` (V41).
- **Fields**: system, site type, RTO/RPO, failover steps JSON, failback steps JSON, last tested, next due, outcome.
- **Actions**: New, Approve, Reject, Activate, Archive, Record Test.

Crisis Room Dashboard

- **EN/AR**: Crisis Room | ■■■■ ■■■■■■■
- **Path**: `/crisis-management`.

Supplier Register

- **EN/AR**: Supplier Register | ■■■ ■■■■■■■■
- **Path**: `/scm` (Vendors tab) + `/tprm`.

Supplier Risk Assessment

- **EN/AR**: Vendor Risk Assessment | ■■■■■ ■■■■■ ■■■■■■
- **Path**: `/tprm` (Reassessment + Onboarding tabs).

Dependency Map

- **EN/AR**: Dependency Map | ■■■■■ ■■■■■■■■
- **Path**: `/bcm-dependency`.

Supply Chain Map

- **EN/AR**: Supply Chain Map | ■■■■■ ■■■■■ ■■■■■■■
- **Path**: `/scm` + `/fourth-party` for sub-tier.

NCA Compliance Dashboard

- **EN/AR**: NCA Compliance | ■■■■■■■■ ■■ NCA
- **Path**: `/cyber` (NCA tab) + `/nca-ecc-export`.

NCA Control Assessment

- **EN/AR**: NCA Controls | ■■■■■ NCA
- **Path**: `/framework-controls` (filter by NCA framework).
- **Tabs**: All, ECC, CSCC, CCC, OTCC, SAMA, ISO 27001, ISO 22301, PCI DSS.

Asset Register

- **EN/AR**: Asset Register | ■■■ ■■■■■■
- **Path**: `/assets`.

Critical Systems Register

- Subset of Asset Register filtered to `classification = CRITICAL`.

Vulnerability Register

- **EN/AR**: Vulnerabilities | ■■■■■■■
- **Path**: `/cyber/vulns/v2`.

Cyber Incident Register

- **EN/AR**: Cyber Incidents | ■■■■■■■ ■■■■■■■■■■
- **Path**: `/incidents` + `/cyber` (Incidents tab).

PDPL Dashboard

- **EN/AR**: PDPL Dashboard | ■■■■ PDPL
- **Path**: `/privacy`.

Processing Activity Register (ROPA)

- **Path**: `/ropa`.
- **Detail panel**: per-ROPA PDPL workflow chips (notices / CBT / disposal) with live counts.

PIA Form

- **Path**: `/privacy` (PIA tab) + `/detail/dpia/:id`.

Data Subject Request Register

- **Path**: `/privacy` (DSR tab) + `/portal/dsr` (public form).

Consent Register

- **Path**: `/privacy` (Consent tab).

Cross-Border Transfer Register

- **Path**: `/data-lifecycle` (CBT tab).

Data Breach Register

- **Path**: `/privacy` (Breach tab).

Evidence Repository

- **Path**: `/evidence` + `/evidence-chain` (chain-of-custody view).

Corrective Action Register

- **Path**: `/capa`.

Board Report Generator

- **Path**: `/board-pack`.
- **Actions**: PDF, PPTX, both bilingual.
- **Signature**: required (Chairman) at finalisation.

Regulatory Evidence Package Generator

- **Path**: `/nca-ecc-export` + on-demand per-regulator export.

Administration and Workflow Configuration

- **Paths**: `/admin`, `/workflows`, `/workflow-versions`, `/notifications-channels`, `/sso`, `/mfa`, `/white-label`, `/settings`, `/onboarding`.

New screens (this doc set)

- `/fourth-party` — Fourth-party exposure register
- `/data-sharing` — PDPL data-sharing agreements
- `/processor-assessments` — PDPL Art. 28 due diligence
- `/third-party-cyber` — Third-party cyber risk assessment
- `/resilience-tests` — Supplier resilience tests
- `/tprm` → enhanced with consolidated TPRM overview component
- `/dashboard` → enhanced with TPRM snapshot widget

Saudi GRC Platform

Evidence Library

Source: `evidence-library.md`

06 — Evidence Library

Per-domain catalogue of the evidence types the platform stores and presents to auditors / regulators.

Storage model: every entry below maps to a row in `evidence.evidence_items` with `evidence_type` set per the "Evidence name" column. Versions live in `evidence.evidence_versions` (SHA-256 chain). Links to the originating control / risk / incident are in `evidence.evidence_links`.

Evidence name	Description	Owner	Frequency	File types	Expiry rule	Review rule	Approval	Module	Regulatory source	Sig req.
BCM Charter	Top-level BCM programme charter	BCM Manager	Annual	PDF	12 months	Annual mgmt review	Board	BCM	ISO 22301 §5.1	✓
BIA Report	Per-service business impact analysis	BIA Owner	Annual + change-driven	PDF, XLSX	12 months	Annual	BCM Manager	BCM	ISO 22301 §8.2.2	✓
BCP Document	Service BCP playbook	BCM Manager	12 months	PDF	12 months	Annual + post-test	BCM Manager	BCM	ISO 22301 §8.4	✓
DRP Playbook	System DR runbook	DR Owner	12 months	PDF, MD	12 months	After every test	CIO + BCM	BCM	ISO 22301 §8.4 + NCA ECC	✓
DR Test After-Action	Outcome + lessons from each DR test	DR Owner	Per test (annual+)	PDF	24 months	n/a	BCM Manager	BCM	ISO 22301 §8.5	—
Crisis Declaration Log	Crisis activation timeline	Crisis Manager	Per event	PDF, JSON	60 months	Per event	Executive	BCM	NRC	✓
Crisis Comms Record	Distribution log of crisis communications	Comms Lead	Per event	PDF	60 months	n/a	Crisis Manager	BCM	NRC	—
BCM Exercise Report	After-action from BCM exercise	BCM Manager	Per exercise	PDF	24 months	n/a	BCM Manager	BCM	ISO 22301 §8.5	—
Supplier Due-Diligence Pack	Vendor onboarding due diligence	Procurement	Onboarding + biennial	PDF, XLSX	24 months	Biennial	Vendor Risk Mgr	SCM	SAMA outsourcing	—

Evidence name	Description	Owner	Frequency	File types	Expiry rule	Review rule	Approval	Module	Regulatory source	Sig req.
Alternate Supplier Vetting	Vetting of standby vendor	Vendor Risk Mgr	Annual	PDF	12 months	Annual	Vendor Risk Mgr	SCM	SAMA outsourcing	—
Exit-Plan Document	90-day vendor exit plan	Procurement	Per critical vendor	PDF	24 months	Annual	COO	SCM	SAMA outsourcing	✓
Exit-Plan Rehearsal After-Action	Outcome of exit rehearsal	Vendor Risk Mgr	Annual	PDF	24 months	n/a	COO	SCM	SAMA	—
Supplier Resilience Test After-Action	Tabletop / failover / SLA / joint-crisis report	Vendor Risk Mgr	Annual+	PDF	24 months	n/a	CIO + BCM	SCM	SAMA + ISO 22301	—
Fourth-Party Validation Memo	Validation of fourth-party relationship	Vendor Risk Mgr	Annual	PDF	12 months	Annual	Vendor Risk Mgr	SCM	SAMA + NCA	—
Contract Addendum (Flow-down)	Flow-down clauses to sub-processors	Legal	Per vendor	PDF	Contract term	Per contract change	GC	SCM	SAMA + PDPL Art. 28	✓
ERM Risk Register Snapshot	Periodic register dump	Risk Mgr	Quarterly	PDF, XLSX	36 months	Quarterly	Risk Committee	ERM	ISO 31000	—
Risk Acceptance Memo	Above-appetite acceptance	Risk Owner	Per acceptance	PDF	Until expiry	Annual	CRO	ERM	ISO 31000 + ISO 27001	✓
KRI Monthly Snapshot	KRI values+ breaches	Risk Mgr	Monthly	XLSX, PDF	12 months	Monthly	Risk Committee	ERM	ISO 31000	—
Scenario Analysis Pack	Monte Carlo / stress / what-if calculation	Risk Analyst	Per scenario	PDF, XLSX	24 months	Per use	Risk Mgr	ERM	ISO 31000	✓ at APPROVED
Risk Committee Minutes	Per-meeting	Committee Secretary	Quarterly	PDF	60 months	Per meeting	Chair	ERM	ISO 31000	✓

Evidence name	Description	Owner	Frequency	File types	Expiry rule	Review rule	Approval	Module	Regulatory source	Sig req.
NCA Self-Assessment Pack	Annual ECC + CSCC + CCC + OTCC self-assessment	NCA Compliance Owner	Annual	PDF	12 months	Annual	CISO	NCA	NCA ECC + CSCC + CCC + OTCC	✓
NCA Filing PDF	Filed self-assessment	CISO Office	Annual	PDF	Permanent	n/a	CISO	NCA	NCA ECC §3	✓
NCA Control Attestation	Per-control owner attestation	Control Owner	Annual	PDF	12 months	Annual	Control Owner	NCA	NCA ECC	—
Pentest Report	Annual penetration test	CISO Office	Annual	PDF	12 months	n/a	CISO	Cyber	NCA + PCI DSS 11.4	—
Vulnerability Scan Output	Quarterly internal + ASV external	SOC	Quarterly	PDF, CSV	12 months	Quarterly	CISO	Cyber	PCI DSS + NCA	—
Asset Inventory Snapshot	Per-system inventory	Asset Owner	Quarterly	XLSX	12 months	Quarterly	CIO	Cyber	NCA ECC §2	—
Cyber Incident Report	Per-incident timeline + classification + lessons	Incident Manager	Per incident	PDF	60 months	n/a	CISO	Incident	NCA + SAMA	✓ at NOTIFIED
RCA Report	Root cause analysis (5-Whys/Fishbone/Pareto)	RCA Facilitator	Per incident	PDF	60 months	n/a	RCA Approver	Incident	ISO 27035	✓ at APPROVED
CISO Attestation (NCA filing)	Annual CISO sign-off	CISO	Annual	PDF	12 months	n/a	CISO	NCA	NCA ECC	✓
ROPA Snapshot	Per-tenant ROPA dump	DPO	Annual	PDF, XLSX	12 months	Annual	DPO	Privacy	PDPL Art. 31	—
Privacy Notice (Published)	The signed published notice	DPO	Per version	PDF	Until superseded	n/a	DPO	Privacy	PDPL Art. 12	✓ at PUBLISH

Evidence name	Description	Owner	Frequency	File types	Expiry rule	Review rule	Approval	Module	Regulatory source	Sig req.
DSR Response Pack	Per-request response	DSR Officer	Per request	PDF	36 months	n/a	DPO	Privacy	PDPL Art. 22-26	✓
PIA Report	Privacy impact assessment	DPO	Per high-risk activity	PDF	24 months	Biennial	DPO + CISO	Privacy	PDPL Art. 25	✓ at APPROVED
Personal Data Breach Notification	SDAIA + subject notifications	DPO	Per breach	PDF	60 months	n/a	DPO + CISO	Privacy	PDPL Art. 20 (72h)	✓
Cross-Border Transfer Approval	Per-transfer approval pack	DPO	Per transfer	PDF	Until expiry	Annual	DPO	Privacy	PDPL Art. 29	✓
Consent Record	Captured consent event	System	Per event	JSON, PDF	Per retention	n/a	Auto	Privacy	PDPL Art. 11	—
Disposal Certificate	Verified disposal evidence	Data Owner	Per disposal	PDF	36 months	Per event	DPO	Privacy	PDPL Art. 18	✓ at VERIFY
Processor Due-Diligence Pack	Art. 28 control evidence	DPO	Per processor + annual	PDF, XLSX	12 months	Annual	DPO	Privacy	PDPL Art. 28	✓ at APPROVED
Data Sharing Agreement (Signed)	Per DSA	Legal	Per agreement	PDF	Until expiry	Annual	GC + DPO	Privacy	PDPL Art. 6 + 29	✓ at ACTIVE
Bridge Event Log	Cyber→PDPL automated bridge log	System	Per event	JSON	60 months	n/a	Auto	Privacy	PDPL Art. 20	—
Board Risk Report	Quarterly board pack	Board Secretary	Quarterly	PDF, PPTX	60 months	Quarterly	Board Chair	Reporting	CMA + SAMA	✓
Board Acknowledgement	Board confirmation of receipt	Board Chair	Quarterly	PDF	60 months	n/a	Chair	Reporting	CMA + SAMA	✓
Policy Approval	Signed policy	Policy Owner	Per version	PDF	Until superseded	Annual	Executive	Compliance	ISO 27001 §5	✓
Audit Findings Pack	Internal audit findings	Internal Auditor	Per audit	PDF	60 months	n/a	Audit Committee	Audit	ISO 19011	—

Evidence name	Description	Owner	Frequency	File types	Expiry rule	Review rule	Approval	Module	Regulatory source	Sig req.
Audit Evidence Package	Per-engagement evidence	Internal Auditor	Per engagement	PDF + ZIP	60 months	n/a	Audit Committee	Audit	ISO 19011	—
Regulator Notification Receipt	Filed regulator notice	Regulatory Liaison	Per filing	PDF	60 months	n/a	DPO/CISO	Incident	All regulators	—
Evidence Chain Report	SHA-256 chain verification	System	On-demand + scheduled	JSON, PDF	12 months	Quarterly	Auto	Evidence	ISO 27001 §9	—
Workflow Sign-Off (Digital)	Any digital-signature transaction	Signer	Per transaction	JSON	60 months	n/a	Signer	Signature	—	inherent
Attestation Campaign Response	Per-control attestation cycle	Control Owner	Per cycle	PDF	12 months	Per cycle	Compliance	Compliance	Multi	—
Vendor Cyber Assessment	Cyber-specific TPRM assessment	Vendor Risk Mgr	Annual	PDF	12 months	Annual	CISO	TPRM	NCA + SAMA outsourcing	✓ at APPROVED

File-handling rules

- All evidence is encrypted at rest (SQL Server TDE + per-blob AES-256 envelope).
- Maximum file size: 50 MB per version; chunked upload above 10 MB.
- Allowed types (configurable per tenant): `pdf`, `docx`, `xlsx`, `pptx`, `csv`, `json`, `png`, `jpg`, `zip`.
- SHA-256 of every version is computed on upload and chained against the prior version (`evidence.evidence_versions.chain_hash_sha256`).
- Chain integrity is independently verifiable via the `/api/evidence/chain/{id}/verify` endpoint.

Saudi GRC Platform

Regulatory Mapping

Source: `regulatory-mapping.md`

07 — Regulatory Mapping Matrix

Cross-walk from regulatory source → platform module → workflow → data object → evidence → responsible role → compliance status.

Placeholder convention: where official control IDs were not provided in the source spec, the entries are tagged `*-PLACEHOLDER-NNN` and must be re-numbered when the official control library is imported.

Compliance-status options used throughout: `NOT_APPLICABLE | NOT_IMPLEMENTED | PLANNED | PARTIAL | IMPLEMENTED | VERIFIED`.

Gap-handling process: when status drops below `IMPLEMENTED`, the platform automatically opens a CAPA (`originType=compliance_gap`) and assigns it to the responsible role. Aging gaps escalate through the `AppetiteBreachFeed`.

NCA — Essential Cybersecurity Controls (ECC)

Source	Domain	Control / requirement	Summary	Module	Workflow	Data object	Evidence	Role	Status options	Report
NCA ECC	Governance	ECC-1-1 (seeded)	Cybersecurity strategy approved by management	Cyber	NCA Self-Assessment	CyberControl	Strategy doc	CISO	All	NCA Filing
NCA ECC	Governance	ECC-1-2 (seeded)	Cybersecurity policy framework	Cyber	NCA Self-Assessment	CyberControl + Policy	Policy PDF	CISO	All	NCA Filing
NCA ECC	Governance	ECC-1-3 (seeded)	Cybersecurity governance roles and responsibilities	Cyber	NCA Self-Assessment	CyberControl	RACI matrix	CISO	All	NCA Filing
NCA ECC	Defence	ECC-2-1 (seeded)	Asset management	Cyber	Asset Inventory	CyberAsset	Inventory snapshot	Asset Owner	All	NCA Filing
NCA ECC	Defence	ECC-2-5 (seeded)	Vulnerability management	Cyber	Vuln + Patch	Vulnerability	Scan report	Vuln Manager	All	NCA Filing
NCA ECC	Defence	ECC-2-9 (seeded)	Network security	Cyber	Control Assessment	CyberControl	Network diagram	CISO	All	NCA Filing
NCA ECC	Resilience	ECC-4-1 (seeded)	Cybersecurity resilience	Cyber	Resilience	CyberControl	Resilience plan	CISO	All	NCA Filing

Source	Domain	Control / requirement	Summary	Module	Workflow	Data object	Evidence	Role	Status options	Report
NCA ECC	TPRM	ECC-5-1 (seeded)	Third-party cybersecurity	TPRM	TPRM Cyber Assessment	ThirdPartyCyberAssessment	TPRM pack	Vendor Risk Mgr	All	NCA Filing
(full library)		NCA-ECC-PLACEHOLDER-001..114	All 114 ECC main controls — to be imported from official library	Cyber	NCA Self-Assessment	CyberControl	Per control	CISO	All	NCA Filing

NCA — Cloud Cybersecurity Controls (CSCC)

Source	Domain	Control	Summary	Module	Workflow	Data object	Evidence	Role	Report
NCA CSCC	Cloud	CSCC-1-1 (seeded, 32 controls)	Customer responsibilities for cloud cyber	Cyber	Cloud cyber assessment	CyberControl (CSCC)	Cloud pack	CISO + CIO	NCA Filing
(full library)		NCA-CSCC-PLACEHOLDER-001..N	Official CSCC controls — to import	Cyber	Cloud cyber	CyberControl	Per control	CISO	NCA Filing

NCA — Critical Systems Cybersecurity Controls (CCC)

Source	Domain	Control	Summary	Module	Workflow	Data object	Evidence	Role	Report
NCA CCC	Critical Systems	CCC-1-1 (seeded, 30 controls)	Critical-system identification	Cyber	Critical-systems classification	CyberAsset	Classification	CISO	NCA Filing
(full library)		NCA-CCC-PLACEHOLDER-001..N	Official CCC controls — to import	Cyber	Critical systems	CyberAsset + CyberControl	Per control	CISO	NCA Filing

NCA — Operational Technology Cybersecurity Controls (OTCC)

Source	Domain	Control	Summary	Module	Workflow	Data object	Evidence	Role	Report
NCA OTCC	OT/ICS	OTCC-1-1 .. OTCC-5-12 (seeded, 27 controls)	OT cyber security strategy, governance, operations, third-party, resilience	Cyber	OT cyber assessment	CyberControl	Per control	OT Cyber Lead	NCA Filing
(full library)		NCA-OTCC-PLACEHOLDER-001..N	Full OTCC v1.0 — to import	Cyber	OT cyber	CyberControl	Per control	OT Cyber Lead	NCA Filing

SAMA — Cyber Security Framework

Source	Domain	Control	Summary	Module	Workflow	Data object	Evidence	Role	Report
SAMA Cyber	Leadership and Governance	SAMA-1.1.1 (seeded, 8 controls)	Cybersecurity governance	Cyber	NCA-style self-assessment	CyberControl	Charter	CISO	SAMA pack
SAMA Cyber	Operations	SAMA-3.3.1 (seeded)	Identity & access mgmt	Cyber	IAM + Privileged access	CyberControl	IAM evidence	CISO	SAMA pack
SAMA Cyber	TPRM	SAMA-4.4.1 (seeded)	Third-party cyber risk	TPRM	TPRM Cyber	ThirdPartyCyberAssessment	TPRM pack	Vendor Risk Mgr	SAMA pack
SAMA Cyber	Resilience	SAMA-5.5.1 (seeded)	Incident response	Incident	NIST 800-61 lifecycle	CyberIncident	Incident report	CISO	SAMA pack
(full library)		SAMA-PLACEHOLDER-001..N	Full SAMA Cyber Security Framework — to import	Cyber/Comp	Per domain	Per	Per	Per	SAMA pack

SAMA — Outsourcing Rules (CCO-OUTS)

Source	Control	Module	Workflow	Data object	Evidence	Role
SAMA Outsourcing	Vendor risk management	SCM/TPRM	Vendor onboarding + assessment	Vendor + VendorAssessment	DD pack	Vendor Risk Mgr
SAMA Outsourcing	Exit planning	SCM	Supplier exit planning	ExitPlan	Exit plan doc	COO
SAMA Outsourcing	Resilience testing	SCM	Supplier resilience test	SupplierResilienceTest	Test after-action	Vendor Risk Mgr

Source	Control	Module	Workflow	Data object	Evidence	Role
SAMA Outsourcing	Fourth-party visibility	SCM	Fourth-party validation	FourthPartyExposure	Validation memo	Vendor Risk Mgr
(full library)	SAMA-PLACEHOLDER-OUT-001..N	SCM	Per	Per	Per	Per

SDAIA / PDPL

Source	Article	Requirement summary	Module	Workflow	Data object	Evidence	Role	Status options
PDPL	Art. 6	Lawful basis	Privacy	ROPA, DSA	ProcessingActivity, DSA	ROPA snapshot, DSA	DPO	All
PDPL	Art. 11	Consent	Privacy	Consent capture	Consent	Consent record	DPO	All
PDPL	Art. 12	Privacy notice	Privacy	Notice mgmt	PrivacyNotice	Published notice	DPO	All
PDPL	Art. 18	Retention + disposal	Privacy	Disposal certificate	DisposalCertificate	Disposal cert	Data Owner	All
PDPL	Art. 20	Breach (72h)	Privacy	Breach mgmt + Cyber-bridge	DataBreach	Notification, log	DPO + CISO	All
PDPL	Art. 22-26	DSR (30 days)	Privacy	DSR	DataSubjectRequest	Response pack	DPO	All
PDPL	Art. 28	Processor due diligence	Privacy	Processor assessment	Processor Assessment	Art. 28 pack	DPO	All
PDPL	Art. 29	Cross-border transfer	Privacy	CBT	CrossBorderTransfer	Approval pack	DPO	All
PDPL	Art. 31	ROPA	Privacy	ROPA	ProcessingActivity	ROPA snapshot	DPO	All
PDPL	Art. 35	Quarterly regulator evidence	Privacy + Reporting	Regulator pack	Multi	Quarterly packet	DPO	All
PDPL implementing regs	PDPL-PLACEHOLDER-001..N	Implementing regulations — to import	Privacy	Per	Per	Per	DPO	All

DGA — Digital Government Authority

Source	Requirement	Module	Workflow	Data object	Evidence	Role
DGA	DGA-PLACEHOLDER-001..N	Digital service quality + security baseline	Compliance	Regulatory mapping	Requirement	Service evidence

Source	Requirement	Module	Workflow	Data object	Evidence	Role
DGA	DGA-PLACEHOLDER-DATA-001	Data sharing across govt	Privacy	DSA	DSA	DSA
DGA	DGA-PLACEHOLDER-INTEROP-001	API interoperability	API	Integration spec	n/a	API contract

National Risk Council / Resilience

Source	Requirement	Module	Workflow	Data object	Evidence	Role
NRC	NRC-PLACEHOLDER-001..N	National-resilience programme requirements	BCM	Crisis activation + BCP	CrisisEvent + BCP	Crisis log

ISO 22301 (BCM)

Source	Clause	Control	Module	Workflow	Data object	Evidence	Role
ISO 22301	4.1	Context	BCM	Charter	BcmPlan (charter)	Charter	BCM Mgr
ISO 22301	5.1	Leadership	BCM	Governance	Committee	Minutes	Exec
ISO 22301	6.1	Risk + opportunity	BCM	BCM Risk Assessment	Risk + BiaRecord	Assessment	BCM Mgr
ISO 22301	8.2	BIA + risk assessment	BCM	BIA	BiaRecord	BIA report	BIA Owner
ISO 22301	8.4	BCP + DRP	BCM	BCP/DRP	BcmPlan, DrPlan	Plan docs	BCM Mgr
ISO 22301	8.5	Exercise programme	BCM	Exercises + tests	BcmExercise, SupplierResilienceTest	After-action	BCM Mgr
ISO 22301	9.1	Performance	BCM	KPI monitoring	KRI/KPI	Quarterly report	BCM Mgr
ISO 22301	10.2	Nonconformity + CAPA	BCM	CAPA	CapaTask	CAPA log	BCM Mgr

ISO 27001 (ISMS)

Source	Annex A	Module	Workflow	Data object	Evidence	Role
ISO 27001	A.5 Information security policies	Compliance	Policy lifecycle	Policy	Signed policy	CISO
ISO 27001	A.6 Org of info sec	Cyber	Governance	CyberControl	Org chart	CISO
ISO 27001	A.7 HR security	IAM + Compliance	User mgmt	User	Onboarding evidence	HR

Source	Annex A	Module	Workflow	Data object	Evidence	Role
ISO 27001	A.8 Asset mgmt	Cyber	Asset inventory	CyberAsset	Inventory	Asset Owner
ISO 27001	A.9 Access control	Cyber	IAM + Privileged access	CyberControl	Quarterly recertification	CISO
ISO 27001	A.10 Cryptography	Cyber	Key mgmt	CyberControl	Key inventory	CISO
ISO 27001	A.11 Physical security	Cyber	Physical	CyberControl	Physical audit	Facilities
ISO 27001	A.12 Operations	Cyber	Ops	CyberControl	Per control	CISO
ISO 27001	A.13 Communications	Cyber	Network	CyberControl	Per control	CISO
ISO 27001	A.14 Acquisition + dev + maintenance	Cyber	SDLC	CyberControl	SDLC evidence	CISO
ISO 27001	A.15 Supplier relationships	TPRM	TPRM cyber	ThirdPartyCyberAssessment	TPRM pack	Vendor Risk Mgr
ISO 27001	A.16 Incident mgmt	Incident	NIST 800-61	CyberIncident	Incident report	Incident Mgr
ISO 27001	A.17 BCM	BCM	BCM	BcmPlan + DrPlan	Plans	BCM Mgr
ISO 27001	A.18 Compliance	Compliance	Mapping	Requirement	Crosswalk	Compliance

ISO 31000 (Risk)

Source	Clause	Module	Workflow	Data object	Evidence	Role
ISO 31000	5 Framework	ERM	Risk governance	Committee + Policy	Charter	Risk Mgr
ISO 31000	6.3 Risk identification	ERM	Risk identification	Risk	Register	Risk Mgr
ISO 31000	6.4 Analysis	ERM	Risk assessment	RiskAssessment	Assessment	Risk Mgr
ISO 31000	6.5 Evaluation	ERM	Treatment	TreatmentPlan	Treatment doc	Risk Mgr
ISO 31000	6.6 Treatment	ERM	Treatment	TreatmentPlan + CAPA	Action items	Risk Mgr
ISO 31000	6.7 Recording + reporting	Reporting	Board reports	Report	Board pack	Board Sec

ISO 27701 (Privacy ISMS)

Source	Clause	Module	Workflow	Data object	Evidence	Role
ISO 27701	Controller + processor extensions to ISO 27001	Privacy	PIA, processor DD, breach	ProcessingActivity, ProcessorAssessment	Per control	DPO
ISO 27701	PLACEHOLDER	(full mapping pending official import)	Privacy	Per	Per	Per

Gap handling process

1. When an assessment marks a control / requirement below `IMPLEMENTED`, the system records a gap on the linked CyberControl / ComplianceRequirement.
2. The compliance service auto-opens a CAPA (`originType=compliance_gap`, `originId=`) with severity matching the regulator's priority tier.
3. The CAPA owner receives an email + dashboard notification.
4. Aging unresolved gaps escalate to the appropriate committee through the `AppetiteBreachFeed`.
5. On CAPA closure with verified evidence, the assessment status is re-evaluated; if back to `IMPLEMENTED` the gap is closed.

Report output

The regulatory mapping powers:

- **Board Risk Report** — aggregated compliance % per regulator.
- **NCA Filing PDF** — per-control attestation export.
- **PDPL Compliance Report** — per-article coverage.
- **SAMA Quarterly Pack** — outsourcing + cyber + resilience.
- **Regulatory Evidence Package** — zip per regulator on-demand.

Saudi GRC Platform

Rbac Matrix

Source: `rbac-matrix.md`

09 — Role-Based Access Control Matrix

Spring Security RBAC: roles + permissions backed by `iam.roles` + `iam.role_permissions` + `iam.user_roles`. Permission grain is `{MODULE}:{ACTION}` e.g. `RISK:READ`, `CYBER:WRITE`.

Method-level guard: `@PreAuthorize("hasPermission('MODULE','ACTION')")` delegating to `ModulePermissionEvaluator`. UI gating uses `hasAnyRole(...)` helper from `lib/auth.ts`.

Legend (action columns): - **V** view / read - **C** create - **E** edit - **A** approve / sign - **D** delete / archive - **X** export - **S** digital signature - **R** run report

Role	Modules	V	C	E	A	D	X	S	R
System Administrator	All (platform-wide)	✓	✓	✓	✓	✓	✓	—	✓
GRC Administrator	Platform-config + Workflow + Notifications	✓	✓	✓	✓	✓	✓	—	✓
Risk Manager	ERM, Compliance, Reporting	✓	✓	✓	✓	own	✓	✓	✓
Risk Owner	ERM (own risks), CAPA	✓	✓	own	—	own	own	—	own
Control Owner	Compliance, Cyber, Evidence	✓	✓	own	—	own	own	—	own
Evidence Owner	Evidence	✓	✓	own	own	own	own	own	own
BCM Manager	BCM (all), ERM-link	✓	✓	✓	✓	✓	✓	✓	✓
BIA Owner	BCM (BIA), Critical Services	✓	✓	own	—	own	own	—	own
Service Owner	BCM (own services), BIA	✓	own	own	—	—	own	—	own
DR Owner	BCM (DR plans + tests)	✓	✓	own	own	own	own	✓	own
Crisis Manager	BCM (crisis), Incident, Comms	✓	✓	✓	✓	—	✓	✓	✓

Role	Modules	V	C	E	A	D	X	S	R
Supplier Manager	SCM, TPRM	✓	✓	✓	own	✓	✓	—	✓
Procurement Owner	SCM (own vendors), Contracts	✓	✓	own	—	own	own	—	own
Cybersecurity Manager / CISO	Cyber, Incident, NCA, TPRM-cyber	✓	✓	✓	✓	✓	✓	✓	✓
NCA Compliance Owner	Cyber, Compliance, NCA filing	✓	✓	✓	✓	own	✓	✓	✓
Asset Owner	Cyber (own assets)	✓	✓	own	—	own	own	—	own
Vulnerability Manager	Cyber (vulns), CAPA	✓	✓	✓	own	own	✓	—	✓
Data Protection Officer (DPO)	Privacy (all), PDPL workflows	✓	✓	✓	✓	own	✓	✓	✓
Privacy Manager	Privacy, DSR, PIA, breach	✓	✓	✓	✓	own	✓	✓	✓
Data Owner	Privacy (own data), Disposal	✓	own	own	—	own	own	—	own
Legal Reviewer	Compliance, Privacy (DSA, contracts)	✓	—	review	✓	—	own	✓	own
Compliance Officer	Compliance (all), Reporting	✓	✓	✓	✓	own	✓	✓	✓
Internal Auditor	All (read-only) + Audit module	✓	own (audit only)	own (audit)	—	—	✓	—	✓
Executive Reviewer	Dashboards, Reports, sign-off	✓	—	—	sign	—	✓	✓	✓

Role	Modules	V	C	E	A	D	X	S	R
Board Secretary	Board Pack, Committee, Reporting	✓	✓	✓	✓	—	✓	✓	✓
External Auditor	All (read-only) for engagement window	✓	—	—	—	—	✓	—	✓
Supplier User	Vendor Portal (own vendor only)	own	own (questionnaire)	own	—	—	—	—	—
Vendor Risk Manager	SCM, TPRM, Fourth-party	✓	✓	✓	✓	own	✓	✓	✓

Module-level access summary

The matrix above expressed per module:

Module	Read	Write	Approve	Sign
ERM	RM, RO, all read-only roles	RM, RO	RM	CRO, Executive
BCM	BCM Mgr, BIA Owner, Svc Owner, DR Owner, Crisis Mgr	BCM Mgr, DR Owner	BCM Mgr	CIO, Exec
SCM	Supplier Mgr, Procurement, Vendor Risk Mgr	Supplier Mgr	Vendor Risk Mgr	COO
Cyber	CISO, NCA Compliance Owner, Asset Owner, Vuln Mgr	CISO, Vuln Mgr	CISO	CISO
Privacy	DPO, Privacy Mgr, Data Owner	DPO, Privacy Mgr	DPO	DPO + CISO
Compliance	Compliance Officer, Legal	Compliance Officer	Compliance Officer	Exec
Evidence	Evidence Owner, Auditors	Evidence Owner	Evidence Owner	Auditor (chain)
Incident	Incident Mgr, CISO, Crisis Mgr	Incident Mgr	CISO	CISO + DPO
TPRM	Vendor Risk Mgr, CISO, Procurement	Vendor Risk Mgr	CISO	CISO
Reporting	All execs, Auditors	Board Sec	Board Sec	Chair
Admin / Workflow	System Admin, GRC Admin	System Admin, GRC Admin	System Admin	n/a

Special access patterns

1. **Tenant scope.** Every permission check is filtered by `organisationId`. Users with `PLATFORM_ADMIN` can switch tenants via the org-switcher in the topbar.
2. **Own-record scoping.** Roles with "own" in the matrix can only read/ write records where `owner_user_id = currentUserId()` or where the record is in their direct-report tree.
3. **Auditor windows.** External auditors get a time-bound role `EXTERNAL_AUDITOR` valid only for the engagement window.
4. **Vendor portal.** A vendor user's session is bound to a single `vendor_id`; they cannot enumerate other vendors.
5. **Break-glass.** A `BREAK_GLASS` permission grants temporary `PLATFORM_ADMIN`-like access; every use writes a special audit event and a Slack/Teams alert to the SOC.
6. **MFA enforcement.** Approve / sign actions require MFA satisfied within the last 15 minutes; otherwise re-prompt.

Seeded users (dev profile only)

Username	Password	Role
admin	Admin@12345	PLATFORM_ADMIN
riskmanager	Risk@12345	RISK_MANAGER
auditor	Audit@12345	AUDITOR

These accounts must be disabled in prod.

Saudi GRC Platform

Automation Rules

Source: `automation-rules.md`

10 — Automation and Business Rules

Cross-module automation rules. Each rule is a service-layer hook (`@TransactionalEventListener` or direct invocation) that fires after a state change. Every rule writes an audit event.

#	Rule	Trigger	Conditions	Action	Created records	Notifications	Escalation	Exceptions	Audit
1	Cyber incident → PDPL breach	CyberIncident.transition(NOTIFIED) or asset has pii=true	impacted asset flagged as PII	call CyberPdplBridgeService.triggerForIncident() — creates DataBreach + starts 72h timer + logs to cyber_breach_bridge_log	DataBreach, BridgeEvent	DPO + CISO email + dashboard	Hour-48 to CISO; hour-60 to DPO	BREACH_SKIPPED if breach already exists	bridge log + audit.events
2	System with personal data → PIA	new cyber.cyber_assets row with pii=true	pii=true AND classification IN (CONFIDENTIAL, RESTRICTED)	create Dpia DRAFT + notify DPO	Dpia	DPO	Day-7 if not started	none	dpia.events
3	Critical system → BIA + DRP + NCA assessment	new asset with classification=CRITICAL	criticality CRITICAL	create BIA stub + DRP stub + NCA-CCC control-assessment stub	BiaRecord, DrPlan, ControlAssessment	BCM Mgr + DR Owner + CISO	per-record SLA	system asset already covered → skip	per-stub events
4	Supplier processes personal data → processor DD	new Vendor with data_processor=true	new vendor; processor flag set	create ProcessorAssessment IN_PROGRESS	ProcessorAssessment	DPO	day-14 if not started	none	processor.events
5	Cloud service supports critical → CCC + supplier resilience + DRP review	new cloud-vendor or new critical-service link	service is critical AND vendor is cloud	create NCA-CCC assessment + AlternateSupplier stub + DRP review	ControlAssessment, AlternateSupplier, DrPlan-review	CISO + Vendor Risk Mgr	day-30	none	cloud.bootstrap

#	Rule	Trigger	Conditions	Action	Created records	Notifications	Escalation	Exceptions	Audit
6	Risk exceeds appetite → escalate to committee	Risk.residualScore > appetiteBand.ceiling	residual > ceiling	mark risk ABOVE_APPETITE; add to AppetiteBreachFeed; auto-schedule next risk-committee agenda item	AppetiteBreachEvent + CommitteeAgendaItem	Risk Committee	Daily until accepted/mitigated	accepted risks excluded	breach event + audit
7	BIA RTO < current recovery capability → gap + CAPA	BiaRecord.rto < DrPlan.rto_actual	gap > 0	open CAPA originType=bia_gap severity HIGH; mark BIA GAP_IDENTIFIED	CapaTask	BIA Owner + DR Owner	day-7 if owner not assigned	accepted gaps with active risk acceptance	bia.gap
8	Supplier has no valid BCP → CAPA	vendor has no evidence_links with type=BCP newer than 12 months	criticality HIGH or CRITICAL	open CAPA originType=supplier_bcp_missing severity HIGH	CapaTask	Vendor Risk Mgr	day-14 if not actioned	grace for new vendors (90d)	scm.evidence
9	NCA evidence expires → notify evidence owner + control owner	evidence expiry_date <= today + 30d	scheduled job	mark EXPIRING_SOON; email both owners	EvidenceNotification	Evidence Owner + Control Owner	7d before expiry; expiry day; +7 to CISO	none	evidence.expiry
10	DSR breaches SLA → escalate to Privacy Mgr	DataSubjectRequest.status != FULFILLED AND received_at + 30d - now < 2d	open DSR	escalate to Privacy Mgr + auto-add to DPO daily digest	EscalationEvent	DPO + Privacy Mgr + Compliance	day-23 (DPO), day-28 (Privacy Mgr), day-30 (Compliance)	DSR marked complex with extension	dsr.escalation
11	Risk acceptance expires → reopen risk review	RiskAcceptance.expiry_date <= today	active acceptance	flip risk to EXPIRED review; create review task; notify Risk Owner + CRO	Task	Risk Owner + CRO	7d to re-decide	none	risk.acceptance.expiry

#	Rule	Trigger	Conditions	Action	Created records	Notifications	Escalation	Exceptions	Audit
12	Fourth-party concentration HIGH → CAPA (NEW — TprmAutomationService)	FourthPartyExposure.concentration_risk newly = HIGH	rising edge only	open CAPA originType=fourth_party_exposure severity HIGH	CapaTask	Vendor Risk Mgr	day-30 target	none	tprm.automation
13	Processor DD FAIL → CAPA (NEW)	ProcessorAssessment.overall_outcome = FAIL AND status=COMPLETED	overall outcome FAIL	open CAPA originType=processor_assessment severity CRITICAL	CapaTask	DPO + CISO	day-45 target	none	tprm.automation
14	Resilience test FAIL → CAPA (NEW)	SupplierResilienceTest.outcome = FAIL AND status=COMPLETED	FAIL outcome	open CAPA originType=supplier_resilience_test severity HIGH	CapaTask	Vendor Risk Mgr + BCM	day-60 target	none	tprm.automation
15	RCA APPROVED → spawn CAPAs	RootCauseAnalysis.status = APPROVED	recommendations text parsed	parse numbered list; create one CAPA per recommendation; append CAPA IDs back to RCA capa_refs	N × CapaTask	RCA owner	per CAPA SLA	none	rca.capa.gen
16	Evidence chain BROKEN → alert	EvidenceChainVerifyService finds break	scheduled or on-demand	mark item chain_status=BROKEN; notify Evidence Owner + Auditor	ChainBreakEvent	Evidence Owner + Compliance	next business day	manual override with sign-off	evidence.chain.break
17	Vendor exit-plan rehearsal FAIL → CAPA + DRP re-test	ExitPlan.recordTest(outcome=FAIL)	FAIL outcome	open CAPA; schedule DR retest within 90d	CapaTask + DRP TestSchedule	COO + BCM Mgr	day-90	none	scm.exit.fail

#	Rule	Trigger	Conditions	Action	Created records	Notifications	Escalation	Exceptions	Audit
18	KRI threshold breached → KRI breach event + escalate	KRI value crosses threshold	value > threshold	record KriBreachEvent; notify Risk Owner; escalate at +14d if unresolved	KriBreachEvent	Risk Owner	day-7 RM; day-14 Risk Committee	none	kri.breach
19	Policy expires → renew workflow	Policy.effective_to - today <= 30d	scheduled	start renewal workflow; assign to policy owner	Renewal Task	Policy Owner	day-7 escalate to Compliance	none	policy.renewal
20	Cross-border transfer expires → reassess	CrossBorderTransfer.expiry_date <= today + 30d	scheduled	flip to REVIEW_DUE; notify DPO	ReviewTask	DPO	day-30	none	cbt.review
21	Vulnerability critical 30d overdue → CAPA	Vulnerability.severity=CRITICAL AND created_at + 30d < now	overdue	open CAPA + alert CISO	CapaTask	Vuln Mgr + CISO	daily	accepted exceptions	vuln.overdue
22	Board-pack signed → distribute	DigitalSignatureTransaction.status=SIGNED AND purpose contains BOARD_PACK	chairman signed	distribute pack to board members + audit committee	DistributionEvent	Board members	n/a	none	reporting.board.dist
23	Workflow promote to ACTIVE → version snapshot	WorkflowVersion.status=DRAFT → ACTIVE	version promote	snapshot prior ACTIVE → DEPRECATED; broadcast to in-flight workflows	WorkflowVersion	Workflow users	n/a	none	workflow.promote
24	Tenant white-label change → realtime broadcast	Organisation.branding_json update	new branding	realtime push to all sessions for that tenant	broadcast event	tenant users	n/a	none	branding.update

#	Rule	Trigger	Conditions	Action	Created records	Notifications	Escalation	Exceptions	Audit
25	Suspicious login → MFA challenge	login from new IP/UA combination	risk score > threshold	force MFA before allowing session	AuthChallenge	user	block after 3 fails	none	auth.suspicious
26	Failed Art. 28 control C5 (breach notification) → open bridge config	ProcessorAssessment.c5_breach_notification=FAIL	C5 fail	flag bridge-config gap on the related vendor	Gap flag	DPO	day-14	none	bridge.config.gap
27	Crisis declared → invocation of related BCPs	CrisisEvent.declare()	severity ≥ SEV2	auto-invoke BCPs for affected services	Invocation × N	service owners	hour-1	none	crisis.invoke
28	Lessons-learned approved → propagate	Lessons Learned. status=APPROVED	per source	distribute to relevant BIAs + DRPs + risk register; create tasks for material changes	LinkedTasks	owners	per task	none	lessons.dispatch

Notification routing

Every rule's notifications go through `notification.outbox` and respect the recipient's channel preferences (`notification.channels`): EMAIL, SMS, WEBHOOK, MS Teams. Dashboard surfaces always update via realtime broadcaster `changed.{entity}`.

Exceptions / suppression

- A rule fires only on a rising-edge state change (no infinite loops).
- An admin can suppress a rule per-record via the `automation.suppressions` table (audit-logged).
- The `BREAK_GLASS` permission bypasses suppression checks for a single manual action.

Saudi GRC Platform

Reports Dashboards

Source: `reports-dashboards.md`

11 — Reports and Dashboards

Report catalogue. Every report is generated via the reporting module (`/api/v1/reporting/*`) with bilingual templates and ExportMenu support.

Shared: - Formats: PDF + XLSX + PPTX where useful; CSV always available. - Bilingual: every template has EN + AR variants; `lang` query param. - Audit: every export writes to `audit.events` (`verb=export`). - Digital signature: where required, the export pipeline pauses until a signing transaction completes.

---

1. Board Risk Report

- **Audience**: Board, Audit Committee, CRO
- **Purpose**: quarterly enterprise risk snapshot for governance review
- **Sections**: cover + executive summary + heatmap + top-10 risks + appetite-breach feed + KRI dashboard + acceptances + CAPA + emerging-risk watchlist
- **KPIs/KRIs**: total risks, critical risks, appetite breaches, KRI breaches, # acceptances, average treatment age
- **Charts**: heatmap (5x5), risks by category bar, trend line per appetite band
- **Tables**: top-10 risks, recent acceptances, open CAPAs, emerging risks
- **Filters**: organisation, quarter, category
- **Formats**: PDF + PPTX + XLSX
- **Approval**: Risk Mgr → CRO → Board
- **Signature**: ✓ Chairman
- **Path**: Board Pack module, `/api/v1/reporting/board-pack-pdf`

2. Executive GRC Dashboard

- **Audience**: CxOs, CEO
- **Purpose**: live snapshot across all GRC modules
- **Surfaces**: `/dashboard` widget grid
- **KPIs**: critical risks open, compliance %, control coverage, open incidents, BCM readiness, supplier-resilience score, PDPL DSR SLA
- **Filters**: organisation, time window
- **Formats**: live + PDF snapshot
- **Signature**: not required for view; required for snapshot export

3. BCM Readiness Report

- **Audience**: BCM Manager, COO, Risk Mgr
- **Purpose**: programme readiness summary
- **Sections**: critical-services count + BIA completeness + BCP coverage + DR-test status + exercise programme + open CAPAs
- **KPIs**: critical-services with current BIA %, plans with current test %, average RTO target vs actual

- **Charts**: BIA freshness donut, DR-test status by tier
- **Tables**: critical services without BIA / BCP / DRP
- **Formats**: PDF + XLSX
- **Signature**: optional (BCM Mgr)

4. Critical Services Continuity Report

- **Audience**: COO, Service Owners
- **Purpose**: per-service continuity posture
- **Sections**: service header → BIA → BCP → DRP → exercises → gaps
- **Filters**: service, criticality
- **Formats**: PDF
- **Signature**: optional

5. DR Readiness Report

- **Audience**: CIO, BCM Mgr
- **Purpose**: DR plans + test outcomes + RTO/RPO trends
- **Sections**: per-plan card + last-test outcome + next-test calendar + RTO target vs actual + gaps
- **Charts**: test outcomes timeline, RTO trend per system
- **Formats**: PDF + XLSX

6. Crisis Exercise Report

- **Audience**: Crisis Mgr, BCM Mgr, Exec
- **Purpose**: after-action from a crisis exercise
- **Sections**: scenario + timeline + participants + observations + CAPAs
- **Formats**: PDF
- **Signature**: BCM Mgr

7. Supplier Resilience Report

- **Audience**: COO, Vendor Risk Mgr, BCM
- **Purpose**: supplier portfolio resilience posture
- **Sections**: critical vendors + alternates + exit plans + tests + fourth-party concentration
- **KPIs**: % critical vendors with valid alternate, % with current exit plan, % tested in last 12m
- **Filters**: criticality, tier, country
- **Formats**: PDF + XLSX

8. NCA Compliance Report

- **Audience**: CISO, NCA Compliance Owner, Internal Audit
- **Purpose**: NCA control coverage and maturity

- **Sections**: per-framework heatmap + maturity bars + gap list + CAPA pipeline
- **KPIs**: implementation %, average maturity per domain
- **Filters**: framework (ECC/CSCC/CCC/OTCC/SAMA)
- **Formats**: PDF + XLSX
- **Signature**: ✓ CISO for filing

9. PDPL Compliance Report

- **Audience**: DPO, Privacy Mgr, Exec
- **Purpose**: PDPL article-by-article coverage
- **Sections**: ROPA freshness + notices + consent rollup + DSR SLA + breach register + CBT + disposal + processor DD + DSA
- **KPIs**: ROPA reviewed-last-90d %, DSR within-SLA %, notification within 72h %, current processor assessments %
- **Filters**: lawful-basis, data category
- **Formats**: PDF + XLSX

10. Regulatory Compliance Report

- **Audience**: Compliance Officer, Internal Audit
- **Purpose**: cross-framework compliance posture
- **Sections**: per-framework summary + control coverage + open gaps
- **Filters**: framework, regulator
- **Formats**: PDF + XLSX

11. Corrective Action Status Report

- **Audience**: CAPA owners, managers
- **Purpose**: open / overdue / closed CAPAs
- **Sections**: open by severity + overdue + by origin + verification queue
- **KPIs**: open count, average age, overdue %
- **Formats**: PDF + XLSX

12. Risk Appetite Breach Report

- **Audience**: Risk Committee, CRO
- **Purpose**: above-appetite exposures
- **Sections**: appetite statement + breach feed + acceptances
- **Formats**: PDF

13. Cyber Incident Report

- **Audience**: CISO, SOC, regulator

- **Purpose**: per-incident or roll-up
- **Sections**: timeline + classification + impacted assets + IOCs + containment + recovery + lessons learned + CAPAs
- **Formats**: PDF (per incident) + XLSX (roll-up)
- **Signature**: required at regulator-notification step

14. Data Breach Report

- **Audience**: DPO, CISO, SDAIA liaison
- **Purpose**: PDPL Art. 20 breach notification + post-event report
- **Sections**: scope + affected subjects + categories + containment + notification record
- **Signature**: ✓ DPO

15. Audit Evidence Package

- **Audience**: Internal + External Auditors
- **Purpose**: per-engagement evidence zip
- **Sections**: cover + scope + linked evidence + signed attestations + chain-of-custody verification report
- **Formats**: ZIP (PDF + supporting files)

16. Management Review Report

- **Audience**: Executive, Board
- **Purpose**: ISO clause 9.3 management review (BCM + ISMS + privacy)
- **Sections**: status of actions from prior review + KPIs/KRIs + audit-findings status + non-conformity + improvements
- **Formats**: PDF + PPTX
- **Signature**: ✓ Exec

Saudi GRC Platform

Implementation Backlog

Source: `implementation-backlog.md`

12 — Implementation Backlog

Agile backlog grouped by epic. Status reflects the platform at HEAD. Stories not marked DONE are recommended next-sprint work.

Statuses: **DONE** ✓ shipped · **IN_PROGRESS** ■ partly shipped · **PLANNED** ■

EPIC 1 — Foundation Platform ✓ DONE

Story	Priority	Status	Notes
F1.1 Multi-tenant Organisation model with TenantContext	P0	✓	platform/tenant/
F1.2 Bilingual EN/AR shell with RTL/LTR auto-switch	P0	✓	lib/i18n.tsx
F1.3 JWT auth + refresh + MFA	P0	✓	module/auth/
F1.4 IAM (users, roles, permissions, SSO/Nafath)	P0	✓	module/iam/
F1.5 Audit log + realtime broadcaster	P0	✓	platform/audit/ + STOMP
F1.6 Soft-delete + audit on every entity (BaseEntity)	P0	✓	enforced via @Where
F1.7 White-label / branding	P1	✓	lib/whiteLabel.ts

Acceptance: any new module inherits tenant + audit + soft-delete for free. ✓ verified across 17 backend modules.

EPIC 2 — Regulatory Library ✓ DONE

Story	Priority	Status
F2.1 Framework catalogue (NCA + SAMA + ISO + PCI)	P0	✓ V37
F2.2 Control library (145 controls)	P0	✓ V42-44, V49
F2.3 Requirement → control crosswalk	P0	✓
F2.4 Per-tenant applicability	P0	✓
F2.5 Regulatory change feed	P1	✓ compliance/regulatory-change/

EPIC 3 — Workflow Engine ✓ DONE

Story	Priority	Status
F3.1 State-machine service pattern with IllegalTransitionException	P0	✓
F3.2 Workflow versioning DRAFT→ACTIVE→DEPRECATED	P0	✓
F3.3 Workflow designer UI	P1	✓ WorkflowDesigner.tsx

Story	Priority	Status
F3.4 SLA timers + escalations	P0	✓
F3.5 Approval matrix per workflow	P0	✓

EPIC 4 — Evidence Repository ✓ DONE

Story	Priority	Status
F4.1 Evidence items + versions + links	P0	✓
F4.2 SHA-256 chain-of-custody (V47)	P0	✓
F4.3 Bilingual evidence catalogue	P0	✓
F4.4 Per-tenant permissions	P0	✓
F4.5 Expiry + renewal workflow	P1	✓

EPIC 5 — ERM ✓ DONE

Story	Priority	Status
F5.1 Risk register + assessment + treatment	P0	✓
F5.2 Appetite + breach feed	P0	✓
F5.3 KRI definitions + breach events	P0	✓
F5.4 Scenario analysis (Monte Carlo + stress + what-if)	P0	✓ V35
F5.5 Emerging risk (horizon-scan)	P0	✓ V39
F5.6 Committee workflows	P0	✓ V40
F5.7 Risk acceptance with digital signature	P0	✓
F5.8 Lessons-learned integration	P1	✓

EPIC 6 — BCM ✓ DONE

Story	Priority	Status
F6.1 Critical services + BIA	P0	✓
F6.2 BCP builder	P0	✓
F6.3 IT DRP with site type + failover/failback steps	P0	✓ V41
F6.4 Exercise programme	P0	✓
F6.5 Crisis activation + comms templates	P0	✓
F6.6 Dependency map	P0	✓
F6.7 Lessons learned	P1	✓

EPIC 7 — Supply Chain Resilience ✓ DONE

Story	Priority	Status
F7.1 Vendor register + criticality + assessment	P0	✓
F7.2 Alternate supplier + exit plan	P0	✓ V36
F7.3 Supplier resilience tests	P0	✓ V54
F7.4 Fourth-party exposure + concentration risk	P0	✓ V50
F7.5 Contract clause library	P0	✓ V45
F7.6 SLA monitoring	P1	✓
F7.7 Consolidated TPRM overview	P1	✓ (component)

EPIC 8 — NCA Compliance ✓ DONE

Story	Priority	Status
F8.1 ECC framework + 30 seeded controls	P0	✓
F8.2 CSCC + 32 controls	P0	✓ V42
F8.3 CCC + 30 controls	P0	✓ V43
F8.4 OTCC + 27 controls	P0	✓ V44
F8.5 SAMA + ISO 22301 + PCI DSS seeds	P0	✓ V49
F8.6 NCA self-assessment + filing	P0	✓
F8.7 Cyber incident NIST 800-61 lifecycle	P0	✓
F8.8 RCA with CAPA generation	P0	✓ V31

EPIC 9 — PDPL Compliance ✓ DONE

Story	Priority	Status
F9.1 ROPA register	P0	✓
F9.2 Privacy notices	P0	✓ V32
F9.3 Consent	P0	✓
F9.4 DSR (30-day SLA)	P0	✓
F9.5 PIA	P0	✓
F9.6 Personal data breach (72h timer)	P0	✓
F9.7 Cross-border transfer	P0	✓ V32
F9.8 Disposal certificate	P0	✓ V32
F9.9 Data sharing agreement	P0	✓ V51
F9.10 Processor due diligence (Art. 28)	P0	✓ V52

Story	Priority	Status
F9.11 Cyber→PDPL bridge automation	P0	✓ V46

EPIC 10 — Incident & Crisis ✓ DONE

Story	Priority	Status
F10.1 Incident lifecycle (NIST 800-61)	P0	✓
F10.2 Crisis activation	P0	✓
F10.3 Regulator notification routing	P0	✓
F10.4 RCA + CAPA wiring	P0	✓ V31
F10.5 Lessons learned	P1	✓

EPIC 11 — Reporting & Dashboards ✓ DONE

Story	Priority	Status
F11.1 Customisable dashboard with widgets	P0	✓
F11.2 Board pack PDF + PPTX	P0	✓
F11.3 Scheduled reports	P1	✓
F11.4 Per-regulator evidence pack export	P0	✓
F11.5 TPRM snapshot widget	P1	✓ (this doc set)

EPIC 12 — Digital Signature ✓ DONE

Story	Priority	Status
F12.1 Signature transactions	P0	✓ V30
F12.2 Provider-pluggable (internal/DocuSign/Absher/Nafath)	P1	✓
F12.3 SHA-256 payload binding	P0	✓
F12.4 Inbox + history	P0	✓

EPIC 13 — Administration & Workflow Config ✓ DONE

Story	Priority	Status
F13.1 Tenant management	P0	✓
F13.2 User + role + permission management	P0	✓
F13.3 Committees	P0	✓ V40
F13.4 Notification channels + outbox	P0	✓
F13.5 Workflow versioning UI	P1	✓

Story	Priority	Status
F13.6 White-label	P1	✓

EPIC 14 — API & Integration Layer ✓ DONE

Story	Priority	Status
F14.1 OpenAPI/Swagger at /swagger-ui.html	P0	✓
F14.2 Connectors (intake, vendor, regulator feeds)	P1	✓
F14.3 Realtime broadcaster (STOMP/WS)	P0	✓
F14.4 Webhook outbox	P1	✓

EPIC 15 — Bilingual AR/EN UI ✓ DONE

Story	Priority	Status
F15.1 EN + AR dictionaries with parallel keys	P0	✓
F15.2 RTL CSS + logical properties	P0	✓
F15.3 Hijri calendar surface	P1	✓ HijriDate.tsx
F15.4 Saudi-native Arabic phrasing	P1	✓ (this doc set)
F15.5 PDF/PPTX bilingual templates	P0	✓

EPIC 16 — TPRM Automation (this doc set) ✓ DONE

Story	Priority	Status
F16.1 Auto-CAPA on processor FAIL	P0	✓
F16.2 Auto-CAPA on fourth-party HIGH concentration	P0	✓
F16.3 Auto-CAPA on resilience-test FAIL	P0	✓
F16.4 Cross-module link chips	P1	✓
F16.5 Consolidated /tprm overview	P0	✓
F16.6 Dashboard TPRM snapshot widget	P1	✓

Sprint grouping (post-shipment recommendations)

Sprint 7 — Operate & Tune

- Hardening pass on the 50+ NVARCHAR columns that previously had mojibake (write a Flyway migration that re-asserts canonical Arabic literals).

- Auto-CAPA noise tuning (suppression for already-known issues).
- Saudi-native Arabic polish pass on remaining ~2,000 keys.
- Performance budget: page LCP < 2s on cold load.

Sprint 8 — AI Governance

- AI register (similar to ROPA, per AI use-case).
- LLM provider DD (extension of Processor Assessment).
- Bias / fairness audit workflow.

Sprint 9 — ESG / Vision 2030 alignment

- ESG framework seeds.
- Vision-2030 KPI overlay on dashboard.
- Saudization (Nitaqat) deeper integration.

Sprint 10 — Advanced analytics

- Time-series KPI store.
- Forecasting (e.g. CAPA backlog burn-down).
- Multi-tenant benchmarking (anonymised).

Saudi GRC Platform

Developer Handoff

Source: `developer-handoff.md`

14 — Developer Handoff Specification

Everything a developer joining the platform needs to be productive on day one. Anchored to the actual code at HEAD.

---

1. Platform assumptions

- Single SQL Server database per tenant; multi-tenant logical isolation via `organisationId` on every row.
- Java 17 (pinned — Lombok incompatible with Java 25 in this repo).
- Spring Boot 3.5 + Hibernate 6 + Spring Security 6.
- React 18 + Vite 5 + TypeScript (strict). No SSR.
- Backend port 8084 (dev); frontend dev server 5173 (proxies `/api` and `/ws` to 8084).
- Hard rules: never disable hooks, never commit secrets, never run `mvn flyway:clean`.

2. Recommended architecture

Layer	Choice	Why
Backend	Spring Boot modular monolith	one repo, one process, fast iteration; modules under module/
ORM	Hibernate 6 / Spring Data JPA	familiar; @Where for soft-delete
API	REST JSON over HTTPS; STOMP/WebSocket for realtime	broad client compat
DB	SQL Server 2019+ with UTF-8 collation	KSA-common; collation Latin1_General_100_CI_AS_SC_UTF8
Migrations	Flyway (non-dev profiles); Python bootstrap scripts (dev)	controlled prod; flexible dev
Caching	Caffeine L1	adequate for current scale
Background work	@Scheduled + @Async	simple; Spring TaskExecutor
Frontend	Vite + React 18 + TanStack Query (via shared lib/api.ts)	fast HMR; SSR-not-needed
Charts	Chart.js 4 + custom 3D bars	bilingual + RTL-aware
PDF	OpenPDF 1.3 + RTL font config	Arabic shaping support
XLSX	Apache POI 5.2	full-featured
Auth	JJWT 0.12.6 (HS256 access, HttpOnly refresh cookie)	stateless + safe
Observability	Actuator + JSON logs + Micrometer	standard

3. Workflow engine requirements

- Each module owns its state machine in its `service/` class.
- Transition methods throw `IllegalTransitionException` (HTTP 409) on forbidden moves.
- Every transition: (a) writes to audit, (b) broadcasts via `RealtimeBroadcaster`, (c) calls automation hooks.

- Workflow versions live in `workflow.workflow_versions`; in-flight records keep their start-version snapshot.

4. API requirements

- All endpoints under `/api/...`.
- OpenAPI 3 at `/v3/api-docs`, Swagger UI at `/swagger-ui.html` (dev only).
- Standard responses: 200 (ok), 201 (created), 204 (no-content), 400 (validation), 401 (unauth), 403 (forbidden), 404 (not-found), 409 (illegal transition), 500 (with problem-detail JSON).
- Pagination: `?page=&size=` returning Spring `Page` JSON.
- Filtering: query params per resource; complex via filter modal payload.
- Sorting: `?sort=field,asc|desc`.
- Bilingual: every entity returns `*_en` + `*_ar`; client picks.
- CORS: dev allowlist in `application-dev.yml`; prod via Ingress.

5. Database requirements

- Soft-delete: every business table has `is_deleted SMALLINT DEFAULT 0`; every JPA entity has `@Where(clause = "is_deleted = 0")`.
- Tenancy: every business table has `organisation_id BIGINT NOT NULL`; indexed first in any composite index.
- Audit columns: `created_at`, `created_by`, `updated_at`, `updated_by`, `deleted_at`, `deleted_by`, `row_version`.
- Bilingual: `*_en NVARCHAR(N) NOT NULL`, `*_ar NVARCHAR(N) NULL` (AR recommended but not required).
- Foreign keys: indexed on both sides; cascade behaviour explicit.
- Migrations: Flyway, V*-numbered, idempotent (`IF NOT EXISTS` guards).
- Encoding: SQL files saved as UTF-8 with BOM; Flyway `encoding=UTF-8` in `application.yml`.

6. Audit-trail requirements

- Every state transition writes to `audit.events`.
- Sensitive reads (auditor view, PII access) also write read-events.
- `audit.events` retention: 60 months minimum.
- Only roles with `AUDIT_READ` permission can query.
- Tamper-evidence: optional periodic chain hash of `audit.events` blocks (planned).

7. Notification requirements

- All notifications flow through `notification.outbox`.
- Per-recipient channel preferences in `notification.channels`.
- Channels supported: EMAIL (SMTP), SMS (placeholder for Saudi gateway), WEBHOOK (HMAC signed), MS Teams (webhook).

- Outbox processor: `@Scheduled(fixedDelay)`; at-least-once with idempotency key.

8. Integration requirements

- Inbound: REST + scheduled fetchers + webhook receivers (intake module).
- Outbound: webhook to vendors / regulators / connected systems.
- File exchange: SFTP (planned) for regulator filings.
- Federation: SSO/SAML2 + OIDC; Saudi-specific Nafath integration via `module/iam/sso/`.
- Connectors directory: `tss-grc-backend/src/main/java/com/tss/grc/module/intake/connectors/`.

9. Digital signature requirements

- Generic transaction model (`signature.digital_signature_transactions`) with `provider` field.
- Providers: INTERNAL (HS256 hash), DOCUSIGN, ABSHER, NAFATH, custom.
- Provider-specific adapters under `module/signature/provider/`.
- Bind signature to a SHA-256 digest of the payload at sign-time so the signer can't repudiate by changing the underlying record.
- MFA must be within 15 minutes of the sign action.

10. Security requirements

- TLS 1.2+ at edge; backend HTTP only on local interface.
- JWT secret rotation: at least quarterly (deploy-pipeline-managed env var).
- Password policy: min 12 chars, complexity, no top-1000 list, history 12.
- MFA: TOTP default; SMS as fallback; WebAuthn (planned).
- Brute-force: 5 fails → 15-min lockout (prod); 99 fails → 1-min in dev.
- CSP: strict; Swagger UI exempted in dev only.
- DB at rest: TDE + per-blob AES-256.
- Backups: encrypted, off-site, restore-tested quarterly.

11. Localization requirements

- Two languages: ar-SA (primary), en (secondary).
- Calendar: dual surface (Gregorian + Hijri) for user-facing dates.
- Number formats: Arabic-Indic digits optional per user pref; ISO-8601 internally.
- Currency: SAR primary; multi-currency where business-meaningful.
- RTL CSS: logical properties (`margin-inline-start`, `padding-inline-end`) throughout — no `left`/`right`.
- PDF/PPTX rendering: dedicated `RtlFontConfig` with shaping-aware Arabic font stack.

12. Reporting requirements

- Bilingual report templates (one definition, two render passes).

- Export pipeline: queueable for >5s reports; live for snapshot.
- Watermarking: classification stamp on every export.
- Audit: every export writes `audit.events` (verb=export).
- Board pack: signed (Chairman); distributed only after sign.

13. Testing requirements

- Backend: 272+ JUnit/Spring tests at HEAD; minimum 70% line coverage on service layer.
- Frontend: TypeScript strict; per-page smoke test with `mcp__Claude_Preview__preview` during dev.
- Integration: Postman/Bruno collection mirroring OpenAPI.
- UAT: per the test-case catalogue in `/14-Test-Cases/`.
- Performance: page LCP < 2s on cold load (target).

14. Data migration requirements

- Greenfield: Flyway V1..VN bootstraps everything; dev uses Python scripts (`setup_*.py`) for speed.
- Brownfield (customer-import):
- One-off ETL into `migration_staging.*` tables.
- Then `INSERT INTO module.* SELECT ... FROM migration_staging.*`.
- Mark all imported rows with `external_id` containing the source system identifier.
- Mojibake fix: `fix_arabic_mojibake.py` runs after any non-UTF-8 import to repair encoded Arabic.

Repo layout cheat sheet

```
/
■■■ tss-grc-backend/ ← Spring Boot REST API
■ ■■■ src/main/java/com/tss/grc/
■ ■■■ GrcApplication.java
■ ■■■ config/ ← Security, Cors, DataSource, Cache, OpenApi, Locale, WebMvc
■ ■■■ security/ ← JwtTokenProvider, JwtAuthenticationFilter, GrcUserDetails,
ModulePermissionEvaluator
■ ■■■ common/ ← BaseEntity, tenant/, exception/, model/
■ ■■■ module/ ← 17 functional modules
■ ■■■ auth, iam, admin, risk, bcm, scm, tprm, cyber,
■ ■■■ compliance, privacy, evidence, incident, capa,
■ ■■■ signature, workflow, reporting, dashboard, platform
■■■ tss-grc-ui-v2/ ← Frontend
■ ■■■ src/
■ ■■■ App.tsx
■ ■■■ lib/ ← api.ts, auth.ts, i18n.tsx, toast.tsx, ...
■ ■■■ components/ ← layout/, ui/, viz/, ...
■ ■■■ pages/ ← one folder per route
■ ■■■ translations/ ← en.ts + ar.ts
■■■ tss-grc-backend/src/main/resources/
■ ■■■ application.yml + application-dev.yml + application-prod.yml
```

```
■ ■■■ messages*.properties ← server i18n
■ ■■■ db/migration/sqlserver/ ← Flyway V*
■■■ Saudi-GRC-Platform-Integration/ ← this deliverable package
■■■ docs/ ← internal docs
```

Onboarding checklist

- [ ] Clone repo
- [ ] Install JDK 17, Maven, Node 20, SQL Server 2019
- [ ] Create DB `TSS_GRC` with `Latin1_General_100_CI_AS_SC_UTF8`
- [ ] Run Python bootstrap scripts (`setup_cyber_db.py`, `setup_bcm_db.py`, `fix_arabic_db.py`)
- [ ] Set env `JWT_SECRET`, `DB_USERNAME`, `DB_PASSWORD`
- [ ] `mvn spring-boot:run -Dspring-boot.run.profiles=dev`
- [ ] `cd tss-grc-ui-v2 && npm install && npm run dev`
- [ ] Login `admin / Admin@12345` at `http://localhost:5173`

Saudi GRC Platform

Api Specification

Source: `api-specification.md`

13 — API Specification

The live OpenAPI 3 spec is published at `/v3/api-docs`; Swagger UI at `/swagger-ui.html` (dev profile only). This document summarises the contract and the conventions every endpoint follows.

Auth

Endpoint	Method	Purpose
/api/auth/login	POST	username + password → access token (body) + refresh cookie
/api/auth/refresh	POST	refresh-cookie → new access token
/api/auth/logout	POST	revoke session
/api/auth/me	GET	current user + organisation
/api/auth/switch-org	POST	switch active organisation (platform admin)

Risk & ERM

Endpoint	Method	Purpose
/api/risk/risks	CRUD	Risk register
/api/risk/assessments	CRUD	Risk assessments
/api/risk/appetite	CRUD	Appetite statements
/api/risk/kris	CRUD	KRI definitions
/api/risk/kri-breaches	GET, POST	KRI breach events
/api/risk/scenarios	CRUD + /approve /reject /archive	Scenario analysis
/api/risk/emerging	CRUD + /review /escalate /mature /dismiss	Emerging risk

BCM

Endpoint	Method	Purpose
/api/bcm/services	CRUD	Critical services
/api/bcm/bia	CRUD + /approve	BIA records
/api/bcm/plans	CRUD	BCPs
/api/bcm/dr-plans	CRUD + /approve /reject /activate /archive /record-test	DR plans
/api/bcm/exercises	CRUD	Exercises
/api/bcm/invocations	CRUD + /declare /standdown	Crisis invocations
/api/bcm/crisis-templates	CRUD	Crisis comms templates

SCM

Endpoint	Method	Purpose
/api/scm/vendors	CRUD	Vendor register
/api/scm/dependencies	CRUD	Dependency map
/api/scm/resilience/alternates	CRUD + /approve /archive	Alternate suppliers
/api/scm/resilience/exit-plans	CRUD + /approve /reject /activate /archive /record-test	Exit plans
/api/scm/resilience/tests	CRUD + /start /complete /approve /cancel	Resilience tests
/api/scm/fourth-party	CRUD + /validate /mitigate /retire	Fourth-party exposure
/api/scm/contract-clauses	CRUD + /approve /deprecate	Contract clause library

TPRM

Endpoint	Method	Purpose
/api/v1/tprm/vendors	CRUD	TPRM vendor master
/api/v1/tprm/assessments	CRUD	Generic vendor assessment
/api/v1/tprm/onboarding	GET, POST	Onboarding pipeline
/api/v1/tprm/reassessments	GET	Reassessment due dashboard
/api/tprm/cyber-assessments	CRUD + /posture /submit /approve /retire	Third-party cyber risk

Cyber

Endpoint	Method	Purpose
/api/v1/cyber/frameworks	GET	Cyber frameworks
/api/v1/cyber/controls	GET (paged)	Controls (paged)
/api/v1/cyber/controls/all	GET	All controls (for filtering UI)
/api/v1/cyber/sub-controls	GET	Sub-controls
/api/v1/cyber/assessments	CRUD	Control assessments
/api/v1/cyber/incidents	CRUD + /transition	Cyber incidents
/api/v1/cyber/vulnerabilities	CRUD	Vulnerabilities
/api/v1/cyber/exceptions	CRUD	Exceptions
/api/v1/cyber/assets	CRUD	Cyber assets
/api/v1/cyber/assets/all	GET	All assets
/api/v1/cyber/evidence	GET	Cyber evidence
/api/v1/cyber/action-plans	CRUD	Cyber action plans

Incident & RCA

Endpoint	Method	Purpose
/api/incident/incidents	CRUD	Generic incidents
/api/incident/timeline	CRUD	Timeline events
/api/incident/lessons	CRUD	Lessons learned
/api/incident/rca	CRUD + /submit /approve /reject /generate-capas	Root-cause analysis

Privacy / PDPL

Endpoint	Method	Purpose
/api/privacy/ropa	CRUD	ROPA
/api/privacy/ropa-workflows/{code}	GET	Per-ROPA workflow bundle
/api/privacy/ropa-workflows/{code}/counts	GET	Per-ROPA counts
/api/privacy/notices	CRUD + /publish /archive /supersede	Privacy notices
/api/privacy/consents	CRUD	Consent records
/api/privacy/dsr	CRUD + /assign /fulfil /reject	DSR cases
/api/privacy/dpias	CRUD + /submit /approve /reject	PIAs
/api/privacy/breaches	CRUD + /notify /close	Personal-data breaches
/api/privacy/cross-border-transfers	CRUD + /assess /approve /reject	Cross-border transfers
/api/privacy/disposal-certificates	CRUD + /start /complete /verify	Disposal certificates
/api/privacy/data-sharing	CRUD + /submit /activate /expire /terminate	Data sharing agreements
/api/privacy/processor-assessments	CRUD + /score /approve /reject	Processor due diligence
/api/privacy/cyber-bridge/log	GET	Cyber→PDPL bridge audit log
/api/privacy/cyber-bridge/trigger	POST	Manual bridge fire

Compliance

Endpoint	Method	Purpose
/api/compliance/frameworks	GET	Frameworks
/api/compliance/requirements	GET	Requirements
/api/compliance/controls	CRUD	Controls
/api/compliance/policies	CRUD	Policies
/api/compliance/regulatory-changes	CRUD	Regulatory feed
/api/compliance/attestation-campaigns	CRUD	Campaigns

Evidence

Endpoint	Method	Purpose
/api/v1/evidence/items	CRUD	Evidence items
/api/v1/evidence/versions	CRUD	Versions
/api/v1/evidence/links	CRUD	Links
/api/evidence/chain	GET	Chain summaries
/api/evidence/chain/{id}	GET	Per-item chain report
/api/evidence/chain/{id}/verify	POST	Verify chain

Signature

Endpoint	Method	Purpose
/api/signature/transactions	CRUD	Transactions
/api/signature/transactions/inbox	GET	My inbox
/api/signature/transactions/by-entity	GET	Per-entity
/api/signature/transactions/{id}/sign	POST	Sign
/api/signature/transactions/{id}/reject	POST	Reject

CAPA

Endpoint	Method	Purpose
/api/capa/tasks	CRUD + /transition	CAPA tasks

Admin / Workflow

Endpoint	Method	Purpose
/api/admin/organisations	CRUD	Tenants
/api/admin/users	CRUD	Users
/api/admin/roles	CRUD	Roles
/api/admin/committees	CRUD + /dissolve	Committees
/api/admin/committees/meetings	CRUD + /start /complete /approve-minutes /cancel	Meetings
/api/workflow/workflows	CRUD	Workflows
/api/workflow/versions	CRUD + /promote	Versions
/api/notification/channels	CRUD	Channels
/api/notification/outbox	GET	Outbox

Reporting / Dashboard

Endpoint	Method	Purpose
/api/v1/dashboard/stats	GET	Dashboard KPIs

Endpoint	Method	Purpose
/api/v1/dashboard/heatmap	GET	Risk heatmap data
/api/v1/reporting/board-pack-pdf	POST	Generate board pack PDF
/api/v1/reporting/board-pack-pptx	POST	Generate board pack PPTX
/api/v1/reporting/risk-register-pdf	POST	Export risk register
/api/v1/reporting/risk-register-xlsx	POST	Export risk register
/api/v1/reporting/nca-filing-pdf	POST	NCA self-assessment filing
/api/v1/reporting/regulatory-package	POST	Per-regulator zip
/api/v1/reporting/schedules	CRUD	Scheduled reports

WebSocket

- Endpoint: `/ws` (STOMP).
- Topic prefix: `/topic/`.
- Per-org filtered topics: `/topic/{orgId}/changed.{entity}`.
- Used by every list page for live refresh.

Saudi GRC Platform

Test Cases

Source: `test-cases.md`

15 — Test Cases and UAT Scenarios

Per-workflow test cases for UAT. Each case has: ID, scenario, preconditions, steps, expected result, role, pass/fail criteria.

TC-BIA-001 — Score a new BIA and approve

- **Scenario**: New service requires a BIA cycle.
- **Preconditions**: critical service exists; user is BIA Owner.
- **Steps**: 1. Navigate to `/bcm`, click BIA tab, click "New BIA". 2. Select service. Fill impact dimensions, MTPD 24h, RTO 4h, RPO 1h. 3. Add dependency on `DB-PRIMARY`. 4. Save → submit for review. 5. BCM Manager logs in, opens BIA, clicks Approve.
- **Expected**: BIA status APPROVED; signature transaction created; audit event logged; evidence link created.
- **Role**: BIA Owner → BCM Manager.
- **Pass/fail**: status APPROVED + signed evidence visible.

TC-BCP-001 — Build, peer-review, approve BCP

- **Scenario**: New BCP for a critical service.
- **Preconditions**: BIA APPROVED.
- **Steps**: draft BCP → peer review → BCM approves → publish ACTIVE.
- **Expected**: BCP ACTIVE; PDF generated; linked to evidence.

TC-DRP-001 — DR plan creation, approval, test

- **Scenario**: New DR plan, test it, record outcome.
- **Steps**: create DR plan → review → approve → run test action `recordTest(outcome=PASS_WITH_OBSERVATIONS)`.
- **Expected**: DR plan ACTIVATED; test outcome captured; next-test-due set.

TC-VENDOR-RISK-001 — Vendor onboarding risk assessment

- **Scenario**: New vendor risk assessment.
- **Steps**: create vendor → trigger KYC → run risk assessment → score HIGH → approve.
- **Expected**: vendor ACTIVE with risk HIGH; reassessment due 12 months.

TC-SUPP-INC-001 — Supplier incident escalation

- **Scenario**: Vendor reports incident.
- **Steps**: log incident → assess impact → if critical-service affected, invoke BCP.
- **Expected**: incident logged; if BCP invoked, crisis-management notified.

TC-ERM-RA-001 — ERM risk assessment

- **Scenario**: Identify and assess a new risk.
- **Steps**: add new risk → assess L×I → calculate inherent + residual → approve.
- **Expected**: risk status ASSESSED → APPROVED.

TC-ERM-ACC-001 — Risk acceptance above appetite

- **Scenario**: Risk residual > appetite; formal acceptance.
- **Steps**: open above-appetite risk → request acceptance → CRO signs → ACTIVE.
- **Expected**: acceptance status ACTIVE; digital signature transaction recorded; expiry 12m.

TC-NCA-CTRL-001 — NCA control assessment

- **Scenario**: Annual ECC control assessment.
- **Steps**: open control → score implementation → upload evidence → approve.
- **Expected**: control implementation status updated; evidence linked; CISO sign-off.

TC-NCA-EVID-EXP-001 — NCA evidence expiry

- **Scenario**: Evidence approaching expiry triggers notification.
- **Preconditions**: NCA control evidence with expiry 30d out.
- **Steps**: wait for scheduled job (or trigger manually).
- **Expected**: evidence flagged EXPIRING_SOON; both owners notified; renewal CAPA created if not actioned by expiry.

TC-CYBER-BREACH-001 — Cyber incident to PDPL breach

- **Scenario**: Cyber incident impacts PII.
- **Steps**: open cyber incident → mark impacted-assets with `pii=true` → transition to ANALYSIS.
- **Expected**: `CyberPdplBridgeService` auto-creates DataBreach record; 72h timer started; DPO + CISO notified; bridge-log row written.

TC-PIA-001 — New high-risk PIA

- **Scenario**: New high-risk processing activity.
- **Steps**: create PIA → run risk assessment → DPO + CISO sign → APPROVED.
- **Expected**: PIA APPROVED with signatures; linked to ROPA.

TC-DSR-001 — Data subject request fulfilment

- **Scenario**: Subject submits DSR.
- **Steps**: receive request via portal → triage → fulfil within 30d → respond with sign.
- **Expected**: DSR FULFILLED before day-30 SLA; response signed by DPO; audit logged.

TC-CBT-001 — Cross-border transfer approval

- **Scenario**: Request CBT to USA via SCC.
- **Steps**: request → DPO assesses → approve.
- **Expected**: CBT APPROVED; expiry set; ROPA linked.

TC-BREACH-001 — Personal data breach 72-hour notification

- **Scenario**: Breach detected.
- **Steps**: detect → contain → assess → notify SDAIA within 72h → close.
- **Expected**: breach NOTIFIED within 72h; SDAIA notification reference recorded; DPO signature on notification.

TC-SIG-001 — Digital signature approval

- **Scenario**: User signs a policy.
- **Steps**: signature transaction REQUESTED → user opens inbox → reviews → signs.
- **Expected**: SIGNED status; SHA-256 hash bound to payload; certificate-reference stored.

TC-BOARD-001 — Board report generation

- **Scenario**: Quarterly board pack.
- **Steps**: Board Secretary opens Board Pack → generate PDF → Chairman reviews → Chairman signs → distribute.
- **Expected**: PDF generated; signature transaction SIGNED; distribution event fired to board members.

TC-EVID-PKG-001 — Regulatory evidence package generation

- **Scenario**: NCA requests evidence pack.
- **Steps**: open NCA filing → click "Export evidence package" → ZIP generated.
- **Expected**: ZIP containing per-control evidence + chain verification report + signed cover.

TC-FOURTHP-CONC-001 — Fourth-party concentration triggers CAPA

- **Scenario**: A fourth party appears behind ≥3 primaries.
- **Steps**: create 3 fourth-party rows for the same `fourthPartyName` → observe concentration recompute.
- **Expected**: concentrationRisk auto-elevates to HIGH; automation service auto-opens a CAPA; CAPA visible in `/capa` with `originType=fourth_party_exposure`, severity HIGH, target +30d.

TC-PROC-FAIL-001 — Failed processor assessment opens CAPA

- **Scenario**: Score a processor assessment with one control = FAIL.
- **Steps**: open IN_PROGRESS assessment → submit score with c4 FAIL → watch outcome derive to FAIL → COMPLETED.
- **Expected**: overall outcome FAIL; automation service auto-opens CAPA; CAPA severity CRITICAL.

TC-SRT-FAIL-001 — Failed resilience test opens CAPA

- **Scenario**: Complete a resilience test with FAIL outcome.
- **Steps**: start scheduled test → complete with `outcome=FAIL`, observations + action items.
- **Expected**: test COMPLETED with FAIL; automation service auto-opens CAPA `originType=supplier_resilience_test`, severity HIGH, target +60d.

TC-EVCHAIN-001 — Evidence chain verification

- **Scenario**: Verify SHA-256 chain.
- **Steps**: open evidence item → click Verify chain.
- **Expected**: chain status flips UNVERIFIED → VALID; report shows per- version hash trail; broken chain (if any) flagged.

Cross-cutting checks (every workflow)

- Tenant isolation: a user from org A cannot see org B records.

- Bilingual: every screen + every report renders cleanly in both AR (RTL) and EN (LTR).
- Audit log: every transition writes an `audit.events` row.
- Realtime: a list page open in one browser refreshes when another browser changes a record.
- Soft-delete: a "deleted" record disappears from all reads.
- API contracts: every endpoint matches OpenAPI spec.

Saudi GRC Platform

Sample Seed Data

Source: `sample-seed-data.md`

16 — Sample Seed Data

Demo seed data for every required scenario. Implemented as Flyway migrations (V2 … V54) plus Python bootstrap scripts. Everything below is realistic for a Saudi-headquartered listed entity but contains no real confidential information.

Seed sources

Migration	Scope
V2__core_seed.sql	Roles + first organisation + default users (admin, riskmanager, auditor)
setup_cyber_db.py	Cyber schema + 41 seed rows (dev only)
setup_bcm_db.py	BCM schema + seed (dev only)
V_seed_* migrations	Saudi-native risk taxonomy, sample evidence, sample policies
V30__digital_signatures.sql	11 signature transactions (inbox + history)
V31__root_cause_analyses.sql	7 RCA records linked to incidents
V32__pdpl_extensions.sql	Cross-border, disposal, notices schemas + first seeds
V33-V34__demo_seed_for_new_modules.sql	Top-up rows so every status tab has at least one record
V35__risk_scenarios.sql	11 risk scenarios (MC + stress + what-if)
V36__supplier_resilience.sql	10 alternates + 7 exit plans
V37__nca_framework_seeds.sql	8 cyber frameworks (NCA + SAMA + ISO + PCI)
V38__top_up_seed_gaps_3_4_5.sql	Status-tab top-up rows
V39__emerging_risks.sql	10 horizon-scan signals
V40__committee_workflows.sql	5 committees + 8 meetings
V41__disaster_recovery_plans.sql	8 DR plans
V42__nca_cscc_control_seed.sql	32 CSCC controls
V43__nca_ccc_control_seed.sql	30 CCC controls
V44__nca_otcc_control_seed.sql	27 OTCC controls
V45__contract_clause_library.sql	22 contract clauses across 9 categories
V46__cyber_pdpl_breach_bridge.sql	Cross-link columns + bridge log table
V46a__cyber_pdpl_bridge_seed_fix.sql	5 bridge events (CREATED + SKIPPED)
V47__evidence_chain_of_custody.sql	SHA-256 chain hashing on every evidence version
V47a__evidence_chain_broken_demo.sql	Inject a broken chain so the BROKEN filter shows ≥1
V48__align_ropa_codes_to_demo_register.sql	Align ROPA-2026-NNN → ROPA-NNN
V49__seed_empty_framework_and_demo_tabs.sql	8 SAMA + 8 ISO 22301 + 8 PCI DSS + Linked bridge + Unverified chain
V50__fourth_party_exposure.sql	7 fourth-party edges including HIGH-concentration
V51__data_sharing_agreements.sql	8 DSAs (SIMAH, Yakeen, group HR, NCA, HubSpot, KFUPM, MoCI, group cyber)

Migration	Scope
V52__processor_due_diligence.sql	8 PDPL Art. 28 assessments (incl. 1 FAILED, 1 IN_PROGRESS)
V53__third_party_cyber_risk.sql	8 TPRM cyber assessments (STC, AWS, OpenAI, TCS, HubSpot, Sentry, legacy, Stripe)
V54__supplier_resilience_tests.sql	8 resilience tests (incl. 1 FAILED OpenAI, 1 CANCELLED, 2 SCHEDULED)
fix_arabic_mojibake.py	Repairs any UTF-8/CP1252 mojibake from prior imports

Sample organisations

- **Saudi government entity**: "Authority for Statistics" (variant)
- **Financial institution**: a Saudi commercial bank with SAMA Cyber + ECC + outsourcing scope
- **Vision-2030 listed firm**: a TASI-listed industrial company

Sample critical service

- "Customer onboarding & KYC" — ROPA-001
- "Payment processing" — ROPA-003
- "Employee payroll (WPS)" — ROPA-005

Sample digital government service

- "Yakeen identity verification" via Elm Tabadul (DSA-2026-002).

Sample cloud service

- Workday HCM on AWS Ireland (Workday with AWS as fourth-party).
- AWS eu-west-1 hosting analytics (concentration risk).

Sample critical supplier

- Solutions by STC (managed-cloud, sector CRITICAL)
- AWS (CRITICAL)
- Workday (CRITICAL — HR + payroll)

Sample cybersecurity supplier

- Solutions by STC (managed services), Help AG (SOC), DXC (SOC), Mobily (alternate cloud).

Sample personal-data processing activity

- ROPA-001 Customer onboarding & KYC (legal obligation, identity, contact, financial)
- ROPA-004 Marketing communications (consent-based)
- ROPA-007 Job applicant screening (consent-based, cross-border).

Sample high-risk PIA

- ROPA-004 marketing analytics: consent + cross-border + behavioural data.

Sample NCA assessment

- Per-organisation ECC self-assessment (V42 + V43 + V44 + V49 seeded controls + V37 framework rows).

Sample BIA

- BIA for "Customer onboarding & KYC" with MTPD 24h, RTO 4h, RPO 1h.

Sample BCP

- BCP for the same service with comms tree + alternate site + named team.

Sample DRP

- 8 DR plans in `bcm.dr_plans` (V41) covering SQL Server primary, Workday connector, Elm Tabadul connector, payment gateway, etc.

Sample cyber incident

- INC-2026-0021 phishing email (single user clicked); resolved.
- INC-2026-001 broader phishing campaign (3 users entered creds).

Sample personal-data breach

- Generated automatically by the cyber→PDPL bridge from one of the cyber incidents above.

Sample supplier disruption

- "OpenAI API outage joint crisis sim" — SRT-2026-006 FAILED in V54.

Sample enterprise risk

- RSK-2026-001 above-appetite Aramco contract migration risk.
- RSK-2026-004 18-month exposure above amber appetite (linked to acceptance with CRO signature).

Sample corrective action

- Auto-generated CAPAs from FAILED processor assessment, HIGH fourth-party concentration, and FAILED resilience test.

Sample evidence records

- 58 evidence items in `evidence.evidence_items` with SHA-256 chain hashes.
- 1 broken chain demo (V47a).
- 1 unverified chain demo (V49).

Sample board dashboard data

- All KPIs on `/dashboard` are real (live from the seeded data); board pack PDF generates with real risk + compliance + DR figures.

Re-seeding a fresh dev DB

```
# 1. Drop + recreate DB
sqlcmd -S localhost -U sa -P "tss.123" \
-Q "IF DB_ID('TSS_GRC') IS NOT NULL DROP DATABASE TSS_GRC; CREATE DATABASE TSS_GRC COLLATE Latin1_General_100_CI_AS_SC_UTF8;"

# 2. Apply Flyway migrations (V1..V54) — easiest path via Spring Boot dev
mvn spring-boot:run -Dspring-boot.run.profiles=dev
# or via the Spring Boot Maven Plugin's spring-boot.run.arguments

# 3. Top-up Python scripts (dev only)
python setup_cyber_db.py
python setup_bcm_db.py
python fix_arabic_db.py

# 4. Repair any imported mojibake
python fix_arabic_mojibake.py
```

Total seeded rows across the platform at HEAD: **~3,500** across 80+ tables.

Saudi GRC Platform

Ai Features

Source: `ai-features.md`

16 — AI-Assisted Features

Fifteen LLM-assisted capabilities for the TSS GRC platform. Each is built as an opt-in feature behind a "Suggest with AI" button — never as a silent automation. Every output is treated as a *draft* and routed through the existing approval workflow.

Cross-cutting design principles (apply to every feature):

Principle	Enforcement
Human-in-the-loop	Every AI output is editable + requires a human reviewer to save / approve
Provenance	Each AI-generated field stamped with model name + version + prompt-id + invocation timestamp in ai.invocations (audit log)
Confidence + grounding	Outputs include cited sources (regulatory clauses, prior records, evidence ids) and a confidence score
Bilingual	Prompt scaffolding accepts EN or AR; outputs match the user's lang setting
Data privacy	Personal data is masked before sending to the LLM; PDPL transfer log written if cross-border
Tenant scope	The retrieval layer filters every prompt context to organisationId so cross-tenant leakage is impossible
Provider portability	One AiProvider interface; Saudi-region providers preferred (e.g. STC AI, Azure UAE/KSA region OpenAI)
Off-switch	Tenant admin can toggle the entire AI suite or per-feature

---

17.1 Risk description generation

Attribute	Value
Feature name	Risk-description copilot
User problem	Risk owners write descriptions inconsistently; some are one line, others verbose. Auditors mark this as a control weakness during NCA / ISO 31000 assessment
Required input	Risk title, category, related asset/process, identified-by source (audit finding / KRI / incident), prior similar risks from the org's register, regulator hints (e.g. NCA ECC domain)
AI output	Two paragraphs — (1) plain-language description with named threat + vulnerability + exposed asset, (2) "current control posture" pointing to controls already linked to the asset
Human review	Required. Editable; Risk Owner approves before saving
Approval requirement	At RISK_ASSESSED transition (Risk Manager)
Hallucination risk	Medium — model may invent regulator clauses or controls. Mitigated by retrieval grounding
Guardrails	(a) Output limited to ≤ 1,800 chars; (b) inline citations to retrieved sources required; (c) refuses if input contains real personal-data values; (d) blocked terms list (no "we" / "your organisation" — third-person factual only)

Attribute	Value
Audit log	ai.invocations row with prompt hash, output hash, reviewer userId, accept/reject, time
Privacy	No PII forwarded — input is structured metadata only. Free-text risk title is screened for pii_detector before send.

17.2 Risk cause and consequence suggestions

Attribute	Value
Feature name	Cause-and-consequence advisor
User problem	Cause / consequence sections of risk records are often left blank; root-cause work happens too late, after incidents
Input	Risk record + linked control set + recent incidents touching the same assets + sector-typical scenarios
Output	(1) Ranked list of plausible causes with weights; (2) consequence chain mapping to financial / regulatory / reputational / operational dimensions matching the BIA scoring scheme
Human review	Required — Risk Owner ticks the rows to keep
Approval	Persists with the risk; appears in board pack only after Risk Mgr sign-off
Hallucination risk	Medium — fabrication of incidents. Mitigated by grounding strictly on the org's own incident register
Guardrails	(a) Each suggestion must cite at least one source record id; (b) refuses to invent regulator deadlines; (c) bilingual output guarded against MT artifacts
Audit log	Same as 17.1
Privacy	Tenant-scoped retrieval; never reads other tenants' incidents

17.3 BIA impact recommendation

Attribute	Value
Feature name	BIA impact coach
User problem	Business Owners over- or under-rate impact dimensions inconsistently across services, weakening the BIA-driven prioritisation
Input	Service description, revenue dependency, customer-facing flag, regulatory drivers, peer-service ratings, historical incident downtime
Output	Suggested scores per impact dimension (financial / regulatory / reputational / operational) with a one-sentence rationale per dimension
Human review	Required — BIA Owner approves each dimension; original Service Owner must counter-sign
Approval	BIA Manager at IN_REVIEW → APPROVED
Hallucination risk	Low (scores are bounded 1-5) but rationale text can drift

Attribute	Value
Guardrails	(a) Numeric output must lie within configured min/max per dimension; (b) refuses if BIA already APPROVED (avoid silent re-scoring); (c) rationale capped 200 chars per dimension
Audit log	Stored alongside the BIA versioned record
Privacy	Aggregated metrics only; no individual customer data

17.4 RTO / RPO recommendation

Attribute	Value
Feature name	RTO-RPO advisor
User problem	RTO/RPO are often set by tradition rather than evidence; this creates BIA / DRP gaps
Input	Service criticality, MTPD, downstream-service map, current architecture (HA vs single-instance), regulator floor (e.g. SAMA outsourcing rules), peer benchmark band
Output	(1) Recommended RTO (hours) + RPO (hours) with rationale; (2) gap statement vs current DrPlan.rto_actual/rpo_actual; (3) suggested treatment if gap > 0
Human review	Required — DR Owner + BCM Manager both review
Approval	BCM Manager at BIA APPROVED
Hallucination risk	Low for numeric output, medium for the treatment narrative
Guardrails	(a) Numeric output must be a positive integer ≤ MTPD; (b) regulator-floor check before showing — never recommend below the floor; (c) rationale must cite retrieved source ids
Audit log	Yes; also stamps bcm.bia_records.ai_suggested_rto so reviewers can see drift over time
Privacy	No PII

17.5 Supplier risk-scoring suggestions

Attribute	Value
Feature name	Vendor-risk scoring copilot
User problem	Vendor risk-rating is heterogeneous across teams; some assessors are stricter than others, eroding comparability
Input	Vendor metadata (sector, country, criticality, services), latest TPRM cyber assessment, recent supplier incidents, fourth-party concentration, sanctions hit (SIMAH/Dow Jones)
Output	Suggested overall rating (LOW/MEDIUM/HIGH/CRITICAL) with weighted contributors visualised + 1-paragraph narrative
Human review	Required — Vendor Risk Manager
Approval	Mandatory before propagating into the TPRM cyber assessment auto-CAPA trigger
Hallucination risk	Low — output bounded enum

Attribute	Value
Guardrails	(a) Output is enum-bound; (b) narrative must cite contributor breakdown numerically; (c) refuses to upgrade above CRITICAL or downgrade below LOW
Audit log	Yes; tprm.cyber_assessments.ai_suggested_residual stamped
Privacy	Vendor PII screened before send; only structured metadata

17.6 PDPL PIA gap suggestions

Attribute	Value
Feature name	PIA gap finder
User problem	DPOs miss specific PDPL articles (Art. 25 PIA triggers, Art. 26 consultation rules) when assessing new processing activities
Input	Processing activity (ROPA row) + selected lawful basis + data categories + cross-border flag + linked processors
Output	Per-PDPL-article checklist with status (likely-MET / likely-GAP / needs-evidence) + suggested remediation step
Human review	Required — DPO
Approval	DPO at PIA APPROVED
Hallucination risk	Medium — model may misclassify lawful basis. Mitigated by retrieving the PDPL article text from compliance.requirements at prompt time
Guardrails	(a) Each gap must cite a PDPL article id; (b) only suggests articles already loaded in the platform's regulatory library — no inventing; (c) refuses to assert "compliant" — only "likely met pending evidence"
Audit log	Yes; suggested gaps that the DPO accepts spawn CAPA tasks with originType=pia_gap
Privacy	Processing-activity metadata only; no real subject data

17.7 NCA compliance gap analysis

Attribute	Value
Feature name	NCA gap analyser
User problem	Annual NCA self-assessment is a manual exercise per control; CISOs need a first-pass gap analysis to focus reviewer time
Input	Cyber control library (the 145 seeded controls + sub-controls), per-control evidence linkage, recent assessment notes, framework version
Output	Per-control predicted implementation status (IMPLEMENTED / PARTIAL / PLANNED / NOT_IMPLEMENTED / NOT_APPLICABLE) + per-control evidence-gap explanation + a domain-level maturity-tier projection

Attribute	Value
Human review	Required for every control before filing; CISO sign-off
Approval	CISO at NCA filing SUBMITTED
Hallucination risk	High — easy to invent compliance. Mitigated by requiring at least one linked evidence id per "IMPLEMENTED" suggestion
Guardrails	(a) Refuses to mark "IMPLEMENTED" without ≥ 1 linked evidence; (b) blocks output that contradicts a recent assessor note flagged as authoritative; (c) regulator-citation required per control
Audit log	Full; the filing PDF lists each AI-suggested control vs CISO-accepted control
Privacy	No PII

17.8 Evidence quality review

Attribute	Value
Feature name	Evidence reviewer
User problem	Auditors find evidence packs are stale, unsigned, or missing scope context
Input	Evidence item + version + its chain-of-custody status + linked controls + the requirement text it should support
Output	(1) Quality score (0-5), (2) per-defect list (date stale, no signature, scope mismatch, etc.), (3) suggested remediation
Human review	Required — Evidence Owner
Approval	At evidence APPROVE transition
Hallucination risk	Low for score, medium for defect narrative
Guardrails	(a) Score bounded 0-5; (b) does not download or parse the actual file unless tenant has explicitly enabled file-content review (off by default for sensitive evidence); (c) only references defects against the linked control's stated requirement
Audit log	Per-version, including the prompt and the auto-checks (date, sig, hash chain) it performed deterministically before invoking the LLM
Privacy	Optional file-content review respects evidence ACL; staff under the tenant's EVIDENCE_READ_RESTRICTED role can be excluded

17.9 Corrective action recommendation

Attribute	Value
Feature name	CAPA advisor
User problem	CAPA owners draft thin action statements; the system can't track meaningful progress against vague language

Attribute	Value
Input	Source record (incident / audit finding / KRI breach / failed assessment) + similar past CAPAs (closed, resolved) + the linked control
Output	SMART action statement (Specific, Measurable, Achievable, Relevant, Time-bound) + target date + suggested owner role
Human review	Required — CAPA Owner
Approval	At CAPA create + at AWAITING_VERIFICATION
Hallucination risk	Medium
Guardrails	(a) Target date inside policy window per severity (e.g. CRITICAL ≤ 45d); (b) owner suggestion is a role, not a named user (avoid name fabrication); (c) refuses if source record is in a state that doesn't allow CAPA creation
Audit log	Yes
Privacy	No PII

17.10 Executive report drafting

Attribute	Value
Feature name	Executive narrative writer
User problem	Exec teams need a clean 1-page narrative on top of the dashboard numbers; analysts spend hours writing it
Input	Selected dashboard KPIs, current quarter risk trends, top-5 movers, regulator-deadline calendar
Output	One-page narrative (≤ 600 words) with sections: headline, top risks, compliance posture, BCM readiness, supplier resilience, ask-of-the-exec
Human review	Required — Compliance Officer / Risk Mgr
Approval	Before any distribution beyond owner
Hallucination risk	High — risk of stating outcomes not in the data
Guardrails	(a) Output must include numeric figures only from the supplied KPI set; (b) "ask-of-the-exec" section requires referencing a real open CAPA or above-appetite risk; (c) no projection beyond next quarter
Audit log	Yes; the published version is signed by reviewer + content-hashed
Privacy	Tenant-scoped, no PII

17.11 Board summary drafting

Attribute	Value
Feature name	Board-pack narrative writer
User problem	Same as 17.10 but for the Board: governance language, less detail, more decisions-to-take

Attribute	Value
Input	Board pack draft (numeric sections) + previous quarter's signed pack
Output	Three sections: (1) "Decisions taken since last meeting", (2) "Material risks + acceptance candidates", (3) "Items for board decision"
Human review	Required — Board Secretary + CRO
Approval	Chairman digital signature before distribution
Hallucination risk	High (board-level statements)
Guardrails	(a) Outputs only when the underlying KPIs are signed off; (b) explicit refusal of any forward-looking statement that isn't already in an approved plan; (c) board-tone enforced via prompt + reviewer check
Audit log	Yes; included in the signed board pack
Privacy	No PII; cross-border AI calls disabled if the tenant is in SENSITIVE mode

17.12 Regulatory change impact analysis

Attribute	Value
Feature name	Reg-change impact analyser
User problem	NCA / SDAIA / SAMA / CMA push out reg updates; compliance teams take weeks to map them
Input	The reg-change text (ingested via RegulatoryChange module) + the platform's current control + policy library
Output	(1) Affected requirements list, (2) per-requirement implementation gap, (3) suggested CAPA themes
Human review	Required — Compliance Officer
Approval	Before any auto-CAPA generation
Hallucination risk	High
Guardrails	(a) Only references requirements already in compliance.requirements; (b) refuses to map to specific control IDs unless a textual match score > threshold; (c) all CAPA themes routed to draft, never auto-created
Audit log	Yes
Privacy	No PII

17.13 Incident root-cause draft

Attribute	Value
Feature name	RCA draft assistant
User problem	RCAs are time-consuming; the 5-Whys / Fishbone / Pareto methodology is well-defined but tedious
Input	Incident timeline entries, impacted assets, contributing factors free-text, linked vulnerabilities

Attribute	Value
Output	Methodology-specific draft (5-Whys chain / Fishbone branches / Pareto top-3) + root-cause statement + recommendations list
Human review	Required — RCA Facilitator
Approval	RCA APPROVED workflow gate
Hallucination risk	Medium
Guardrails	(a) Each "why" must cite a timeline-event id; (b) no hindsight bias — output must answer "what was knowable when?"; (c) recommendations always require a target date placeholder
Audit log	Yes
Privacy	Incident-touching subject data masked before send

17.14 Lessons-learned extraction

Attribute	Value
Feature name	Lessons distiller
User problem	After-action reports are written but rarely re-used; lessons stay locked in PDFs
Input	Approved RCAs + exercise after-action reports + closed CAPAs from the last 24 months
Output	Themed lessons-library (e.g. "Phishing — top 3 recurring causes") with citations back to source records
Human review	Required — Risk Mgr + BCM Mgr
Approval	Before publication to Knowledge Base
Hallucination risk	Medium
Guardrails	(a) Each lesson must cite ≥ 2 source records; (b) refuses to publish a lesson contradicted by an unresolved exception; (c) freshness — lessons referencing > 24-month-old records are flagged for re-validation
Audit log	Yes; lessons get a content hash so the source-record link is tamper-evident
Privacy	Subject identifiers redacted in published lessons

17.15 Control mapping suggestions

Attribute	Value
Feature name	Control-mapping copilot
User problem	When a new framework (e.g. SAMA Cyber update) is imported, mapping its controls to existing ones is slow + error-prone
Input	Imported framework's controls (text) + the platform's existing control library

Attribute	Value
Output	Per-imported-control: top-3 candidate mappings with similarity score + rationale + suggested action (NEW / REUSE / VARIANT)
Human review	Required — Control Owner
Approval	Compliance Officer at framework-activation
Hallucination risk	Low-medium (score-grounded)
Guardrails	(a) Similarity score must exceed threshold; (b) refuses to mark as REUSE if the candidate is currently in DEPRECATED state; (c) ≤ 3 candidates per source, never more
Audit log	Yes
Privacy	No PII

AI invocation table (cross-cutting persistence)

Every invocation persists a row to `ai.invocations`:

Column	Meaning
id	PK
organisation_id	tenant scope
feature_code	e.g. risk_description, pia_gap_finder
provider	OPENAI_KSA / STC_AI / AZURE_UAE_NORTH etc.
model	gpt-4-turbo etc.
prompt_hash	sha256 of full prompt
output_hash	sha256 of returned output
input_token_count	for cost tracking
output_token_count	for cost tracking
latency_ms	observed latency
cost_sar	computed
entity_type + entity_id	what the output was attached to
reviewer_user_id	who accepted/rejected
decision	ACCEPTED / EDITED / REJECTED
accepted_at	timestamp
created_at	invocation time

The `ai.invocations` table is included in the data-model spec (output 4) and gets the standard `BaseEntity` audit columns. Auditors can read this table; tenant admins can purge older than retention (default 36 months).

Provider abstraction

Java interface (suggested addition to backend):

```
public interface AiProvider {
AiResponse complete(AiPrompt prompt);
boolean supportsRegion(String region); // e.g. SA, AE, EU
String modelName();
String providerName();
}
```

Implementations: `OpenAiKsaProvider`, `StcAiProvider`, `AzureUaeNorthProvider`, `OfflineProvider` (returns a deterministic stub for dev / tests). Selection driven by per-tenant config `ai.provider.preferred`.

Privacy gating

Two layers before every send:

1. **PII detector** (`PiiDetector`) — uses regex + ML model offline to classify Saudi National-ID, IBAN, MOI passport, mobile, etc. If any are present, the call is blocked or the values are masked with a reversible per-tenant token.
2. **Cross-border transfer log** — if the chosen provider is hosted outside KSA and the tenant's data-residency policy is `KSA_ONLY`, the call is blocked. Otherwise a row is written to `privacy.cross_border_transfers` with `mechanism=AI_INVOCATION`.

Off-switch

`SettingsPage` → AI tab exposes: - Master toggle (per tenant). - Per-feature toggles (15 switches). - Provider override. - Per-feature daily-call cap. - Per-feature daily-cost cap. - "Send debug invocations to provider X" toggle for tenant security team.

When the master toggle is off, the "Suggest with AI" buttons render as disabled with a hover tooltip "AI features disabled by your tenant administrator".

Saudi GRC Platform

Frontend Requirements

Source: `frontend-requirements.md`

17 — Frontend Implementation Requirements

Spec-level breakdown of the platform's UI so a frontend team can rebuild or extend it. Anchored to the actual React + Vite + TypeScript codebase at `tss-grc-ui-v2/src/`.

Sister docs: - `/05-UI-Screens/` — per-screen list + purpose - `/08-RBAC/` — RBAC matrix (what each role sees) - `/03-Workflow-Catalogue/workflow-lifecycles.md` — state machines

---

1. Navigation menu

Sidebar (left in LTR, right in RTL). 11 groups, max 10 items each (ServiceNow IRM / OneTrust pattern; see `Sidebar.tsx`).

Group	Items
My Work	Dashboard, Lifecycle Overview, Intake Inbox, Approvals, Digital Signatures, Notification Outbox
Risk Management	Enterprise Risk, Risk Lifecycle, Scenario Analysis, Emerging Risks, Incident Response, Root Cause Analysis, Change Management
Compliance & Policy	Compliance, Framework Packs, Policy Templates, Regulatory Feed, Control Crosswalks, Evidence, Attestation Campaigns, Ethics & Compliance, ESG
Audit	Audit Workspace, Audit Lifecycle, Evidence Chain, NCA ECC Export
Privacy	PDPL, Privacy Lifecycle, ROPA, Data Lifecycle, Cyber → PDPL Bridge, Data Sharing, Processor Due Diligence
Cybersecurity	Cybersecurity, Cyber Lifecycle, Framework Controls, Asset Register
Business Continuity	Business Continuity, BCM Lifecycle, Dependency Map, DR Plans, Crisis Management
Third-Party Risk	Third-Party Risk, Vendor Portal, Supply Chain Risk, Supplier Resilience, Contract Clauses, Fourth-party Exposure, Third-party Cyber Risk, Resilience Tests
Saudi Regulators	Regulatory Authorities, HRSD (Labor / GOSI / Nitaqat), MOC (Tasattur / Consumer / CR)
Service Catalog & Knowledge	Services Center, CAPA, Board Pack, Knowledge Base, Communications, Scheduled Reports
Administration	Users & Access, Committees & Meetings, SSO / Nafath, Workflow Versions, Connectors, Notifications, Notification Channels, File Upload, Onboarding, Settings, About

Topbar: organisation switcher, search (Cmd+K palette), language toggle (■■■■■ ↔ English), theme toggle, user menu.

Mobile (≤ 768px): sidebar collapses to a hamburger drawer.

2. Page list

The 80+ React pages live under `src/pages/{slug}/`. Top-level routes configured in `App.tsx`. Categories:

- **Modules** (one per backend module): risk, bcm, scm, tprm, cyber, privacy, compliance, evidence, incident, signature, workflow, reporting, dashboard.
- **Detail pages** (drill-in): RiskDetailPage, VendorDetailPage, ControlDetailPage, PolicyDetailPage, FindingDetailPage, DpiaDetailPage, EngagementDetailPage.
- **Lifecycle pipelines** (visual workflow stage view per module): risk-lifecycle, bcm-lifecycle, audit-lifecycle, cyber-lifecycle, privacy-lifecycle.
- **Portals** (external-facing): DsrPortalPage, VendorPortalPage, SpeakUpPortalPage, CaseTrackerPage, TrustCenterPage.
- **Lifecycle / cross-cutting**: lifecycle-overview, intake-inbox, approvals, signatures, notification-outbox, dashboard.
- **Cross-module hubs**: board-pack, communications, regulatory-change, control-crosswalk, bcm-dependency.
- **Admin**: admin, committees, workflows, workflow-versions, sso, mfa, white-label, settings, onboarding.

3. Component library

Under `src/components/`:

Category	Components
Layout	Shell, PageHeader, Sidebar, Topbar, Breadcrumb, DetailHeader, DetailLayout, DetailRail, OverviewStrip, PublicShell
UI primitives	Card, Kpi, Badge, Button, Tabs, Input, Select, ColorField, RangeField, Progress, Modal, ConfirmDialog, EmptyState, Stepper, Timeline, HijriDate, FilterModal, FormModal, LivePulse, BulkActionsBar, RowActions, RecordPicker, UserPicker, SavedViewSelector, LinkedChangesPanel, FileUploadField, ExportMenu
Data	DataTable, DataTableV2 (paginated, sortable, virtualised), useDataTable
Filter	FilterBuilder + useFilterState + operators
Viz	HeatMap (5×5), BarChart3D, Donut, CoverageMatrix, TimeSeries, LineChart, BarChart, PieChart
Workflows	WorkflowDesigner, ProcessDetailModal, ProcessLifecycleBar, ChainCatalog, ActiveWorkflowsPanel, LiveSlaPulse, SlaCountdown
Lifecycle	LifecyclePipeline, ActivityFeedDrawer
Comms	CommsPanel, AcknowledgeModal, ComposeModal, NewCommunicationModal
TPRM	TprmConsolidatedOverview, TprmOnboardingPipeline, TprmReassessmentDashboard
Compliance	CcmDashboard, PolicyLifecycleStrip, PolicyVersionHistory, NitaqatPanel, MocPanel, MocProcessInitiation, HrsdProcessInitiation
Risk	AppetiteBreachFeed, NewRiskModal
Privacy	PdplBreachConsole
Audit	EngagementMilestonePanel

Category	Components
Authority	RegulatorPostureCard, EntityAnchorsPanel, AnchorChips
Search	CommandPalette (Cmd+K)
RTL	DirectionalArrow
Intake	PromotedBadge, IntakeFormRenderer, ChangeRiskPanel

4. Table column patterns

Every list page uses the same shape:

Column type	Pattern
Code / ID	className="mono", fixed-width font, click navigates to detail
Title	bilingual switch via lang === 'ar' ? titleAr : titleEn
Status / lifecycle	
Severity / risk	colour-coded per tier
Numeric / score	mono, right-aligned
Date	mono ISO; tooltip with Hijri via
Owner	name + role badge
Actions	right-aligned, menu or inline
Expand chevron	left, 28px wide, toggles row-detail panel

5. Form fields

Built via with `FieldDef[]`:

Kind	Use
text	one-line strings (titles, codes, names)
textarea	multi-line (descriptions, justifications, rationale) — rows configurable
number	with min/max validation
date	YYYY-MM-DD; Hijri preview when AR
select	controlled options array

Spans (12-col grid): `3 | 4 | 6 | 8 | 12`. Modal renders responsive grid. Required fields prefixed with `*`. Validation surfaces inline + toasts on submit.

6. Buttons & actions

Variant	Use
primary	Save, Create, Approve, Sign
secondary	Filter, Export, Refresh
ghost	Cancel, Archive, secondary actions
danger	Reject, Delete, Terminate, Mark FAIL

All buttons render an optional leading icon via the `Icon` prop (Lucide). Size: `sm` / `md` / `lg`.

State-aware visibility: each row's action set is computed from current `status` against allowed transitions (state machine).

7. Filters

Per-page filters via with definitions (text, select, multiselect, date-range). Saved views via . Column-header filters via `DataTableV2` for quick narrow.

Free-text search: page-level + global Cmd+K (`CommandPalette`).

8. Modals

Modal	Trigger	Purpose
	"New X" button	Create / edit record
	Destructive actions	Confirm Delete / Reject / Cancel
	"Filter" button	Build a filter
	Communications	Outbound message
	Acknowledgement	Subject ack
	Workflow row click	Show workflow detail + actions

All modals are esc-dismissable, focus-trap, render in a portal, backdrop-blur. RTL flips margin-inline-start/end.

9. Wizard steps

Multi-step flows use + own state. Wizards in the platform: - **TprmOnboardingPipeline** (TPRM Onboarding tab) - **OnboardingPage** (tenant onboarding) - **HrsdProcessInitiation** + **MocProcessInitiation** (intake flows) - **NewCommunicationModal** (compose multi-step)

Step shape: title, sub, status (PENDING / ACTIVE / DONE / SKIPPED). Stepper supports both vertical (rail) and horizontal layouts.

10. Dashboard widgets

Widget engine in `src/pages/dashboard/widgets.tsx`. Each widget has: - `id` (stable) - `titleKey` (translation key) - `defaultSize` (`sm` / `md` / `lg`) - `isKpi` flag - `category` (`kpi` / `chart` / `list` / `progress`) - `render(ctx)` function

Layout is per-user, persisted in localStorage via `useDashboardLayout`. Customise mode: drag to reorder, X to remove, click to add from catalogue. Reset-to-default supported.

Default layout: Saudi posture → KPI strip (intakes / overdue / CAB / critical risks) → **TPRM snapshot** (new) → ERM KPIs → Heatmap → Risks by severity → Frameworks → Activity feed.

11. Empty states

component used wherever a list is empty. Props: `Icon`, `title`, `sub`. Each module supplies its own copy through translation keys (e.g. `risksEmpty`, `riskEmptyHint`).

Pattern: empty state explains *why* (no data, filtered out, demo mode) and points to the next action ("Click New to add a record").

12. Validation messages

Two layers: 1. **Client-side** via FormModal's per-field rules (`required`, `min`, `max`, `maxLength`, regex). 2. **Server-side** via Bean Validation; errors surface as toasts with the field name. `ApiError` from `lib/api.ts` carries the structured body for inline display.

Validation messages translated via `messages*.properties` (server) and `translations/{en,ar}.ts` (client).

13. Arabic / English labels

Every user-visible string declared in two parallel files: `src/translations/en.ts` + `src/translations/ar.ts`. Keys are flat strings, mirrored 1:1. `useI18n()` hook returns: - `t(key)` — string lookup with optional `{var}` substitution - `lang` — current `'en' | 'ar'` - `setLang` — toggle

Saudi-native Arabic preference encoded in `memory/feedback_saudi_native_arabic.md` — prefer business Arabic over literal MSA translations.

14. RTL behaviour

Rule	Enforcement
Root direction	when lang === 'ar'
Logical CSS	margin-inline-start, padding-inline-end, border-inline-start — never left/right
Icons that flip	Wrapped in (e.g. ChevronRight becomes ChevronLeft in RTL)
Numeric formatting	ISO digits by default; Arabic-Indic supported via user pref
Date	Gregorian + optional Hijri overlay via
Tables	Header cells right-aligned in RTL; numeric columns stay right-aligned (universal convention)
Charts	x-axis flipped where meaningful; legend mirrored

15. Role-based UI visibility

`lib/auth.ts → hasAnyRole(...roles)` helper. Patterns:

- **Whole-page guard**: route guard at App.tsx level (e.g. `/admin` only for `PLATFORM_ADMIN` + `GRC_ADMIN`).
- **Button-level guard**: `hasAnyRole('DPO') && …`.
- **Tab-level guard**: tab definition list filtered by role.
- **Field-level guard**: PII fields hidden / masked unless user has `PRIVACY_READ`.

Demo mode: anonymous users get a read-only sample tenant.

16. Workflow status badges

with these tone tokens (defined in `styles/tokens.css`):

Tone	Use
primary	Default / informational
success	APPROVED / VERIFIED / IMPLEMENTED / ACTIVE

Tone	Use
warning	DRAFT / IN_REVIEW / PARTIAL / PENDING
danger	REJECTED / FAILED / EXPIRED / OVERDUE
info	IN_PROGRESS / MITIGATED
accent	Highlight / new

Each module has a `STATUS_TONE` map in its lib file (e.g. `SCENARIO_STATUS_TONE`, `DSA_STATUS_TONE`, etc.).

17. Evidence upload components

+ lib `fileUpload.ts`: - Accept-list configurable per evidence type (pdf, docx, xlsx, pptx, csv, json, png, jpg, zip). - Max size 50 MB; chunked upload above 10 MB. - On upload: SHA-256 computed client-side; sent + server re-verifies + writes to chain. - Per-tenant ACL: hidden upload-button for roles without `EVIDENCE_WRITE`.

18. Approval and digital-signature components

Component	Use
	Approve action
	Reject action
Inline reject reason prompt	window.prompt(t('xxxRejectReasonPrompt'))
	Confirm destructive action
Signature inbox card (SignaturesPage)	Pending signature transactions; Sign / Reject actions per row
Signature transaction modal	Shows the document hash + provider + signer; click "Sign" calls signTransaction() with browser-computed SHA-256

Signature flow: 1. Module fires `POST /api/signature/transactions` to request. 2. Signer's inbox shows REQUESTED row. 3. Signer reviews payload → clicks Sign → client computes SHA-256 → POST `/sign` with hash + cert reference. 4. Status SIGNED, audit logged.

19. Report export components

standardises every list page's export:

```
reportingApi.xxxPdf(lang)}
onXlsx={() => reportingApi.xxxXlsx()}
/>
```

Plus the Dashboard `Board Pack PDF / PPTX` buttons. All exports route through `lib/reporting.ts` which calls the backend `/api/v1/reporting/*` endpoints. Bilingual output: pass `lang` query param.

Audit log: every export writes an `audit.events` row with verb `export`.

Saudi GRC Platform

Workbook Spec

Source: `workbook-spec.md`

18 — Excel Workbook Structure

Companion to the deliverable package: a single `.xlsx` workbook with 23 named sheets, each defining one table the implementation team can hand to BAs / config consultants / customer DBAs. The file lives at `./tss-grc-implementation-package.xlsx` in this folder.

Workbook conventions:

- Sheet name = concise English (≤ 31 chars per Excel limit).
- Row 1 = column headers (bold).
- Row 2 = the example row (italic, light-grey fill).
- Row 3 onwards = the seeded reference data.
- Data validation: dropdowns for enum columns; date format `YYYY-MM-DD`; numeric columns formatted with thousand separators.
- Mandatory columns marked with a `*` in the header.

Sheet 1 — Module Catalogue

Column	Type	Mand.	Dropdown / Validation	Example
Module Code	text	✓	—	RISK
Module Name EN	text	✓	—	Enterprise Risk Management
Module Name AR	text	—	—	■■■■■ ■■■■■■■■ ■■■■■■■■
Backend Package	text	✓	starts with module.	module.risk
Frontend Route Root	text	✓	—	/risk
Primary Persona	dropdown	✓	Risk Mgr / BCM Mgr / DPO / CISO / Compliance Officer / Supplier Mgr / Auditor	Risk Manager
Status	dropdown	✓	DONE / IN_PROGRESS / PLANNED	DONE
Sprint Origin	text	—	sprint-N	sprint-1
Key Frameworks	text	—	comma-separated	NCA ECC, SAMA, ISO 31000

Sheet 2 — Workflow Catalogue

Column	Type	Mand.	Validation	Example
Workflow Code	text	✓	unique	RISK_ACCEPTANCE
Workflow Name EN	text	✓	—	Risk acceptance above appetite

Column	Type	Mand.	Validation	Example
Workflow Name AR	text	✓	—	■■■■ ■■■■■■■ ■■■ ■■■■
Module Code	dropdown	✓	from Sheet 1	RISK
Trigger	text	✓	—	Residual > appetite ceiling
SLA (days)	number	—	≥ 0	14
Signature Required	dropdown	✓	YES / NO	YES
Status Lifecycle	text	✓	arrow-chained	REQUESTED → APPROVED → ACTIVE → EXPIRED
Primary Actor	text	✓	—	Risk Owner
Approver	text	✓	—	CRO
Evidence Required	text	—	comma-separated	Risk acceptance memo

Sheet 3 — Workflow Steps

Column	Type	Mand.	Validation	Example
Workflow Code	dropdown	✓	from Sheet 2	RISK_ACCEPTANCE
Step Order	number	✓	≥ 1	1
Step Name EN	text	✓	—	Submit acceptance request
Step Name AR	text	—	—	■■■■■ ■■■ ■■■■■■
Actor Role	text	✓	—	Risk Owner
Input	text	—	—	Justification + residual score
Output	text	—	—	REQUESTED status
Decision Point	dropdown	—	YES / NO	NO
SLA Hours	number	—	≥ 0	24

Sheet 4 — Role Matrix

Column	Type	Mand.	Validation	Example
Role Code	text	✓	unique	RISK_MGR
Role Name EN	text	✓	—	Risk Manager
Role Name AR	text	—	—	■■■■ ■■■■■■■
Module Code	dropdown	✓	from Sheet 1	RISK
View	dropdown	✓	ALL / OWN / NONE	ALL
Create	dropdown	✓	ALL / OWN / NONE	ALL
Edit	dropdown	✓	ALL / OWN / NONE	ALL

Column	Type	Mand.	Validation	Example
Approve	dropdown	✓	YES / NO	YES
Delete	dropdown	✓	ALL / OWN / NONE	OWN
Export	dropdown	✓	YES / NO	YES
Sign	dropdown	✓	YES / NO	YES
Report	dropdown	✓	YES / NO	YES

Sheet 5 — Approval Matrix

Column	Type	Mand.	Validation	Example
Workflow Code	dropdown	✓	from Sheet 2	RISK_ACCEPTANCE
Approval Level	number	✓	1..5	1
Approver Role	text	✓	—	CRO
Threshold Condition	text	—	—	Residual > appetite
Mandatory	dropdown	✓	YES / NO	YES
Signature Required	dropdown	✓	YES / NO	YES
SLA Hours	number	—	≥ 0	48

Sheet 6 — Data Objects

Column	Type	Mand.	Validation	Example
Object Code	text	✓	unique	Risk
Schema	text	✓	—	risk
Table Name	text	✓	—	risks
Module	dropdown	✓	from Sheet 1	RISK
Lifecycle	text	—	—	DRAFT → ASSESSED → APPROVED
Owner Field	text	—	—	risk_owner_user_id
Bilingual	dropdown	✓	YES / NO	YES
Description EN	text	✓	—	Enterprise-level risk record
Description AR	text	—	—	■■■ ■■■■■■■ ■■■ ■■■■■ ■■■■■■■

Sheet 7 — Entity Relationships

Column	Type	Mand.	Validation	Example
Parent Object	dropdown	✓	from Sheet 6	Risk
Child Object	dropdown	✓	from Sheet 6	RiskAssessment

Column	Type	Mand.	Validation	Example
Relationship Type	dropdown	✓	1:1 / 1:N / M:N	1:N
FK Column	text	✓	—	risk_id
Cascade Behaviour	dropdown	✓	CASCADE / SET_NULL / RESTRICT	RESTRICT
Bidirectional	dropdown	✓	YES / NO	YES

Sheet 8 — UI Screens

Column	Type	Mand.	Validation	Example
Screen Code	text	✓	unique	RISK_REGISTER
Page Path	text	✓	starts with /	/risk
Title EN	text	✓	—	Risk Register
Title AR	text	✓	—	■■■ ■■■■■■■
Layout	dropdown	✓	LIST / DETAIL / DASHBOARD / FORM / WIZARD / PORTAL	LIST
Module	dropdown	✓	from Sheet 1	RISK
Primary Persona	text	✓	—	Risk Manager
RTL Behaviour	text	—	—	Logical CSS; header right-align
Required Role	text	—	—	RISK_READ

Sheet 9 — UI Fields

Column	Type	Mand.	Validation	Example
Screen Code	dropdown	✓	from Sheet 8	RISK_REGISTER
Field Code	text	✓	—	riskCode
Field Type	dropdown	✓	text / textarea / number / date / select / multiselect / file / signature	text
Label EN	text	✓	—	Code
Label AR	text	✓	—	■■■■■
Required	dropdown	✓	YES / NO	YES
Validation	text	—	—	regex / min / max
Default Value	text	—	—	—
Help Text EN	text	—	—	Unique identifier

Sheet 10 — Evidence Library

Column	Type	Mand.	Validation	Example
Evidence Code	text	✓	unique	EV_BIA_REPORT
Name EN	text	✓	—	BIA Report
Name AR	text	—	—	■■■■■ ■■■■■ ■■■ ■■■■■■■
Owner Role	text	✓	—	BIA Owner
Frequency	dropdown	✓	DAILY / WEEKLY / MONTHLY / QUARTERLY / ANNUAL / PER_EVENT / ON_DEMAND	ANNUAL
File Types	text	✓	comma-separated	pdf, xlsx
Expiry Rule	text	✓	—	12 months
Approval Role	text	✓	—	BCM Manager
Module	dropdown	✓	from Sheet 1	BCM
Regulatory Source	text	✓	—	ISO 22301 §8.2.2
Signature Required	dropdown	✓	YES / NO	YES

Sheet 11 — Regulatory Mapping

Column	Type	Mand.	Validation	Example
Source	dropdown	✓	NCA / SAMA / SDAIA / DGA / NRC / ISO 22301 / ISO 27001 / ISO 31000 / ISO 27701 / PCI DSS	NCA
Domain	text	✓	—	ECC Governance
Control / Requirement ID	text	✓	unique within Source	ECC-1-1
Title EN	text	✓	—	Cybersecurity strategy
Title AR	text	—	—	■■■■■■■■■■ ■■■■■ ■■■■■■■■■■
Module	dropdown	✓	from Sheet 1	CYBER
Workflow Code	dropdown	—	from Sheet 2	NCA_SELF_ASSESSMENT
Evidence Code	dropdown	—	from Sheet 10	EV_STRATEGY_DOC
Responsible Role	text	✓	—	CISO
Status	dropdown	✓	NOT_APPLICABLE / NOT_IMPLEMENTED / PLANNED / PARTIAL / IMPLEMENTED / VERIFIED	IMPLEMENTED

Column	Type	Mand.	Validation	Example
Placeholder	dropdown	✓	YES / NO	NO

Sheet 12 — Controls Library

Column	Type	Mand.	Validation	Example
Control Code	text	✓	unique	ECC-1-1
Framework	dropdown	✓	NCA ECC / NCA CSCC / NCA CCC / NCA OTCC / SAMA / ISO 27001 / ISO 22301 / PCI DSS	NCA ECC
Domain	text	✓	—	Governance
Title EN	text	✓	—	Cybersecurity strategy
Title AR	text	—	—	■■■■■■■■■■ ■■■■■ ■■■■■■■■■
Type	dropdown	✓	PREVENTIVE / DETECTIVE / CORRECTIVE	PREVENTIVE
Review Frequency	dropdown	✓	ANNUAL / QUARTERLY / MONTHLY / CONTINUOUS / SEMI_ANNUAL	ANNUAL
Maturity Level	dropdown	✓	L1 / L2 / L3 / L4 / L5	L4
Implementation Status	dropdown	✓	IMPLEMENTED / PARTIAL / PLANNED / NOT_APPLICABLE / NOT_IMPLEMENTED	IMPLEMENTED
Owner	text	—	—	CISO Office

Sheet 13 — Risk Register

Column	Type	Mand.	Validation	Example
Risk Code	text	✓	unique	RSK-2026-001
Title EN	text	✓	—	Aramco contract migration delay
Title AR	text	—	—	■■■■■ ■■■■■ ■■■ ■■■■■■
Category	dropdown	✓	Strategic / Operational / Financial / Cyber / Regulatory / Reputational	Operational
Inherent Likelihood	number	✓	1..5	4
Inherent Impact	number	✓	1..5	4

Column	Type	Mand.	Validation	Example
Residual Likelihood	number	✓	1..5	3
Residual Impact	number	✓	1..5	3
Treatment	dropdown	✓	AVOID / MITIGATE / TRANSFER / ACCEPT	ACCEPT
Owner	text	✓	—	COO
Appetite Band	dropdown	✓	GREEN / AMBER / RED	AMBER
Status	dropdown	✓	DRAFT / ASSESSED / APPROVED / ACCEPTED / MITIGATED / CLOSED	ACCEPTED
Acceptance Expiry	date	—	YYYY-MM-DD	2027-05-11

Sheet 14 — BIA Register

Column	Type	Mand.	Validation	Example
BIA Code	text	✓	unique	BIA-001
Service Name EN	text	✓	—	Customer onboarding & KYC
Service Name AR	text	—	—	■■■■■ ■■■■■■■ ■■■■■■■■■ (KYC)
MTPD (h)	number	✓	≥ 1	24
RTO (h)	number	✓	≤ MTPD	4
RPO (h)	number	✓	≤ MTPD	1
MBCO (%)	number	—	0..100	50
Financial Impact (SAR)	number	—	≥ 0	250000
Regulatory Impact	dropdown	—	LOW / MEDIUM / HIGH / CRITICAL	HIGH
Reputational Impact	dropdown	—	LOW / MEDIUM / HIGH / CRITICAL	MEDIUM
Operational Impact	dropdown	—	LOW / MEDIUM / HIGH / CRITICAL	HIGH
Owner	text	✓	—	Head of Retail
Last Reviewed	date	✓	YYYY-MM-DD	2026-03-15
Status	dropdown	✓	DRAFT / SCORING / IN_REVIEW / APPROVED / SUPERSEDED	APPROVED

Sheet 15 — Supplier Register

Column	Type	Mand.	Validation	Example
Vendor Code	text	✓	unique	VND-0042
Vendor Name EN	text	✓	—	Solutions by STC
Vendor Name AR	text	—	—	■■■■■■ ■■ STC
Country	text	—	ISO-3	SAU
Sector	text	—	—	Telecom
Criticality	dropdown	✓	LOW / MEDIUM / HIGH / CRITICAL	CRITICAL
Contract Start	date	—	YYYY-MM-DD	2024-01-01
Contract End	date	—	YYYY-MM-DD	2027-01-01
Risk Rating	dropdown	✓	LOW / MEDIUM / HIGH / CRITICAL	HIGH
Status	dropdown	✓	DRAFT / KYC_PENDING / ACTIVE / SUSPENDED / CLOSED	ACTIVE
Last Assessment Date	date	—	YYYY-MM-DD	2026-03-15

Sheet 16 — PDPL Processing Register (ROPA)

Column	Type	Mand.	Validation	Example
ROPA Code	text	✓	unique	ROPA-001
Activity Name EN	text	✓	—	Customer onboarding & KYC
Activity Name AR	text	—	—	■■■■■ ■■■■■■■
Purpose	text	✓	—	KYC + AML compliance
Lawful Basis	dropdown	✓	CONSENT / LEGAL_OBLIGATION / CONTRACT / VITAL_INTEREST / PUBLIC_INTEREST / LEGITIMATE_INTEREST	LEGAL_OBLIGATION
Data Categories	text	✓	comma-separated	IDENTITY, CONTACT, FINANCIAL
Data Subjects	text	✓	—	CUSTOMER
Source Asset	text	—	—	SQL Server primary (DB-PRIMARY)
Residency	text	—	ISO-3	SAU
Cross-Border	dropdown	✓	YES / NO	NO
Retention (days)	number	—	≥ 0	3650
Owner	text	✓	—	DPO

Column	Type	Mand.	Validation	Example
Last Reviewed	date	✓	YYYY-MM-DD	2026-03-27
Status	dropdown	✓	DRAFT / ACTIVE / ARCHIVED	ACTIVE

Sheet 17 — NCA Assessment Register

Column	Type	Mand.	Validation	Example
Assessment Code	text	✓	unique	NCA-ECC-2026-Q1
Framework	dropdown	✓	NCA ECC / NCA CSCC / NCA CCC / NCA OTCC	NCA ECC
Control Code	dropdown	✓	from Sheet 12	ECC-1-1
Assessment Type	dropdown	✓	SELF / EXTERNAL / REGULATOR	SELF
Maturity Level	dropdown	✓	L1..L5	L4
Implementation Status	dropdown	✓	IMPLEMENTED / PARTIAL / PLANNED / NOT_APPLICABLE / NOT_IMPLEMENTED	IMPLEMENTED
Evidence Refs	text	—	comma-separated	EV-2026-CISO-STRAT
Assessor	text	✓	—	CISO Office
Assessed At	date	✓	YYYY-MM-DD	2026-04-01
Approver	text	—	—	CISO
Approved At	date	—	YYYY-MM-DD	2026-04-10
Status	dropdown	✓	DRAFT / IN_REVIEW / APPROVED / FILED	APPROVED

Sheet 18 — Incident Register

Column	Type	Mand.	Validation	Example
Incident Code	text	✓	unique	INC-2026-001
Title EN	text	✓	—	Phishing campaign affecting finance team
Title AR	text	—	—	■■■■ ■■■■ ■■■■ ■■■■ ■■■■■■■
Severity	dropdown	✓	LOW / MEDIUM / HIGH / CRITICAL	HIGH
Classification	dropdown	✓	CYBER / PHYSICAL / OPERATIONAL / VENDOR / PRIVACY	CYBER
Detected At	date	✓	YYYY-MM-DD	2026-04-19

Column	Type	Mand.	Validation	Example
Phase	dropdown	✓	DETECTION / ANALYSIS / CONTAINMENT / ERADICATION / RECOVERY / POST_INCIDENT / LESSONS_LEARNED / CLOSED	LESSONS_LEARNED
Impacted Assets	text	—	comma-separated	DB-PRIMARY, MAIL-GW
Regulator Notified	dropdown	✓	YES / NO	YES
Notification Reference	text	—	—	NCA-2026-1023
Assignee	text	✓	—	SOC Lead
Linked Breach	text	—	—	BR-2026-005

Sheet 19 — Corrective Action Register

Column	Type	Mand.	Validation	Example
CAPA Code	text	✓	unique	CAPA-202604-0011
Origin Type	dropdown	✓	rca / processor_assessment / supplier_resilience_test / fourth_party_exposure / audit_finding / bia_gap / kri_breach / compliance_gap	processor_assessment
Origin ID	text	✓	—	PROC-2026-008
Title EN	text	✓	—	PDPL Art. 28 FAIL — Sentry IO
Title AR	text	—	—	■■■■■ ■■■■■■ 28 — Sentry IO
Type	dropdown	✓	CORRECTIVE / PREVENTIVE	CORRECTIVE
Severity	dropdown	✓	LOW / MEDIUM / HIGH / CRITICAL	CRITICAL
Owner Role	text	✓	—	DPO
Target Date	date	✓	YYYY-MM-DD	2026-06-25
Status	dropdown	✓	OPEN / IN_PROGRESS / AWAITING_VERIFICATION / CLOSED / CANCELLED	OPEN

Sheet 20 — Reports Catalogue

Column	Type	Mand.	Validation	Example
Report Code	text	✓	unique	RPT_BOARD_RISK

Column	Type	Mand.	Validation	Example
Title EN	text	✓	—	Board Risk Report
Title AR	text	✓	—	■■■■■ ■■■■■■■ ■■■■■ ■■■■■■■
Audience	text	✓	—	Board, CRO, Audit Committee
Cadence	dropdown	✓	QUARTERLY / MONTHLY / ANNUAL / ON_DEMAND	QUARTERLY
Formats	text	✓	comma-separated	PDF, PPTX, XLSX
Signature Required	dropdown	✓	YES / NO	YES
Approver	text	✓	—	Chairman

Sheet 21 — Automation Rules

Column	Type	Mand.	Validation	Example
Rule Code	text	✓	unique	RULE_PROC_FAIL_CAPA
Trigger	text	✓	—	ProcessorAssessment.scoreAndComplete
Condition	text	✓	—	overallOutcome = FAIL
Action	text	✓	—	Create CAPA with originType=processor_assessment
Notify	text	—	—	DPO, CISO
Escalation	text	—	—	day-45 if not started
Suppressable	dropdown	✓	YES / NO	YES
Module	dropdown	✓	from Sheet 1	PRIVACY

Sheet 22 — Test Cases

Column	Type	Mand.	Validation	Example
Test Case ID	text	✓	unique	TC-PROC-FAIL-001
Workflow Code	dropdown	✓	from Sheet 2	PROCESSOR_ASSESSMENT
Scenario	text	✓	—	Score processor with c4 FAIL
Preconditions	text	✓	—	IN_PROGRESS assessment exists
Steps	text	✓	numbered	1. Open assessment. 2. Submit c4=FAIL. 3. Confirm.
Expected Result	text	✓	—	overallOutcome FAIL; CAPA opened

Column	Type	Mand.	Validation	Example
User Role	text	✓	—	DPO
Pass/Fail Criteria	text	✓	—	New row in capa.tasks

Sheet 23 — Sample Data

Column	Type	Mand.	Validation	Example
Entity	dropdown	✓	Organisation / User / Service / Asset / Vendor / Risk / Processing Activity / Incident / Breach / CAPA / Evidence / Policy / Framework / Control	Risk
Tenant	text	✓	—	tss-bank
Code	text	✓	—	RSK-2026-001
Title EN	text	✓	—	Aramco contract migration delay
Title AR	text	—	—	■■■■■ ■■■■■ ■■■ ■■■■■■
Created At	date	✓	YYYY-MM-DD	2026-01-15
Status	text	✓	—	ACCEPTED
Notes	text	—	—	Linked to acceptance ACC-2026-007

How to consume

- **BA / config consultant:** copy the workbook, fill the rows, send it back to engineering — every column maps to a backend field. The `Validation` column tells you what values are legal.
- **Customer DBA:** the `Schema` + `Table Name` columns in Sheet 6 are the canonical mapping; foreign keys in Sheet 7 give the join paths.
- **QA:** Sheets 22 + 23 are directly importable into a test-management tool.
- **Regulator audit:** Sheets 10 (Evidence), 11 (Regulatory Mapping), 17 (NCA Assessment Register) cover the typical audit-evidence questionnaire.

A working `.xlsx` is committed alongside this file at `./tss-grc-implementation-package.xlsx`. Open in any spreadsheet client; no macros, no external links.